



CIS Critical Security Controls 8.1

Companion Guide for VMware Cloud Foundation 9.1

June 2026

Table of Contents

Disclaimer..... 8

Version..... 9

Introduction..... 9

Third Party Identifiers and Mappings 9

Coverage Levels 9

Controls..... 10

 Control 1.0..... 10

 Control 1.1..... 13

 Control 1.2..... 17

 Control 1.3..... 20

 Control 1.4..... 23

 Control 1.5..... 24

 Control 2.0..... 27

 Control 2.1..... 31

 Control 2.2..... 34

 Control 2.3..... 37

 Control 2.4..... 41

 Control 2.5..... 46

 Control 2.6..... 50

 Control 2.7..... 54

 Control 3.0..... 60

 Control 3.1..... 66

 Control 3.2..... 73

 Control 3.3..... 74

 Control 3.4..... 80

 Control 3.5..... 83

 Control 3.6..... 85

 Control 3.7..... 92

 Control 3.8..... 93

 Control 3.9..... 96

 Control 3.11..... 103

 Control 3.12..... 110

 Control 3.13..... 112

Control 3.14	113
Control 4.0	118
Control 4.1	123
Control 4.2	129
Control 4.3	135
Control 4.4	141
Control 4.5	147
Control 4.6	153
Control 4.7	159
Control 4.8	165
Control 4.9	171
Control 4.11	173
Control 4.12	174
Control 5.0	175
Control 5.1	179
Control 5.2	185
Control 5.3	190
Control 5.4	192
Control 5.5	198
Control 5.6	202
Control 6.0	207
Control 6.1	212
Control 6.2	216
Control 6.3	220
Control 6.4	221
Control 6.5	222
Control 6.6	224
Control 6.7	229
Control 6.8	234
Control 7.0	240
Control 7.1	244
Control 7.2	248
Control 7.3	252
Control 7.4	256

Control 7.5	260
Control 7.6	263
Control 7.7	266
Control 8.0	270
Control 8.1	276
Control 8.2	281
Control 8.3	287
Control 8.4	292
Control 8.5	296
Control 8.6	301
Control 8.7	305
Control 8.8	309
Control 8.9	314
Control 8.11	318
Control 8.12	322
Control 9.0	326
Control 9.1	328
Control 9.2	329
Control 9.3	331
Control 9.4	333
Control 9.5	334
Control 9.6	335
Control 9.7	340
Control 10.0	341
Control 10.1	345
Control 10.2	349
Control 10.3	350
Control 10.4	356
Control 10.5	362
Control 10.6	368
Control 10.7	370
Control 11.0	372
Control 11.1	377
Control 11.2	381

Control 11.3	387
Control 11.4	393
Control 11.5	395
Control 12.0	400
Control 12.1	404
Control 12.2	408
Control 12.3	412
Control 12.4	416
Control 12.5	419
Control 12.6	424
Control 12.7	429
Control 12.8	433
Control 13.0	436
Control 13.1	442
Control 13.2	447
Control 13.3	450
Control 13.4	452
Control 13.5	455
Control 13.6	460
Control 13.7	466
Control 13.8	469
Control 13.9	471
Control 13.11	474
Control 14.0	478
Control 14.1	479
Control 14.2	480
Control 14.3	481
Control 14.4	482
Control 14.5	483
Control 14.6	484
Control 14.7	485
Control 14.8	486
Control 14.9	487
Control 15.0	488

Control 15.1	489
Control 15.2	490
Control 15.3	491
Control 15.4	492
Control 15.5	496
Control 15.6	497
Control 15.7	498
Control 16.0	499
Control 16.1	500
Control 16.2	504
Control 16.3	505
Control 16.4	506
Control 16.5	507
Control 16.6	509
Control 16.7	510
Control 16.8	516
Control 16.9	519
Control 16.11	520
Control 16.12	521
Control 16.13	522
Control 16.14	523
Control 17.0	524
Control 17.1	528
Control 17.2	529
Control 17.3	533
Control 17.4	537
Control 17.5	541
Control 17.6	545
Control 17.7	549
Control 17.8	550
Control 17.9	551
Control 18.0	555
Control 18.1	556
Control 18.2	557

Control 18.3	558
Control 18.4	562
Control 18.5	566

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260612-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations aligning with the CIS Critical Security Controls 8.1. The CIS Critical Security Controls are a prioritized set of safeguards to mitigate the most prevalent cyber attacks against systems and networks, organized into 18 controls whose safeguards are grouped into three Implementation Groups. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for selecting and implementing safeguards remains with the organization.

<https://www.cisecurity.org/controls>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 1.0

> Inventory and Control of Enterprise Assets: Actively manage (inventory, track, and correct) all enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/Internet of Things (IoT) devices; and servers) connected to the infrastructure physically, virtually, remotely, and those within cloud environments, to accurately know the totality of assets that need to be monitored and protected within the enterprise. This will also support identifying unauthorized and unmanaged assets to remove or remediate.

SCF Controls: AST-01, AST-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf

agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 1.1

> Establish and Maintain Detailed Enterprise Asset Inventory

SCF Controls: AST-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 1.2

> Address Unauthorized Assets

SCF Controls: AST-02.2, NET-08.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated monitoring, compliance checking, and alerting mechanisms that detect unauthorized hardware, software, and firmware components within the managed infrastructure. These mechanisms span hardware attestation, host software compliance, firmware compliance, configuration drift detection, and event-driven alarm frameworks, with multiple delivery channels for alert integration.

At the hardware and firmware level, VMware ESX hosts support Secure Boot, Trusted Platform Modules (TPM), and hardware attestation capabilities. VMware vCenter can retrieve TPM event logs and manage TPM endorsement keys through the Trusted Infrastructure API, allowing administrators to validate boot-time measurements and verify that hosts have booted in known-good configurations. TPM module status must be verified during upgrades, and modules must be running the latest 2.0 firmware. VCF Operations also provides hardware-level monitoring through management packs that generate alerts for physical server events, supporting detection of hardware status changes that could indicate unauthorized physical component modifications on supported server platforms.

For host software, vSphere Lifecycle Manager (vLCM) defines a desired-state software image for each cluster and checks host compliance against that image. Hosts that deviate from the approved image are flagged as non-compliant, and the VCF Operations API supports programmatic image compliance checks. vLCM compliance checks also cover firmware: when checking a cluster against its desired-state image, driver and firmware versions are included, so hosts with non-compliant firmware are flagged alongside software deviations. vSphere Configuration Profiles extend this model to host configuration settings, managing all hosts in a cluster collectively and detecting when individual host configurations drift from the cluster-level specification. When drift is detected, automated remediation can bring hosts back into compliance.

At the infrastructure operations layer, VCF Operations provides configuration drift detection for vCenter instances and vSphere clusters. Administrators define configuration templates that represent the desired state, and VCF Operations compares current values against those templates. Deviations appear in the Configuration Drifts dashboard, and drift detection can be scheduled to run automatically at a chosen interval. Configuration templates can also be integrated with a source control repository for versioning, auditing, and change control. VCF Operations tracks the state of configuration templates in source control and detects when the current template does not reflect the desired state.

VCF Operations includes a compliance alerting engine that can be configured to trigger alerts on vCenter instances, ESX hosts, virtual machines, distributed port groups, and distributed switches. These compliance alerts detect configuration drift from approved baselines, which can surface unauthorized software installations, unexpected configuration changes, or components that do not conform to the organization's approved standards. Administrators activate compliance packs containing policies and alert definitions for their environment. When objects fall out of compliance, alerts are generated as violations with triggered symptoms representing the specific rules that were broken. Custom compliance benchmarks can be created to monitor selected alert definitions and policies tailored to organizational requirements.

vCenter provides an event-driven alarm framework that can monitor virtual machine reconfigurations and host status changes. Administrators can create alarm definitions using the vCenter client or VCF PowerCLI to watch for specific events, such as virtual machine reconfigurations that might indicate unauthorized software or hardware changes. Each alarm rule monitors a single event type, so organizations must define multiple rules to cover the range of changes that could indicate unauthorized components. VCF PowerCLI supports programmatic creation and modification of alarm definitions, enabling automation of alarm rule deployment across the environment.

VCF provides a device interaction isolation control (`isolation.device.edit.disable`) that restricts modification of virtual machine devices. When enabled, this setting limits the ability of users within a virtual machine to add or modify virtual hardware, reducing the risk of unauthorized device additions at the VM level.

VCF Operations for Networks supports intent-based detection of default manufacturer passwords on network devices, flagging devices that still have factory credentials in place. The Management Pack for Network Devices collects hardware and software details from network devices across all vendors, including manufacturer name, product name, serial number, and version information.

For alert delivery, VCF supports multiple notification channels to integrate with broader security monitoring infrastructure. vCenter can send SNMP traps and email notifications when alarms are triggered. vCenter's SNMP agent supports v1, v2c, and v3 traps; v3 traps support all security levels, providing authenticated and encrypted trap delivery to management systems. VCF Operations supports outbound SNMP trap notifications to up to four trap destinations, with filtering capabilities to control which alerts generate notifications. VCF Operations can also stream system alerts through its databus, and log-based alerts can be configured through Symptom Definitions in Infrastructure Operations to detect patterns in log data that may indicate unauthorized activity. These delivery mechanisms allow VCF alerts to feed into enterprise SIEM systems or other centralized monitoring platforms where correlation with asset inventory data can identify unauthorized components.

For container workloads on VMware Kubernetes Service (VKS), the Consumption layer extends detection and alerting coverage across the software component supply chain. VCF CLI supports cosign signatures for container image verification, and registry authentication controls restrict which registries can serve container images to the environment. VKS image registry policies support a Warn mode that provides immediate feedback when a potential denial occurs, allowing organizations to observe policy impact before enforcing it in a full blocking mode. VCF Operations validates management pack PAK files against digital signatures, displaying a warning if a PAK file is not signed with a VMware-provided digital signature, which helps detect unauthorized or tampered management pack components.

Kubernetes admission controllers running on VKS intercept all API requests before resources are persisted, providing a centralized enforcement point for image authorization decisions. The Image Policy Webhook admission controller evaluates container images against an external backend, supporting registry allowlists and signature verification requirements. Validating and mutating webhook admission controllers can be configured to assess images against an external policy service before pods are admitted. Pod Security Admission enforces security profiles at the namespace level using Baseline, Restricted, and Privileged modes; the Restricted profile blocks pods that run as root, mount sensitive host paths, or use privileged containers, restricting the workload configurations that can be deployed and reducing the opportunities for unauthorized component introduction. Harbor integration provides container image signing and continuous vulnerability scanning; admission policies can require valid signatures before images are deployed to any namespace, and images that fail scanning thresholds can be blocked from deployment.

The Kubernetes API server on VKS records all API interactions, including attempts to create, modify, or delete workloads. Audit policy can be configured to capture request metadata, request body, and response body at configurable verbosity levels for each API resource and verb combination, recording the identity of service accounts or users that attempted to deploy workloads, the resources affected, and the outcome of each request. Audit events can be delivered to a webhook backend or written to log files for forwarding to a centralized log management system where they can be correlated and alerted on.

Prometheus with Alertmanager is available as a standard package on VKS clusters. The Prometheus Operator deploys Alertmanager as a highly available StatefulSet in the `tanzu-system-monitoring` namespace, where it receives alerts from Prometheus instances and routes them to external notification endpoints based on rules defined in the `AlertmanagerConfig` custom resource. The `AlertmanagerConfig` resource specifies how alerts are grouped, inhibited, and notified to external systems, supporting delivery to email, Slack, PagerDuty, and webhook endpoints. Organizations can define Prometheus alerting rules that trigger when unexpected workloads appear, resource consumption deviates from baselines, or compliance checks fail against known-good states.

The Harness CI/CD platform, available as a VKS service, provides integrated security scanning through Wiz and observability through Dynatrace within the deployment pipeline, performing pre-deployment vulnerability scanning and post-deployment performance verification. Dynatrace's AI engine automatically detects anomalies, identifies root causes, and delivers intelligent alerts for unusual runtime behavior patterns, complementing the rule-based alerting available through Prometheus. Security Technical Implementation Guides (STIGs) for Supervisor components and VMware Kubernetes Release (VKr) deployments are

available through Tanzu STIG Hardening to guide platform hardening, making deviations from expected configuration easier to detect and supporting the broader goal of identifying unauthorized changes to system components.

Together these capabilities provide automated detection and alerting for unauthorized components across hardware, firmware, host software, configuration, and container workload dimensions of the full VCF platform stack.

VMware vDefend (Meets)

VMware vDefend contributes to the detection of unauthorized components through its network-layer detection and prevention capabilities. While vDefend does not perform hardware or firmware inventory, it provides several mechanisms that can surface evidence of unauthorized software components and rogue devices communicating on the network.

vDefend IDS/IPS inspects east-west and north-south traffic for signatures associated with known malware, exploit kits, command-and-control communication, and other indicators of unauthorized software operating within the environment. IDS/IPS detects specific threats including command-and-control traffic and network trojans such as Remcos RAT through signature-based matching. When an unauthorized software component begins communicating, IDS/IPS signature matching can detect that traffic and generate alerts or block it. IDS/IPS supports both Distributed and Gateway deployment models, covering traffic between workloads and traffic entering or leaving the environment. Both Distributed and Gateway IDS/IPS offer a Detect Only option that records detections against signatures without blocking traffic, providing initial visibility without operational disruption. Administrators can monitor IDS/IPS events through the Security dashboard and filter by signature action to distinguish among events categorized as Dropped, Rejected, or Alert, and can filter by Signature Type to distinguish between system-provided and custom signatures. When a signature triggers, vDefend IDS/IPS automatically generates Packet Capture (PCAP) files for forensic review. Detailed event data is also written to the nsx-idps-events.log file on each ESX host in the /var/log/nsx-idps directory, recording all alerts, drops, and rejects with associated metadata.

vDefend Malware Prevention extends detection to file-level analysis. When files traverse the network, the Malware Prevention Service inspects them for known and unknown malware using cloud-based and local analysis. Gateway Firewall rules for Malware Prevention can be configured in Detect Only mode, generating alerts without blocking traffic when initial detection and visibility are the priority. This provides an automated mechanism for detecting unauthorized software that may have been introduced into the environment. Malware Prevention deployment status and error reporting are accessible through the Security > IDS/IPS & Malware Prevention > Settings > Define Scope interface.

vDefend Network Detection and Response (NDR) and Security Intelligence analyze network traffic flows to identify anomalous communication patterns. Unauthorized or rogue components that communicate on the network produce traffic that deviates from established baselines. NDR correlates events across multiple detection sources and can surface indicators of compromise that point to unauthorized software or devices. NDR integrates with external SIEMs, sending campaign and event logs as they occur for detection events, detection updates, and new campaign creation. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, providing ongoing visibility as network communication patterns change.

Security Services Platform provides suspicious traffic detection through configurable detectors that analyze network behavior. Administrators can view detector activation status, manage detected events, and review the source and destination VMs involved in suspicious traffic. NTA detectors can be selectively activated or deactivated, and alarm definitions can be enabled or disabled by authorized users to manage alerting scope.

vDefend policy provides a complementary layer by enforcing microsegmentation rules that restrict which workloads can communicate with each other. When unauthorized components attempt to communicate across segment boundaries, the Distributed Firewall blocks those connections and logs the attempts. This posture means that even if an unauthorized component is introduced, its lateral movement is restricted and firewall rule violations are visible in the DFW audit log.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 1.3

> Utilize an Active Discovery Tool

SCF Controls: AST-02.2, AST-02.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated monitoring, compliance checking, and alerting mechanisms that detect unauthorized hardware, software, and firmware components within the managed infrastructure. These mechanisms span hardware attestation, host software compliance, firmware compliance, configuration drift detection, and event-driven alarm frameworks, with multiple delivery channels for alert integration.

At the hardware and firmware level, VMware ESX hosts support Secure Boot, Trusted Platform Modules (TPM), and hardware attestation capabilities. VMware vCenter can retrieve TPM event logs and manage TPM endorsement keys through the Trusted Infrastructure API, allowing administrators to validate boot-time measurements and verify that hosts have booted in known-good configurations. TPM module status must be verified during upgrades, and modules must be running the latest 2.0 firmware. VCF Operations also provides hardware-level monitoring through management packs that generate alerts for physical server events, supporting detection of hardware status changes that could indicate unauthorized physical component modifications on supported server platforms.

For host software, vSphere Lifecycle Manager (vLCM) defines a desired-state software image for each cluster and checks host compliance against that image. Hosts that deviate from the approved image are flagged as non-compliant, and the VCF Operations API supports programmatic image compliance checks. vLCM compliance checks also cover firmware: when checking a cluster against its desired-state image, driver and firmware versions are included, so hosts with non-compliant firmware are flagged alongside software deviations. vSphere Configuration Profiles extend this model to host configuration settings, managing all hosts in a cluster collectively and detecting when individual host configurations drift from the cluster-level specification. When drift is detected, automated remediation can bring hosts back into compliance.

At the infrastructure operations layer, VCF Operations provides configuration drift detection for vCenter instances and vSphere clusters. Administrators define configuration templates that represent the desired state, and VCF Operations compares current values against those templates. Deviations appear in the Configuration Drifts dashboard, and drift detection can be scheduled to run automatically at a chosen interval. Configuration templates can also be integrated with a source control repository for versioning, auditing, and change control. VCF Operations tracks the state of configuration templates in source control and detects when the current template does not reflect the desired state.

VCF Operations includes a compliance alerting engine that can be configured to trigger alerts on vCenter instances, ESX hosts, virtual machines, distributed port groups, and distributed switches. These compliance alerts detect configuration drift from approved baselines, which can surface unauthorized software installations, unexpected configuration changes, or components that do not conform to the organization's approved standards. Administrators activate compliance packs containing policies and alert definitions for their environment. When objects fall out of compliance, alerts are generated as violations with triggered symptoms representing the specific rules that were broken. Custom compliance benchmarks can be created to monitor selected alert definitions and policies tailored to organizational requirements.

vCenter provides an event-driven alarm framework that can monitor virtual machine reconfigurations and host status changes. Administrators can create alarm definitions using the vCenter client or VCF PowerCLI to watch for specific events, such as virtual machine reconfigurations that might indicate unauthorized software or hardware changes. Each alarm rule monitors a single event type, so organizations must define multiple rules to cover the range of changes that could indicate unauthorized components. VCF PowerCLI supports programmatic creation and modification of alarm definitions, enabling automation of alarm rule deployment across the environment.

VCF provides a device interaction isolation control (`isolation.device.edit.disable`) that restricts modification of virtual machine devices. When enabled, this setting limits the ability of users within a virtual machine to add or modify virtual hardware, reducing the risk of unauthorized device additions at the VM level.

VCF Operations for Networks supports intent-based detection of default manufacturer passwords on network devices, flagging devices that still have factory credentials in place. The Management Pack for Network Devices collects hardware and software details from network devices across all vendors, including manufacturer name, product name, serial number, and version information.

For alert delivery, VCF supports multiple notification channels to integrate with broader security monitoring infrastructure. vCenter can send SNMP traps and email notifications when alarms are triggered. vCenter's SNMP agent supports v1, v2c, and v3 traps; v3 traps support all security levels, providing authenticated and encrypted trap delivery to management systems. VCF Operations supports outbound SNMP trap notifications to up to four trap destinations, with filtering capabilities to control which alerts generate notifications. VCF Operations can also stream system alerts through its databus, and log-based alerts can be configured through Symptom Definitions in Infrastructure Operations to detect patterns in log data that may indicate unauthorized activity. These delivery mechanisms allow VCF alerts to feed into enterprise SIEM systems or other centralized monitoring platforms where correlation with asset inventory data can identify unauthorized components.

For container workloads on VMware Kubernetes Service (VKS), the Consumption layer extends detection and alerting coverage across the software component supply chain. VCF CLI supports cosign signatures for container image verification, and registry authentication controls restrict which registries can serve container images to the environment. VKS image registry policies support a Warn mode that provides immediate feedback when a potential denial occurs, allowing organizations to observe policy impact before enforcing it in a full blocking mode. VCF Operations validates management pack PAK files against digital signatures, displaying a warning if a PAK file is not signed with a VMware-provided digital signature, which helps detect unauthorized or tampered management pack components.

Kubernetes admission controllers running on VKS intercept all API requests before resources are persisted, providing a centralized enforcement point for image authorization decisions. The Image Policy Webhook admission controller evaluates container images against an external backend, supporting registry allowlists and signature verification requirements. Validating and mutating webhook admission controllers can be configured to assess images against an external policy service before pods are admitted. Pod Security Admission enforces security profiles at the namespace level using Baseline, Restricted, and Privileged modes; the Restricted profile blocks pods that run as root, mount sensitive host paths, or use privileged containers, restricting the workload configurations that can be deployed and reducing the opportunities for unauthorized component introduction. Harbor integration provides container image signing and continuous vulnerability scanning; admission policies can require valid signatures before images are deployed to any namespace, and images that fail scanning thresholds can be blocked from deployment.

The Kubernetes API server on VKS records all API interactions, including attempts to create, modify, or delete workloads. Audit policy can be configured to capture request metadata, request body, and response body at configurable verbosity levels for each API resource and verb combination, recording the identity of service accounts or users that attempted to deploy workloads, the resources affected, and the outcome of each request. Audit events can be delivered to a webhook backend or written to log files for forwarding to a centralized log management system where they can be correlated and alerted on.

Prometheus with Alertmanager is available as a standard package on VKS clusters. The Prometheus Operator deploys Alertmanager as a highly available StatefulSet in the tanzu-system-monitoring namespace, where it receives alerts from Prometheus instances and routes them to external notification endpoints based on rules defined in the AlertmanagerConfig custom resource. The AlertmanagerConfig resource specifies how alerts are grouped, inhibited, and notified to external systems, supporting delivery to email, Slack, PagerDuty, and webhook endpoints. Organizations can define Prometheus alerting rules that trigger when unexpected workloads appear, resource consumption deviates from baselines, or compliance checks fail against known-good states.

The Harness CI/CD platform, available as a VKS service, provides integrated security scanning through Wiz and observability through Dynatrace within the deployment pipeline, performing pre-deployment vulnerability scanning and post-deployment performance verification. Dynatrace's AI engine automatically detects anomalies, identifies root causes, and delivers intelligent alerts for unusual runtime behavior patterns, complementing the rule-based alerting available through Prometheus. Security Technical Implementation Guides (STIGs) for Supervisor components and VMware Kubernetes Release (VKr) deployments are

available through Tanzu STIG Hardening to guide platform hardening, making deviations from expected configuration easier to detect and supporting the broader goal of identifying unauthorized changes to system components.

Together these capabilities provide automated detection and alerting for unauthorized components across hardware, firmware, host software, configuration, and container workload dimensions of the full VCF platform stack.

VMware vDefend (Contributes)

VMware vDefend contributes to the detection of unauthorized components through its network-layer detection and prevention capabilities. While vDefend does not perform hardware or firmware inventory, it provides several mechanisms that can surface evidence of unauthorized software components and rogue devices communicating on the network.

vDefend IDS/IPS inspects east-west and north-south traffic for signatures associated with known malware, exploit kits, command-and-control communication, and other indicators of unauthorized software operating within the environment. IDS/IPS detects specific threats including command-and-control traffic and network trojans such as Remcos RAT through signature-based matching. When an unauthorized software component begins communicating, IDS/IPS signature matching can detect that traffic and generate alerts or block it. IDS/IPS supports both Distributed and Gateway deployment models, covering traffic between workloads and traffic entering or leaving the environment. Both Distributed and Gateway IDS/IPS offer a Detect Only option that records detections against signatures without blocking traffic, providing initial visibility without operational disruption. Administrators can monitor IDS/IPS events through the Security dashboard and filter by signature action to distinguish among events categorized as Dropped, Rejected, or Alert, and can filter by Signature Type to distinguish between system-provided and custom signatures. When a signature triggers, vDefend IDS/IPS automatically generates Packet Capture (PCAP) files for forensic review. Detailed event data is also written to the nsx-idps-events.log file on each ESX host in the /var/log/nsx-idps directory, recording all alerts, drops, and rejects with associated metadata.

vDefend Malware Prevention extends detection to file-level analysis. When files traverse the network, the Malware Prevention Service inspects them for known and unknown malware using cloud-based and local analysis. Gateway Firewall rules for Malware Prevention can be configured in Detect Only mode, generating alerts without blocking traffic when initial detection and visibility are the priority. This provides an automated mechanism for detecting unauthorized software that may have been introduced into the environment. Malware Prevention deployment status and error reporting are accessible through the Security > IDS/IPS & Malware Prevention > Settings > Define Scope interface.

vDefend Network Detection and Response (NDR) and Security Intelligence analyze network traffic flows to identify anomalous communication patterns. Unauthorized or rogue components that communicate on the network produce traffic that deviates from established baselines. NDR correlates events across multiple detection sources and can surface indicators of compromise that point to unauthorized software or devices. NDR integrates with external SIEMs, sending campaign and event logs as they occur for detection events, detection updates, and new campaign creation. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, providing ongoing visibility as network communication patterns change.

Security Services Platform provides suspicious traffic detection through configurable detectors that analyze network behavior. Administrators can view detector activation status, manage detected events, and review the source and destination VMs involved in suspicious traffic. NTA detectors can be selectively activated or deactivated, and alarm definitions can be enabled or disabled by authorized users to manage alerting scope.

vDefend policy provides a complementary layer by enforcing microsegmentation rules that restrict which workloads can communicate with each other. When unauthorized components attempt to communicate across segment boundaries, the Distributed Firewall blocks those connections and logs the attempts. This posture means that even if an unauthorized component is introduced, its lateral movement is restricted and firewall rule violations are visible in the DFW audit log.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 1.4

> Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory

SCF Controls: AST-02.6

Aggregate Coverage: Meets

VCF (Meets)

VCF provides DHCP services through NSX, including built-in audit logging for DHCP operations to support asset inventory maintenance and unknown system detection.

NSX generates audit events for all DHCP configuration changes, including creation, modification, and deletion of DHCP profiles, static bindings, and IP pools. The NSX DHCP Create Audit Events widget displays all DHCP create audit events in a single view. NSX controllers also report DHCP log errors through audit logging, providing visibility into DHCP service health and activity within the environment.

NSX Manager supports forwarding DHCP-related logs to external log management systems through its remote logging configuration. The `set logging-server` CLI command configures remote logging with a target hostname or IP address, protocol, log level, facility, message ID filters, and certificate parameters. The `get logging-servers` command displays the current remote logging configuration, including server address, protocol, log level, and facility settings. Forwarding DHCP logs to a centralized log management platform allows organizations to correlate DHCP lease activity with asset inventory records and identify unknown or unauthorized systems requesting addresses.

NSX provides DHCP Snooping through the IP Discovery segment profile, which monitors DHCP traffic in IPv4 environments. DHCP Snooping builds a binding table of MAC addresses, IP addresses, and associated network segments, which is a supplemental data source for asset tracking and detecting unrecognized devices on the network.

Several NSX API endpoints support programmatic monitoring of DHCP service state. GET endpoints allow querying the realized state of DHCP server configurations, static bindings, IP pools, and DHCP relay services. POST, PUT, and DELETE endpoints are available for managing DHCP relay services. These APIs allow integration with external asset management and monitoring tools that can track DHCP allocations and flag unrecognized devices.

VCF Operations for Networks provides network auto discovery capabilities that complement NSX DHCP logging. Device Auto Discovery allows creation of discovery profiles to discover network devices using either a seed IP or an IP range, scanning defined address ranges to identify systems on the network. This is an additional mechanism for detecting unknown devices beyond DHCP log analysis.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 1.5

> Use a Passive Asset Discovery Tool

SCF Controls: AST-02.2, AST-02.6

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated monitoring, compliance checking, and alerting mechanisms that detect unauthorized hardware, software, and firmware components within the managed infrastructure. These mechanisms span hardware attestation, host software compliance, firmware compliance, configuration drift detection, and event-driven alarm frameworks, with multiple delivery channels for alert integration.

At the hardware and firmware level, VMware ESX hosts support Secure Boot, Trusted Platform Modules (TPM), and hardware attestation capabilities. VMware vCenter can retrieve TPM event logs and manage TPM endorsement keys through the Trusted Infrastructure API, allowing administrators to validate boot-time measurements and verify that hosts have booted in known-good configurations. TPM module status must be verified during upgrades, and modules must be running the latest 2.0 firmware. VCF Operations also provides hardware-level monitoring through management packs that generate alerts for physical server events, supporting detection of hardware status changes that could indicate unauthorized physical component modifications on supported server platforms.

For host software, vSphere Lifecycle Manager (vLCM) defines a desired-state software image for each cluster and checks host compliance against that image. Hosts that deviate from the approved image are flagged as non-compliant, and the VCF Operations API supports programmatic image compliance checks. vLCM compliance checks also cover firmware: when checking a cluster against its desired-state image, driver and firmware versions are included, so hosts with non-compliant firmware are flagged alongside software deviations. vSphere Configuration Profiles extend this model to host configuration settings, managing all hosts in a cluster collectively and detecting when individual host configurations drift from the cluster-level specification. When drift is detected, automated remediation can bring hosts back into compliance.

At the infrastructure operations layer, VCF Operations provides configuration drift detection for vCenter instances and vSphere clusters. Administrators define configuration templates that represent the desired state, and VCF Operations compares current values against those templates. Deviations appear in the Configuration Drifts dashboard, and drift detection can be scheduled to run automatically at a chosen interval. Configuration templates can also be integrated with a source control repository for versioning, auditing, and change control. VCF Operations tracks the state of configuration templates in source control and detects when the current template does not reflect the desired state.

VCF Operations includes a compliance alerting engine that can be configured to trigger alerts on vCenter instances, ESX hosts, virtual machines, distributed port groups, and distributed switches. These compliance alerts detect configuration drift from approved baselines, which can surface unauthorized software installations, unexpected configuration changes, or components that do not conform to the organization's approved standards. Administrators activate compliance packs containing policies and alert definitions for their environment. When objects fall out of compliance, alerts are generated as violations with triggered symptoms representing the specific rules that were broken. Custom compliance benchmarks can be created to monitor selected alert definitions and policies tailored to organizational requirements.

vCenter provides an event-driven alarm framework that can monitor virtual machine reconfigurations and host status changes. Administrators can create alarm definitions using the vCenter client or VCF PowerCLI to watch for specific events, such as virtual machine reconfigurations that might indicate unauthorized software or hardware changes. Each alarm rule monitors a single event type, so organizations must define multiple rules to cover the range of changes that could indicate unauthorized components. VCF PowerCLI supports programmatic creation and modification of alarm definitions, enabling automation of alarm rule deployment across the environment.

VCF provides a device interaction isolation control (`isolation.device.edit.disable`) that restricts modification of virtual machine devices. When enabled, this setting limits the ability of users within a virtual machine to add or modify virtual hardware, reducing the risk of unauthorized device additions at the VM level.

VCF Operations for Networks supports intent-based detection of default manufacturer passwords on network devices, flagging devices that still have factory credentials in place. The Management Pack for Network Devices collects hardware and software details from network devices across all vendors, including manufacturer name, product name, serial number, and version information.

For alert delivery, VCF supports multiple notification channels to integrate with broader security monitoring infrastructure. vCenter can send SNMP traps and email notifications when alarms are triggered. vCenter's SNMP agent supports v1, v2c, and v3 traps; v3 traps support all security levels, providing authenticated and encrypted trap delivery to management systems. VCF Operations supports outbound SNMP trap notifications to up to four trap destinations, with filtering capabilities to control which alerts generate notifications. VCF Operations can also stream system alerts through its databus, and log-based alerts can be configured through Symptom Definitions in Infrastructure Operations to detect patterns in log data that may indicate unauthorized activity. These delivery mechanisms allow VCF alerts to feed into enterprise SIEM systems or other centralized monitoring platforms where correlation with asset inventory data can identify unauthorized components.

For container workloads on VMware Kubernetes Service (VKS), the Consumption layer extends detection and alerting coverage across the software component supply chain. VCF CLI supports cosign signatures for container image verification, and registry authentication controls restrict which registries can serve container images to the environment. VKS image registry policies support a Warn mode that provides immediate feedback when a potential denial occurs, allowing organizations to observe policy impact before enforcing it in a full blocking mode. VCF Operations validates management pack PAK files against digital signatures, displaying a warning if a PAK file is not signed with a VMware-provided digital signature, which helps detect unauthorized or tampered management pack components.

Kubernetes admission controllers running on VKS intercept all API requests before resources are persisted, providing a centralized enforcement point for image authorization decisions. The Image Policy Webhook admission controller evaluates container images against an external backend, supporting registry allowlists and signature verification requirements. Validating and mutating webhook admission controllers can be configured to assess images against an external policy service before pods are admitted. Pod Security Admission enforces security profiles at the namespace level using Baseline, Restricted, and Privileged modes; the Restricted profile blocks pods that run as root, mount sensitive host paths, or use privileged containers, restricting the workload configurations that can be deployed and reducing the opportunities for unauthorized component introduction. Harbor integration provides container image signing and continuous vulnerability scanning; admission policies can require valid signatures before images are deployed to any namespace, and images that fail scanning thresholds can be blocked from deployment.

The Kubernetes API server on VKS records all API interactions, including attempts to create, modify, or delete workloads. Audit policy can be configured to capture request metadata, request body, and response body at configurable verbosity levels for each API resource and verb combination, recording the identity of service accounts or users that attempted to deploy workloads, the resources affected, and the outcome of each request. Audit events can be delivered to a webhook backend or written to log files for forwarding to a centralized log management system where they can be correlated and alerted on.

Prometheus with Alertmanager is available as a standard package on VKS clusters. The Prometheus Operator deploys Alertmanager as a highly available StatefulSet in the `tanzu-system-monitoring` namespace, where it receives alerts from Prometheus instances and routes them to external notification endpoints based on rules defined in the `AlertmanagerConfig` custom resource. The `AlertmanagerConfig` resource specifies how alerts are grouped, inhibited, and notified to external systems, supporting delivery to email, Slack, PagerDuty, and webhook endpoints. Organizations can define Prometheus alerting rules that trigger when unexpected workloads appear, resource consumption deviates from baselines, or compliance checks fail against known-good states.

The Harness CI/CD platform, available as a VKS service, provides integrated security scanning through Wiz and observability through Dynatrace within the deployment pipeline, performing pre-deployment vulnerability scanning and post-deployment performance verification. Dynatrace's AI engine automatically detects anomalies, identifies root causes, and delivers intelligent alerts for unusual runtime behavior patterns, complementing the rule-based alerting available through Prometheus. Security Technical Implementation Guides (STIGs) for Supervisor components and VMware Kubernetes Release (VKr) deployments are

available through Tanzu STIG Hardening to guide platform hardening, making deviations from expected configuration easier to detect and supporting the broader goal of identifying unauthorized changes to system components.

Together these capabilities provide automated detection and alerting for unauthorized components across hardware, firmware, host software, configuration, and container workload dimensions of the full VCF platform stack.

VMware vDefend (Contributes)

VMware vDefend contributes to the detection of unauthorized components through its network-layer detection and prevention capabilities. While vDefend does not perform hardware or firmware inventory, it provides several mechanisms that can surface evidence of unauthorized software components and rogue devices communicating on the network.

vDefend IDS/IPS inspects east-west and north-south traffic for signatures associated with known malware, exploit kits, command-and-control communication, and other indicators of unauthorized software operating within the environment. IDS/IPS detects specific threats including command-and-control traffic and network trojans such as Remcos RAT through signature-based matching. When an unauthorized software component begins communicating, IDS/IPS signature matching can detect that traffic and generate alerts or block it. IDS/IPS supports both Distributed and Gateway deployment models, covering traffic between workloads and traffic entering or leaving the environment. Both Distributed and Gateway IDS/IPS offer a Detect Only option that records detections against signatures without blocking traffic, providing initial visibility without operational disruption. Administrators can monitor IDS/IPS events through the Security dashboard and filter by signature action to distinguish among events categorized as Dropped, Rejected, or Alert, and can filter by Signature Type to distinguish between system-provided and custom signatures. When a signature triggers, vDefend IDS/IPS automatically generates Packet Capture (PCAP) files for forensic review. Detailed event data is also written to the nsx-idps-events.log file on each ESX host in the /var/log/nsx-idps directory, recording all alerts, drops, and rejects with associated metadata.

vDefend Malware Prevention extends detection to file-level analysis. When files traverse the network, the Malware Prevention Service inspects them for known and unknown malware using cloud-based and local analysis. Gateway Firewall rules for Malware Prevention can be configured in Detect Only mode, generating alerts without blocking traffic when initial detection and visibility are the priority. This provides an automated mechanism for detecting unauthorized software that may have been introduced into the environment. Malware Prevention deployment status and error reporting are accessible through the Security > IDS/IPS & Malware Prevention > Settings > Define Scope interface.

vDefend Network Detection and Response (NDR) and Security Intelligence analyze network traffic flows to identify anomalous communication patterns. Unauthorized or rogue components that communicate on the network produce traffic that deviates from established baselines. NDR correlates events across multiple detection sources and can surface indicators of compromise that point to unauthorized software or devices. NDR integrates with external SIEMs, sending campaign and event logs as they occur for detection events, detection updates, and new campaign creation. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, providing ongoing visibility as network communication patterns change.

Security Services Platform provides suspicious traffic detection through configurable detectors that analyze network behavior. Administrators can view detector activation status, manage detected events, and review the source and destination VMs involved in suspicious traffic. NTA detectors can be selectively activated or deactivated, and alarm definitions can be enabled or disabled by authorized users to manage alerting scope.

vDefend policy provides a complementary layer by enforcing microsegmentation rules that restrict which workloads can communicate with each other. When unauthorized components attempt to communicate across segment boundaries, the Distributed Firewall blocks those connections and logs the attempts. This posture means that even if an unauthorized component is introduced, its lateral movement is restricted and firewall rule violations are visible in the DFW audit log.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 2.0

> Inventory and Control of Software Assets: Actively manage (inventory, track, and correct) all software (operating systems and applications) on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

SCF Controls: AST-01, AST-02, CFG-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory

Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The ``configure systemconfiguration`` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm configuration, with changes synchronized to Service Engines. The ``configure`` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the ``PUT api/systemconfiguration`` endpoint for system-wide settings and the ``/api/cloud`` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible ``aviconfig`` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the AddonConfig resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control 2.1

> Establish and Maintain a Software Inventory

SCF Controls: AST-01, AST-02, AST-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts

for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

The Avi Load Balancer Controller maintains an internal configuration database that is the authoritative store for all Avi-managed objects within the application delivery layer. The database records configuration information for tenants, virtual services, pools, policies, and accounts, providing structured asset tracking scoped to the load balancing and application delivery functions. This database is the storage layer for all system settings and configurations in Avi Controller, accessible through both the Controller CLI and REST API, giving operators and automation tooling a programmatic way to retrieve and audit configuration details for any Avi-managed object.

For auditors assessing CMDB practices, Avi provides complementary mechanisms. The Controller CLI `configure` command provides access to show subcommands for viewing all configuration objects and system state, including application persistence profiles, application profiles, authentication profiles, backups, cloud configurations, and cluster settings. The Controller REST API endpoint `PUT api/systemconfiguration` enables programmatic retrieval and update of system configuration, allowing external CMDB platforms to pull structured configuration data and maintain up-to-date asset records for all Avi components. Configuration can also be exported and backed up with passphrase encryption of all sensitive fields, producing point-in-time snapshots suitable for import into a third-party CMDB or asset management system.

Avi Load Balancer events provide a record of configuration changes over time and are the foundation of configuration automation within the platform. The Config Events overlay in Service Engine Analytics enables administrators to correlate traffic changes with configuration modifications, such as changes to virtual service security settings, supporting governance requirements by providing a traceable record of configuration state changes within the Avi control plane.

In VCF deployments, Avi adds specific integration capabilities relevant to configuration governance. Organization-Managed Mode allows organization administrators to manage their own Service Engine Group configurations and infrastructure settings within boundaries defined by the VCF Automation Provider Management Portal, which enables provider administrators to specify regions, organizations, and capacity allocations. After upgrading components in a VCF deployment, a drift check against VCF Operations, vCenter, and NSX Manager is required to verify configuration consistency, providing a structured mechanism for detecting configuration drift across the integrated stack.

Organizations deploying Avi in a VCF environment typically integrate Avi configuration data with an enterprise CMDB to achieve unified asset tracking across the full infrastructure stack, with VCF's own inventory mechanisms covering the compute, storage, and networking layers while Avi covers the application delivery layer objects.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 2.2

> Ensure Authorized Software is Currently Supported

SCF Controls: AST-01, AST-02, AST-02.7, RSK-06.2, TDA-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts

for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides technical mechanisms for enforcing software license quota restrictions within its Controller management plane. The Controller enforces a configurable global upper limit on license consumption at the system level through the license quota limit setting, accessible under Administration > Licensing. When that limit is reached, provisioning of new Service Engines is blocked, directly capping usage at the configured boundary and rejecting licensing operations that would exceed it.

The license quota hierarchy extends to multiple levels depending on the licensing model in use. In the On-premise License Hub model, limits can be set at the system, tenant, and Service Engine Group levels; operations are rejected when these quotas are exceeded. In the Cloud Licensing model, limits are supported only at the system level; tenant and Service Engine Group limits are not available in that configuration. This distinction is important for organizations deploying Avi in hybrid or cloud-connected environments.

The Avi Cloud Console provides centralized license management across registered License Hub deployments, including a Maximum Allowed Licenses setting accessible under Administration > Licensing. Access to licensing operations within the Cloud Console is governed by Role-Based Access Control (RBAC): Full Access users with User Administrator or Product Administrator roles can register or deregister License Hubs, add or remove licenses, and perform allocation tasks, while Read-Only users cannot perform these actions. This RBAC separation helps restrict who can modify license entitlements.

For high-security or air-gapped environments, the Avi License Hub supports Private Mode operation. In this mode, a license file is downloaded from Avi Cloud Console and imported together with the private key used to generate it, removing the dependency on external network connectivity for license validation.

Organizations remain responsible for the procurement, tracking, and auditing processes that these technical controls support. Avi's quota enforcement covers the application delivery controller itself; software licenses for the broader VCF stack, operating systems, and other application workloads are managed through platform-level and organizational processes outside Avi's scope.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 2.3

> Address Unauthorized Software

SCF Controls: AST-02.2, CFG-02.8, CFG-03.3, CFG-05.1, CFG-06.1, END-03.1, END-06.2, IRO-02, MON-16.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support monitoring for unauthorized activities and connections within its operational scope as a database-as-a-service platform. These capabilities address the activity and account dimensions of this control, though the broader device and software inventory monitoring dimensions fall outside DSM's scope.

DSM generates two categories of audit logs that record and expose user activity. System Audit Events track all user actions performed through the DSM UI and API, as well as actions that DSM initiates autonomously. These events are accessible through the System Audit Events view, which is the only DSM UI location for reviewing non-database-related operations and tasks. Gateway Audit Logs record read and write operations to DSM data services or infrastructure objects performed through the DSM UI or the DSM Gateway Kubernetes interface, and identify the source entity for each action as either the user's Email ID for user-initiated operations or "System" for DSM-initiated operations. This attribution supports identification of operations performed under unexpected or unauthorized accounts.

For database-level activity monitoring, DSM supports configurable connection logging and login auditing across managed database engines. PostgreSQL instances expose the `log_connections` advanced setting, which activates logging of connection attempts and the successful completion of authentication; this setting takes effect without a database restart when updated. For SQL Server instances, DSM can automatically create a simple audit for login events based on the Login Auditing option selected when provisioning a SQL Server cluster. Both mechanisms support detection of unauthorized or unexpected connection activity to managed databases.

DSM tracks failed login attempts and account lockout state for local user accounts through the `failed_login_count`, `last_failed_login_time`, and `locked_state_start_time` fields. This data is accessible when reviewing local user account records and supports identification of repeated unauthorized access attempts. DSM also maintains an audit capability for verifying password changes, and password reset links issued to local users expire after 20 minutes, limiting the window for unauthorized reuse of a reset credential.

DSM provides an Alerts pane in the Monitoring tab where administrators can review alerts triggered on databases. Webhook-based alerting for database monitoring events, triggered by threshold violations, allows organizations to route DSM alerts to external systems for automated detection. DSM monitoring also tracks active backend connections on each database node, providing continuous visibility into connection activity against managed services through VCF Operations.

Audit logs can be forwarded via syslog to external log management or SIEM systems, allowing organizations to aggregate DSM activity records with those from other platform components for broader unauthorized activity detection.

DSM's monitoring scope is limited to its own management plane and managed database services. It does not monitor for unauthorized software installation, hardware device attachment, or network-level lateral movement. Detecting unauthorized connections at the network layer requires capabilities provided by VMware vDefend or similar network security tools. A complete monitoring posture for this control requires the organization to integrate DSM audit data into a broader security monitoring program that covers the full scope of the control's requirements.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control 2.4

> Utilize Automated Software Inventory Tools

SCF Controls: AST-02, AST-02.2, AST-02.9, CFG-06.1, END-06.2

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes a Config Audit Trail that records all configuration changes made to the Avi Controller, whether initiated through the CLI, API, GUI, or by automated policies. The audit trail captures user activity events and configuration change events over a selected time period and is accessible via Operations > Events > Config Audit Trail. Each event identifies the specific configuration object modified, the tenant context, the timestamp of the change, and the user account that performed the action.

Avi Controller CONFIG_CREATE and CONFIG_DELETE events include client_IP and user_agent fields, which allow operators to identify not only which user account initiated a configuration change but also the source IP address and the client application involved. Event Logs can be filtered by event type using parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE, allowing operators to isolate and review configuration changes systematically. When a configuration event is selected, the event log displays the specific API fields that were changed, providing detailed change tracking for investigation.

Configuration change events can be forwarded to external systems via syslog. The SYSLOG_JSON alert type captures CONFIG_UPDATE events with details including the event type, affected object, tenant context, update status, and performing user, making Avi's configuration audit data suitable for ingestion into a SIEM or log aggregation platform where correlation rules can generate alerts on unexpected changes. This forwarding path is the primary mechanism by which Avi's configuration audit data integrates with an organization's broader incident detection and response workflow.

Avi also provides a Config Events overlay within Service Engine analytics and Server Pool analytics that allows operators to correlate traffic anomalies with configuration changes by time, helping identify whether a specific configuration change caused a traffic or security impact. The Controller can be configured to enable configuration warnings, which notify users when configuration changes occur.

Organizations must supplement these detection capabilities with defined authorization baselines that specify which configuration changes are expected or permitted, SIEM integration or incident management tooling that acts on CONFIG_CREATE or CONFIG_UPDATE events, and response procedures for investigating and remediating anomalies. Avi provides the detection data; the determination of what constitutes an unauthorized change and the response workflow require organizational policy and integration with external platforms.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 2.5

> Allowlist Authorized Software

SCF Controls: CFG-03.2, CFG-03.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered mechanisms to restrict execution of unauthorized software across the hypervisor, virtual machine, container, and automation layers.

At the host level, VMware ESX enforces UEFI Secure Boot, which verifies the digital signature of every component in the boot chain before execution. The vSphere Security Configuration Guide recommends enabling Secure Boot and Trusted Platform Module (TPM) as part of ESX host hardening. Hosts equipped with TPMs provide hardware-rooted attestation, and VMware vCenter monitors host attestation state to confirm that each host has booted into a known-good configuration. The vCenter trusted infrastructure API provides interfaces for retrieving TPM event logs, endorsement keys, and attestation data from host hardware. ESX also supports Intel Trusted Execution Technology (TXT) for hardware-based verification of the hypervisor launch environment. The hypervisor enforces acceptance levels for VIBs (vSphere Installation Bundles), restricting installation and execution of unsigned or untrusted software packages on hosts. ESX also supports the `execInstalledOnly` enforcement setting, which requires that all executables running on the host originate from installed VIBs, directly blocking execution of unsigned or ad hoc binaries outside the VIB-managed software baseline.

vSphere Lifecycle Manager (vLCM) manages all hosts in a cluster collectively with a single image, and upon remediation, the image is installed on all hosts in the cluster. This desired-state model, combined with configuration profiles and drift detection, restricts unauthorized changes to the host software baseline. VCF Operations detects configuration drifts by comparing current vCenter values against configuration template values, notifying administrators of deviations from assigned baselines. Configuration drift detection can be scheduled for vCenter instances and vSphere clusters, and configuration templates can be integrated with source control for versioning and audit. VCF Operations compliance management detects violations, flags risk areas, and provides actionable remediation recommendations.

Host security configuration hardening rules can be enforced through workflows such as Apply Host Security Configuration Rules, which apply security baselines that restrict host-level software execution and configuration changes. VCF's hardening guidance for vCenter covers securing the installation, configuring roles and permissions, securing access and authentication, and enabling auditing and logging. These hardening practices, aligned with industry-standard best practices and the Security Configuration Guide, provide a layered approach to restricting unauthorized software execution across the platform.

For virtual machines, VCF supports UEFI Secure Boot at the guest level, allowing guest operating systems to verify the integrity of their own boot process. Virtual Trusted Platform Modules (vTPMs) extend hardware-rooted trust into virtual machines without requiring physical TPM hardware. The vTPM capability is integrated with VCF Automation for VM Apps, which requires the cryptographic operations direct access privilege in vCenter to support vTPM when deploying Windows 11 VMs. PowerCLI provides the `VMware.VimAutomation.Security` module for managing vTPMs programmatically. VCF Operations management pack PAK files are signed with a digital signature that indicates the original developer or publisher and provides authenticity verification. At the virtual machine level, the `isolation.device.edit.disable` setting, available through both vCenter and VCF Operations, restricts unauthorized modification of virtual machine devices, limiting the ability to attach or alter devices that could be used to introduce unauthorized software into a guest operating system. VCF Operations also provides a setting to disable automatic installation of VMware Tools (`disable tools auto install`), which restricts software from being installed on virtual machines without explicit administrator action. Virtual machines can also be configured with the `restrict-user-commands` setting to restrict users from running commands within the guest, providing a guest-level enforcement layer that complements the RBAC-based guest operations privilege restriction.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), the platform provides a layered set of enforcement mechanisms at the container, pod, and admission control layers. VKS cluster management image registry policies restrict the specific images that can be pulled from a registry for deployment in managed cluster namespaces, with a policy enforcement

setting that defaults to Deny, fully enforcing the policy and blocking admission requests with violations; a Dry run mode is available for testing without enforcement. VKS ships with a vmware-system-restricted Pod Security Policy by default that does not permit privileged access to pod containers, blocks privilege escalation to root, and requires security controls across running workloads. The vmware-system-privileged policy, which permits unrestricted workload execution, requires explicit binding through a RoleBinding or ClusterRoleBinding and is accessible only to cluster administrators by default. Namespaces can be configured to operate under the Baseline or Restricted Pod Security Standard, which restricts unprivileged processes from loading kernel modules, providing an additional boundary against unauthorized code execution. VKS clusters apply the RuntimeDefault seccomp profile to pods by default, restricting the set of system calls available to containerized processes; custom seccomp profiles with SCMP_ACT_ERRNO deny-by-default semantics can be assigned to workloads requiring tighter restrictions. For Linux-based workloads, AppArmor profiles restrict program access to specific system resources by specifying a loaded profile in the container specification; AppArmor can operate in enforcing mode, which blocks access to disallowed resources, or complain mode for audit-only monitoring of violations. AppArmor is available on both Ubuntu and Photon OS VKS node images, restricting container capabilities, file system access, and network access in VMware-native node configurations. Linux Security Modules such as SELinux can be configured to deny the module_request permission to containers entirely, blocking the kernel from loading modules on behalf of containerized processes. Admission control through ValidatingAdmissionPolicy blocks or constrains deployment of workloads that do not satisfy defined criteria, including protecting platform namespaces from non-conforming resources. Content libraries in VKS support assigning a Security Policy at creation time, scoping which artifacts can be sourced from that library and, in internet-restricted environments, limiting deployable artifacts to administrator-approved sources. Running containers can be restricted to an immutable state through the readOnlyRootFilesystem security context field, limiting the ability of a running process to introduce new executable code at runtime. Security Technical Implementation Guides (STIGs) covering Supervisor and VKr system components are available through Tanzu STIG Hardening, providing validated hardening baselines for VKS cluster node software execution environments.

PowerShell, which is the primary scripting and automation interface for VCF through PowerCLI, supports an execution policy feature that determines whether scripts are allowed to run and whether they must be digitally signed. The execution policy defaults to Restricted, the most secure setting, restricting unauthorized script execution in management contexts. Administrators can configure this policy to allow only signed scripts from trusted publishers.

VCF Automation for VM Apps allows administrators to create a list of permitted day-2 actions that users can run on deployments. By defining an explicit allow list of operations, administrators restrict users from initiating actions outside the approved set, limiting the ability to deploy or execute unauthorized software through the automation platform.

ESX Agent Manager provides privilege-based restrictions on operations performed against ESX agent virtual machines. By integrating solutions with ESX Agent Manager, administrators can limit operations such as powering off agent VMs to users who hold the EAM.Modify privilege, restricting unauthorized users from interfering with or substituting managed agent software.

The vCenter authorization model enforces consistent role-based access control across the environment. Software components require authorization to perform operations on behalf of a user, and vSphere implements mechanisms to restrict access to virtual infrastructure components to valid, authenticated users.

Across the full VCF platform, mechanisms exist at every layer to restrict execution of unauthorized software: Secure Boot and VIB acceptance levels at the host, VM-level attestation and device restriction at the guest, and Pod Security policies, seccomp syscall filtering, AppArmor and SELinux enforcement, admission control, and image registry policies at the Kubernetes workload layer. The combination of these natively available mechanisms, including defaults such as the vmware-system-restricted Pod Security Policy and the RuntimeDefault seccomp profile applied to VKS workloads, satisfies the control's requirement that mechanisms exist to configure systems against unauthorized software execution. Determining which software is authorized and selecting appropriate enforcement strictness levels for the organization's specific environment remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to preventing the execution of unauthorized software through its Malware Prevention Service, which operates at the hypervisor layer to detect and block malicious executables and scripts within guest workloads.

The Distributed Malware Prevention feature intercepts and analyzes executable files across a range of formats, including portable executables (.exe), ELF executables (.elf), Microsoft installers (.msi), Windows shortcuts (.lnk), and related binary categories. The analysis runs through the Security Services Platform (SSP), and the Malware Prevention Service intercepts process start and stop events on endpoints to gather critical details including Process ID (PID), command lines, binary paths, and hashes. On Windows workloads, Guest Introspection drivers are required to receive the full distributed protection. When a file is identified as malicious, Distributed Malware Prevention with Guest Introspection provides interfaces for remediation actions, including denying access to suspicious files or deleting files identified as malicious.

vDefend's Malware Prevention Service also addresses fileless attacks that bypass traditional file-based controls. The Fileless Malware Detection capability monitors Indicators of Compromise (IoC) including process command lines, process hash, process execution trees, and in-memory executions. In 9.1, the service intercepts in-memory scripts through Microsoft's Antimalware Scan Interface (AMSI), capturing execution traces of scripts running directly within process memory, including PowerShell, VBScript, and JScript. This detection path addresses script-based attacks that operate within system memory using existing binaries and in-memory operations without leaving executable artifacts on disk.

Administrators can manage software execution policy through the Malware Prevention Allowlist, which lets them override or suppress the verdict that vDefend has computed for specific files, providing a mechanism to approve known-good software. Malware Prevention profiles can be configured to send files to the cloud for analysis or to process files locally, providing flexibility for environments with cloud connectivity constraints.

The Malware Prevention Dashboard supports monitoring by tracking Process Name, PID, Command Line, and Binary Path for processes associated with in-memory script buffer execution. A Process Analysis Report provides detailed results for inspected processes and in-memory script buffers, including verdict information for each, supporting investigation and incident response workflows.

These capabilities complement VCF platform controls (Secure Boot, code signing, container image trust) by adding a runtime detection and prevention layer within guest workloads, including coverage of fileless and in-memory techniques that static boot-time and installation-time controls cannot address.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as `IpToCountryCode` available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with `Is` and `Is Not` operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault` seccomp profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 2.6

> Allowlist Authorized Libraries

SCF Controls: CFG-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as pod-security.kubernetes.io/enforce, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The vmware-system-restricted Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through ClusterRoleBinding or RoleBinding, giving administrators control over which service accounts may run under that restricted profile.

ValidatingAdmissionPolicy provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's resourceRules specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment specifications. MutatingAdmissionPolicy can transform submitted resources to conform to policy requirements before admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to

disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the `module_request` permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a RuntimeDefault seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes NetworkPolicy resources provide a namespace-level deny-by-default network posture: a NetworkPolicy that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The DenyServiceExternalIPs admission controller restricts Service resources from using LoadBalancer types or ExternalIPs fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support SecurityPolicies instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the EAM.Modify privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend (DFW) contributes to application access control at the network layer through explicit allowlist and denylist enforcement on workload traffic flows. DFW rules support four actions: Allow, Block, Reject, or Jump To Application. A default-deny posture drops all traffic not explicitly allowed, protecting application groups from unauthorized communication.

The 9.1 DFW Application Connectivity Strategy provides structured policy templates for common allowlist and denylist postures. The Allow Intra, Deny Other Traffic strategy generates an intra-group ALLOW rule using the ALLOW_INTRA and ALLOWLIST APIs plus a default ANY/ANY/DROP rule, enforcing strict isolation for application groups. The Allow Outbound, Deny Other Traffic strategy generates a specific egress ALLOW rule (application group to any) plus a default DROP rule,

permitting only authorized outbound communication. The Deny List strategy allows all traffic by default with optional logging, supporting environments where observed-traffic baselining is the initial posture. ALLOW EGRESS rules can be individually configured with Allow or Drop actions to control whether application entities may initiate external communication. Centralized Transit Gateway Firewall rules can enforce inter-project isolation by denying all inter-project communication except designated infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

Identity Firewall supports user identity-based access controls with Allow and Reject actions for specified user groups, services, and destinations, extending allowlist and denylist enforcement to user context through Active Directory integration.

Security Services Platform Application Protection in Strict Mode enforces application-level firewall rules across all workloads except infrastructure, with coverage scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence recommends granular application-level rules that allow only authorized traffic between environment pairs, helping administrators build explicit allowlist policy from observed flows.

Host-level application execution controls, such as OS-level application allowlisting (AppLocker, SELinux), are outside vDefend's scope and must be addressed by endpoint security tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as IpToCountryCode available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with Is and Is Not operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the botdetectionpolicy CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault seccomp` profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 2.7

> Allowlist Authorized Scripts

SCF Controls: CFG-03.3, IAC-16, MNT-04, MNT-04.4

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the authorizedGroups field of the PAISConfiguration custom resource when activating Private AI Services in an organization namespace through kubectl, or through the oidc-authorized-groups setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as group-for-pais-access-01 or group-for-pais-access-02, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the grafana-oidc-role-mapping property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the harbor-pull-secret-readonly mechanism to control access to container images stored in private registries, and the oras login command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the `resource_permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a

vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including L4POLICYSET, WAFPOLICYPSMGROUP, PINGACCESSAGENT, NETWORKSERVICE, and NATPOLICY, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 3.0

> Data Protection: Develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data.

SCF Controls: DCH-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression,

and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The etcdctl snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During kubeadm upgrades, backup folders for etcd state and cluster manifests are written automatically to /etc/kubernetes/tmp with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides VolumeSnapshotContent and VolumeSnapshot resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a PersistentVolumeClaim using a VolumeSnapshotClass that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new PersistentVolumeClaim with the target VolumeSnapshot as its dataSource, referenced via the snapshot.storage.k8s.io API group. Kubernetes PersistentVolumes have a configurable reclaim policy; setting the policy to Retain preserves volume data in a Released state after the associated PersistentVolumeClaim is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 3.1

> Establish and Maintain a Data Management Process

SCF Controls: CRY-01, CRY-03, DCH-01, DCH-01.1, DCH-01.2, DCH-01.4, DCH-02, DCH-03, DCH-03.1, DCH-08, DCH-09, DCH-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware

that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 3.2

> Establish and Maintain a Data Inventory

SCF Controls: DCH-06.2, DCH-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.3

> Configure Data Access Control Lists

SCF Controls: DCH-01, DCH-01.4, DCH-03, DCH-03.1, DCH-13.1, DCH-14, DCH-14.2, DCH-14.3, IAC-08, NET-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression,

and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The etcdctl snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During kubeadm upgrades, backup folders for etcd state and cluster manifests are written automatically to /etc/kubernetes/tmp with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides VolumeSnapshotContent and VolumeSnapshot resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a PersistentVolumeClaim using a VolumeSnapshotClass that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new PersistentVolumeClaim with the target VolumeSnapshot as its dataSource, referenced via the snapshot.storage.k8s.io API group. Kubernetes PersistentVolumes have a configurable reclaim policy; setting the policy to Retain preserves volume data in a Released state after the associated PersistentVolumeClaim is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Meets)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 3.4

> Enforce Data Retention

SCF Controls: DCH-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention

regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 3.5

> Securely Dispose of Data

SCF Controls: AST-09, DCH-08, DCH-09, DCH-21, PRI-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support secure logical disposal and sanitization of virtual resources, though the physical destruction or secure disposal of hardware remains an organizational responsibility outside VCF's scope.

vSAN data-at-rest encryption uses a two-tier key architecture with Key Encryption Keys (KEK) and Data Encryption Keys (DEK), managed through an external Key Management Server (KMS) or vSphere Native Key Provider. When decommissioning encrypted storage, destroying the encryption keys renders the data unrecoverable without requiring a full disk wipe, a technique known as cryptographic erasure. vSAN also provides an "Erase disks before use" option during encryption configuration that wipes existing data from storage devices. For devices being added to or removed from vSAN disk groups, residual data and partition information can be cleaned before the device is reclaimed or released. Administrators can wipe ineligible disks through the vSAN Management API after verifying the partition table and stored data. vSphere provides API methods for cryptographic key lifecycle management, including `removeKey` and `removeKeys` operations that delete encryption keys from host caches. These methods support a `force` parameter for definitive key removal.

VCF Operations includes a Reclamation dashboard and associated settings that help administrators identify virtual resources eligible for cleanup and disposal. The Reclamation Settings interface surfaces powered off VMs, idle VMs, snapshots, and orphaned disks, quantifying the resources that can be reclaimed. The Datastore Capacity Dashboard and ESX Capacity Dashboard both identify three specific reclamation opportunities: powered off VMs, snapshots, and orphaned VMDKs. These dashboards give operations and capacity teams visibility into resources that should be reviewed for secure removal before equipment is repurposed or decommissioned. The Reclamation Report tracks CPUs reclaimed, memory reclaimed, and storage reclaimed across different time periods, providing evidence of resource cleanup activity.

For the actual deletion of virtual resources, VCF Operations provides a `DELETE VM(s)` capability that removes selected powered off VMs, and a `RECLAIM RESOURCES` function that allows immediate execution of resource reclamation processes. VCF Automation extends this with a `Delete` action on Deployments that destroys an entire deployment and deletes all associated resources for reclamation. VCF Automation also supports the creation and deletion of secret reusable properties through its secrets management interface under Administration Secrets, which is relevant when sanitizing credential material before equipment reuse.

VCF Operations can disable virtual disk wiper and disk shrink operations on virtual machines through the `isolation.tools.diskWiper.disable` setting, which blocks data recovery attempts from within guest operating systems.

Core dump handling is another area where VCF provides disposal-relevant guidance. VMware recommends considering disabling core dumps on VMware vCenter systems to protect sensitive information. Unlike virtual machine core dumps, which are encrypted when VM encryption is active, vCenter core dumps are not encrypted by default; vCenter systems support core dump encryption through the `core-dump-encryption` setting, and encrypted core dumps can be decrypted or re-encrypted as needed. Core dumps may contain sensitive information such as host keys, and organizations should follow their security and privacy policies to protect this data. When decommissioning or repurposing hosts, addressing core dumps is an important step for reducing the likelihood of information recovery.

VCF also recommends securely deleting decrypted backup files after restore operations for VCF Operations, vCenter, and NSX components.

Auditors should verify that the organization has defined procedures for securely disposing of or repurposing VCF-managed infrastructure. This includes confirming that virtual resources (VMs, snapshots, orphaned disks, secrets) are deleted through VCF's reclamation and deletion tools before physical equipment is removed from service, and that encryption keys are destroyed via cryptographic erasure for storage that held sensitive data. Physical chain-of-custody procedures, media

sanitization verification, and equipment tracking through the disposal lifecycle are organizational processes outside the scope of VCF.

VMware vDefend (Contributes)

VMware vDefend contributes to secure information disposal through mechanisms built into its security analytics and threat prevention components. While vDefend is not a storage or media sanitization product, it collects and retains security-relevant data including network flow records, threat analytics, security policy metadata, and classification labels, and provides mechanisms for disposing of that data when it is no longer needed.

Security Services Platform provides deactivation paths that result in permanent deletion of associated data. Graceful deactivation of Bare Metal Security Service deletes all associated server information including certificates and inventory, and blocks the decommissioned server from reconnecting to the platform. A forceful deactivation path is also available that performs the same permanent data removal and deregistration. When an NDR Sensor is offboarded, Security Services Platform clears all registration and trust data from the system. The force offboard endpoint capability in Endpoint Management immediately deletes all endpoint data from the License Hub. Deleting a Security Services Platform instance removes the platform and all its associated components.

Security Services Platform supports certificate management with an explicit Remove action, including deletion of certificates for web proxies. Role assignments for remote users and groups can be deleted when LDAP is configured as an authentication provider. The platform backs up tokens and Bare Metal server inventory as part of inventory backup, supporting controlled lifecycle management and enabling intentional disposal after a backup is confirmed.

Malware Prevention Service rules and Service Virtual Machines can be deleted through Security Services Platform. The platform records metrics for purged records from Malware Prevention Service tables, covering inspection events, intercepted entities, and malware classification data, providing visibility into automated data purge activity.

Security Intelligence supports label deletion, which clears all associated label assignments to compute entities in the Security Intelligence visualization. Label assignments are also automatically cleared up to 30 days after an associated compute entity is deleted from inventory.

These capabilities address the disposal of vDefend's own operational and security analytics data. Broader information disposal requirements, such as sanitizing storage media, managing organizational data retention schedules, enforcing disposal verification processes, and cryptographic erasure of application data, fall outside vDefend's scope and are handled by other VCF components or organizational processes.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.6

> Encrypt Data on End-User Devices

SCF Controls: CRY-01, CRY-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-

compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 3.7

> Establish and Maintain a Data Classification Scheme

SCF Controls: DCH-02, DCH-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.8

> Document Data Flows

SCF Controls: AST-04, DCH-14.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of

members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at ports.broadcom.com, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.9

> Encrypt Data on Removable Media

SCF Controls: CRY-01, CRY-05, CRY-05.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-

compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 3.11

> Encrypt Sensitive Data at Rest

SCF Controls: CRY-01, CRY-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-

compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCrypto_PASSWORD and PGCrypto_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 3.12

> Segment Data Processing and Storage Based on Sensitivity

SCF Controls: DCH-02.1, SEA-03.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for partitioning systems so that workloads and data reside in separate physical domains or environments. These capabilities operate at the infrastructure, compute, storage, and network layers, giving administrators granular control over how resources are segmented across physical boundaries.

Workload domains are the primary partitioning construct in VCF. Each workload domain is an independent cluster (or set of clusters) with its own compute, storage, and networking resources, managed as a distinct unit within VCF Operations. A workload domain is isolated from other workload domains in the VCF instance, and each domain supports separate lifecycle management. Administrators can assign different security policies, network segments, and storage configurations to each domain. Workload domains include a VMware vCenter and NSX Manager instance (which can be shared with other workload domains), along with one or more vSphere clusters with VMware ESX hosts. Each domain can use distinct storage backends, including vSAN, NFS, FC, or iSCSI. The vCenter appliance for a given domain can run on one of the ESX hosts in its cluster, and administrators can place it on infrastructure separate from the infrastructure it manages when full physical separation is required. After deploying or adding a workload domain, administrators can deploy VCF Identity Broker and configure identity and access management independently for that domain.

At the network layer, VCF supports distributed switch models that provide physical air-gapped separation of network traffic. The Workload Separation Distributed Switch Model places virtual networking traffic onto different physical ESX host NICs and can isolate workload traffic to a separate network fabric. In secure environments, this model provides physical air-gapped separation of network traffic. The Storage and Workload Separation Distributed Switch Model extends this further by isolating storage traffic onto its own fabric as well, though it requires higher physical switch port density. NSX transport zones control the reach of Layer 2 networks, and transport zones in different NSX instances cannot communicate with each other, providing built-in network boundary enforcement. NSX network segments further partition traffic within and across domains, providing logical network isolation that maps to physical separation when backed by dedicated transport zones and uplinks.

At the storage layer, vSAN fault domains allow administrators to define rack-level or location-level boundaries within a cluster. When virtual machines are provisioned in a cluster with fault domains using a Failures to Tolerate policy, copies of the associated virtual machine objects are distributed across separate racks. This places data replicas in physically distinct locations, so a failure in one rack does not compromise all copies of a given object. For broader geographic separation, the VCF Stretched Cluster Model provides dual storage fault domains, enabling a single logical cluster to span two physical sites. This configuration places data replicas across site boundaries, maintaining availability if an entire site becomes unavailable. Virtual machines can move between availability zones during an outage.

For compute partitioning, VCF supports vSphere Zones within Supervisor environments. A vSphere Zone maps to one vSphere cluster that can be set up as an independent failure domain, capable of failing independently from other zones. Storage placement is co-located within the zone, so workloads assigned to different zones run on physically separated hosts and network paths. DRS affinity and anti-affinity rules provide additional placement controls, allowing administrators to pin specific virtual machines to designated clusters or hosts, or so that certain workloads never co-reside on the same physical hardware. Anti-affinity rules keep designated VMs on separate physical hosts, so workloads that must remain partitioned do not co-reside. These rules restrict virtual machine migration across cluster boundaries when physical domain separation is required, and are configurable through vSphere Client, PowerCLI, and the vSphere Web Services API. Storage DRS anti-affinity rules extend this partitioning to the storage layer, allowing administrators to place the virtual disks of specific virtual machines on different datastores within a datastore cluster, so storage-level separation is maintained between designated workloads.

Within the Kubernetes consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor provide partitioning mechanisms at the orchestration level that complement the infrastructure-layer boundaries. Kubernetes namespaces create logical partitions within a VKS cluster, each with its own RBAC policies and resource quotas. Supervisor integrates vSphere Namespaces with VCF SSO, so each namespace is governed by independent access control policies and can be assigned to specific organizational teams or environments, supporting separation of development, staging, and production workloads. For physical domain separation at the orchestration level, multi-zone VKS cluster deployments span multiple vSphere Zones mapped to distinct physical infrastructure; in a three-zone configuration, workloads are distributed across zones to achieve separation at the physical cluster level. StorageClass objects use the `allowedTopologies` parameter to restrict persistent volume provisioning to specific zones, binding stateful workloads to particular physical locations. VKS clusters with multiple zones require a late-binding storage class for persistent volumes on MachineDeployment nodes to preserve zone affinity. Node-level isolation is available through Kubernetes taints, tolerations, and node selectors, which restrict which workloads run on which nodes; this supports a model where high-sensitivity workloads run on dedicated node pools isolated from lower-trust workloads. VKS cluster autoscaling uses separate MachineDeployments for node pools with different operating systems or workload characteristics, maintaining separation between heterogeneous workload populations. VKS clusters provisioned using the ClusterClass API support the `osConfiguration.immutability.usrPartitionMode` variable, which when set to `ReadOnly` locks the `/usr` partition on Photon OS nodes and restricts modification of system binaries on running cluster nodes, reducing the attack surface from within a partition.

An auditor reviewing a VCF deployment should verify that workload domain boundaries align with the organization's partitioning requirements, that vSAN fault domains are configured to reflect actual physical rack or site boundaries, that stretched clusters (if deployed) span distinct failure domains, and that DRS affinity rules enforce the required placement constraints. NSX segment configurations should enforce the intended network-level separation between domains, and distributed switch models should match the required level of physical traffic isolation. For deployments using VKS, auditors should confirm that namespace boundaries map to organizational partitioning requirements, that multi-zone configurations reflect physical separation goals, that StorageClass `allowedTopologies` constraints align storage placement with physical domains, and that node pool separation is enforced through taints and tolerations where workloads of different trust levels must not co-reside.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.13

> Deploy a Data Loss Prevention Solution

SCF Controls: NET-17

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend does not provide a dedicated content-aware Data Loss Prevention engine, but contributes network-level controls that reduce the risk of sensitive data being exfiltrated. The Distributed Firewall (DFW) enforces microsegmentation policies that restrict which workloads can communicate and over which protocols, limiting unauthorized data exfiltration paths.

Security Intelligence, part of the Security Services Platform, identifies risky application protocols that transport data in cleartext and recommends that organizations restrict or block them and enforce minimum secure protocol versions. Identified protocols include HTTP, FTP, Telnet, TFTP, LDAP, POP3, and IMAP. Administrators can use Security Intelligence to monitor inter-environment traffic leakage, establish exceptions, and implement lockdown protection rules to control cross-segment data flows.

IDS/IPS signatures provide detection capabilities for known exfiltration techniques and anomalous data movement patterns. Gateway Firewall URL and FQDN filtering can block known exfiltration destinations. TLS inspection on the Gateway Firewall extends visibility into encrypted traffic, allowing vDefend to identify potential policy violations that would otherwise be concealed within encrypted sessions.

Network Detection and Response (NDR), included in vDefend Advanced Threat Prevention, analyzes network traffic and can surface behavioral patterns consistent with data exfiltration activity.

Content inspection, classification of sensitive data at rest, and enforcement based on data content or sensitivity labels remain outside vDefend's scope. A dedicated content-aware DLP solution is required to fully satisfy this control.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.14

> Log Sensitive Data Access

SCF Controls: MON-01.15, MON-02, MON-02.1, MON-02.3, MON-03, MON-03.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware

Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to /var/log/syslog.log include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to /var/log/syslog.log on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API

endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control 4.0

> Secure Configuration of Enterprise Assets and Software: Establish and maintain the secure configuration of enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/IoT devices; and servers) and software (operating systems and applications).

SCF Controls: CFG-01, CFG-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of configuration controls that restrict systems to only essential capabilities by controlling ports, protocols, and services across the platform stack.

At the hypervisor layer, VMware ESX hosts include a built-in host firewall that controls which ports and services are accessible. The firewall supports specification of allowed hosts through the `allowedHosts` parameter, so administrators can limit which IP addresses may connect to specific services. Services such as SSH (TSM-SSH) can be individually started or stopped through the VMware Host Client, giving administrators direct control over which management services are running. ESX lockdown mode restricts host access so that all management is performed through VMware vCenter, with an Exception Users list for controlled overrides when direct host access is needed. ESX also supports disabling unexposed features through isolation configuration parameters, removing functionality that is not needed in the environment.

Port groups on distributed switches are communication boundaries where security policies can be configured. Each port group carries its own security policy settings, including controls over promiscuous mode, MAC address changes, and forged transmits. Administrators can modify these policies to restrict which types of network traffic virtual machines are permitted to generate or receive. Each port group can also be assigned a VLAN ID to restrict traffic to a logical Ethernet segment. SpoofGuard and switch security profiles can be applied to distributed port groups to prevent traffic spoofing and enforce network security policies at the virtual switch layer. Distributed port groups also support Port Blocking Policies, which allow administrators to selectively block ports from sending or receiving data, including blocking all ports within a group simultaneously. Traffic Filtering and Marking Policy can be applied at the individual distributed port or uplink port level to permit or stop traffic flows through virtual machines, VMkernel adapters, and physical adapters. Port-level configuration overrides on distributed virtual switches are deactivated by default, so permitting per-port policy exceptions requires deliberate administrator action. The virtual serial port proxy provides an additional gateway that enforces security for remote serial port connections, restricting access to only authorized communication paths.

Management traffic is isolated on dedicated networks. The Fleet Level Components on Dedicated Management Network model uses VLAN-backed distributed port groups to provide isolation from other networks. NSX allows configuration of services with port and protocol pairing, and these services can be referenced in firewall rules to allow or block specific types of traffic.

The platform documents explicit port requirements for each component. When vSAN is enabled on a cluster, required ports are added to ESX firewall rules and configured automatically, keeping firewall configuration aligned with actual service requirements rather than leaving unnecessary ports open. VCF Operations Cloud Proxy requires only ports 4505, 4506, and 8443 via TCP for application monitoring, establishing a minimal set of allowed network communication paths. These defined port lists give administrators a clear baseline of what must be open rather than relying on permissive defaults.

VCF Operations supports firewall hardening, which when activated restricts network access to internal services, limiting exposure to only the ports and protocols required for operation. A service discovery policy setting controls whether the system actively discovers services on the network; disabling this policy reduces the attack surface by preventing unnecessary service enumeration, though administrators should be aware that turning it off changes the security posture of the operating system. For orchestration functions, VCF Operations enforces privilege requirements where ports below 1024 can only be opened with superuser privileges on Linux systems, providing an inherent restriction on which processes can bind to well-known service ports. VCF Operations also collects ESX security properties including service running status, firewall rulesets,

service policies, and disabled protocols when the vSphere Hardening Guide policy is applied, giving administrators visibility into the least-functionality posture of each host.

The Security Configuration Guide provides recommendations for disabling unnecessary services and enabling security features on ESX hosts as a baseline for least-functionality configuration.

At the workload consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor enforce least functionality across compute, kernel, and network dimensions for containerized workloads. Pod Security Admission (PSA), enabled by default in Supervisor clusters running VKS 1.25 and later, enforces Kubernetes Pod Security Standards at the namespace level. Administrators configure each namespace with an enforcement profile from three options: Privileged (no restrictions), Baseline (blocks known privilege escalation paths), and Restricted (heavily restricted, following pod hardening practices). Each profile supports three independent modes: enforce (rejects non-compliant pods at admission), audit (records violations in the audit log without blocking), and warn (surfaces policy warnings to the requesting user without blocking), allowing operators to gain visibility into policy gaps before tightening enforcement. The Restricted PSA level requires containers to drop all Linux capabilities, blocks host networking, host PID, and host IPC namespaces, restricts volume types to a safe subset, disallows privilege escalation by setting `allowPrivilegeEscalation` to false, and requires a defined Seccomp profile. Supervisor applies the `vmware-system-restricted` Pod Security Policy by default to VKS clusters, which blocks privileged container access, helps prevent root escalation, and restricts permitted volume types; standard packages such as Contour also reference this policy so that system components operate under the same restricted constraints. VKS Cluster Management Security Policies provide an additional management layer for pod security within VKS clusters; when creating a security policy, the Restricted pod security policy template offers a preconfigured tight security context that constrains pod privileges and capabilities across the cluster.

Kubernetes pod and container security context configuration allows administrators to add or drop specific POSIX kernel capabilities through the `securityContext.capabilities` field, restricting which kernel operations individual containers may exercise. Pods can be configured with Seccomp profiles that filter the system calls available to containers; the `RuntimeDefault` profile applies the container runtime's default system call filter and blocks calls not required by typical applications, while custom profiles allow more precise control. The Restricted Pod Security Standard makes a defined Seccomp profile mandatory for compliant workloads. Supervisor also supports SELinux, which restricts access to files, applications, ports, and processes through labels and security policies enforced on tagged processes, and AppArmor profiles that restrict a container's abilities by enforcing a defined set of rules and restrictions on process behavior at the kernel level. On Ubuntu and Photon nodes in VKS clusters, AppArmor additionally controls file system access and network access, extending mandatory access control across multiple resource dimensions beyond process behavior alone. These mechanisms operate independently of Kubernetes admission controls and provide a defense-in-depth layer for workload capability restriction. Kubernetes ephemeral containers disallow ports, `livenessProbe`, and `readinessProbe` fields, further restricting their capabilities relative to standard containers.

Network-level least functionality for VKS workloads is enforced through Kubernetes `NetworkPolicy` objects, implemented by Antrea or NSX-based CNI plugins in Supervisor, which restrict ingress and egress traffic at the pod and namespace level by port, protocol, and peer selector. Cluster administrators can restrict the IP address ranges allowed for Kubernetes Services through centralized management of `ServiceCIDR` resources, reducing the scope of reachable service endpoints across the cluster. Access to control plane ports such as the etcd API port should be restricted at the network level to only specified and trusted IP address ranges. VKS control plane nodes enforce a set of default inbound firewall rules that administrators cannot override, covering only the ports required for control plane operation, including TCP 6443 for the kube-apiserver, TCP 2379-2380 for etcd, TCP 22 for SSH, TCP 179 for BGP, and TCP 10100 for the kapp-controller, among others. The kubelet `allow-privileged` flag controls whether privileged containers are permitted on cluster nodes. The Istio CNI plugin, configurable through the `istioCNI.enabled` setting, manages pod network interfaces and enforces network policies without requiring privileged containers, reducing the need for elevated privileges in service mesh deployments. Kubernetes guidance documented in Supervisor materials states that access control components operating with high privileges should be isolated from general workloads using namespace boundaries, so that privilege is scoped to where it is operationally required.

VCF Automation provides security groups that define isolation settings for on-demand private or outbound networks, allowing administrators to restrict which services and ports are accessible within network segments. Network profiles support isolation

policies defined as either on-demand or existing security groups, enabling granular control over network communication boundaries.

For ongoing compliance verification, VCF Network Operations provides a search query capability to identify firewall rules that permit any port, querying for rules where the action is set to allow and the service is configured as "any." This allows administrators to systematically find and remediate overly permissive rules that violate least-functionality principles, restricting access to only the ports and protocols that are explicitly required.

VMware vDefend (Meets)

VMware vDefend provides the primary enforcement mechanism for least functionality at the network layer, allowing administrators to configure systems so that only essential ports, protocols, and services are permitted.

vDefend (DFW) operates per workload and supports Allow, Drop, or Reject actions on traffic matching defined services with specific port and protocol pairings. Administrators build policies that permit only the traffic required for a workload's function while denying everything else. DFW policies can explicitly block insecure protocols such as Telnet, FTP, and TFTP across the data center, actively blocking protocols that should not be present in the environment. DFW governance implements a least-privilege posture by preventing overly permissive rules such as "ANY/ANY/ANY ALLOW," guiding administrators toward specific port and protocol restrictions rather than broad allow policies. Rules are processed in precedence order across multiple policy sections, giving administrators fine-grained control over which traffic categories are evaluated first.

vDefend extends least-functionality enforcement to inter-project and perimeter boundaries. Gateway Firewall rules support configurable service selection, allowing administrators to specify a blanket block on all protocols or access restricted to specific ports for selective inter-project communication. Enterprise administrators can configure inter-project isolation policies that allow only essential infrastructure protocols while denying all other inter-project communication, defining perimeter-level traffic boundaries based on what each segment actually requires.

Security Intelligence, part of the Security Services Platform, provides traffic flow analysis with protocol and port filtering. Administrators can analyze observed flows using Exclude or Match criteria, supporting up to 15 entries of single ports, port ranges, or protocols. This visibility helps administrators verify that only essential ports and protocols carry traffic and identify unexpected communication patterns that may indicate unnecessary services remain enabled. Security Intelligence also provides guidance on restricting risky application protocols that transport data in clear text, flagging these for restriction or replacement as part of the overall least-functionality posture.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (srm_configuration.properties) to simplify or automate the import process, invoke the import-export.jar utility interactively using the --importInteractive flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the Least Functionality control through its infrastructure policy framework and data service policy allowlists, which restrict what network resources, compute configurations, and service parameters are available to database consumers.

Infrastructure policies are the primary mechanism. Each infrastructure policy requires the selection of specific network port groups for each compute resource (network-port-group setting), and at least one IP pool must be defined for each selected port group (ip-pools setting). This constrains which network segments database instances can attach to, restricting consumers from selecting arbitrary network endpoints. Infrastructure policies must be explicitly enabled before they become available for database provisioning; policies that are not yet ready for use can be kept deactivated (infrastructure-policy-enabled setting), which limits which network configurations are offered to consumers at any given time. DSM also validates infrastructure policy IP ranges against system configuration networks, detecting and rejecting overlapping configurations before they take effect.

Data service policies build on infrastructure policies to create a tiered allowlisting mechanism. Each data service policy requires the selection of at least one infrastructure policy, and in the self-service consumption model, the DataServicePolicy custom resource's allowedInfrastructurePolicies field enumerates precisely which infrastructure policies authorized consumers may use. Database users cannot select infrastructure configurations outside the approved set defined by administrators. Infrastructure policies also filter storage policies to display only those compatible with the designated compute resources, further narrowing the options available at provisioning time.

Infrastructure policies create broader resource guardrails as well: the overall policy framework restricts the quality and quantity of resources DSM users can consume from vSphere clusters, and database clusters are deployed with infrastructure and storage policies that enforce isolation and resource constraints from the moment they are provisioned.

Data service policies support an "Allow with a List" option, which creates a specific allowlist of approved parameters that users can select from during provisioning. SQL Server data service policies extend this pattern: they require selection of at least one infrastructure policy and restrict instance provisioning and server-level configuration, including Active Directory integration and high availability settings, to administrators only.

For PostgreSQL databases, DSM provides an additional connection control capability. The Block Database Connections operation can stop existing client connections and block new ones from being established, with exemptions only for monitoring, replication, and internal service traffic. This allows administrators to restrict access to a database instance to only the services required for continued operation.

DSM's contribution to this control is scoped to the database-as-a-service layer. Restrictions on ports, protocols, and services at the network perimeter, host, or hypervisor level depend on the underlying VCF platform, NSX networking configuration,

and vDefend firewall policies outside DSM's direct control. Organizations should complement DSM's policy framework with platform-level network security controls to fully address the Least Functionality requirement.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides mechanisms for restricting ports, protocols, and services at the application delivery layer, supporting least-functionality configurations for application traffic and management access.

At the application traffic layer, each virtual service accepts traffic only on explicitly configured service ports. The per-Service-Port profile configuration (ApplicationProfile or NetworkProfile) can be overridden on a per-service-port basis for advanced use cases. Virtual Service Network Security Policies can match on service port to filter traffic based on TCP service ports on which the virtual service is listening, allowing administrators to explicitly permit or block traffic by protocol and port on a per-virtual-service basis.

For Controller management access, Avi provides several mechanisms to restrict access to management channels. The Client Management Access configuration allows administrators to define allowed SSH clients, allowed CLI shell clients, allowed external HTTP(S) clients, and allowed external SNMP clients separately, each scoped to specific IP addresses, ranges, subnets, or IP groups. Management channels not included in the configured allowlist are blocked. This configuration is accessible through the Securing Management IP Access workflow in the Controller UI under System settings. Trusted host profiles can be configured to restrict which hosts are permitted to access the Controller, providing an additional layer of host-identity-based access restriction. The Controller also limits the allowed ciphers and HMACs for management sessions, reducing the cryptographic surface exposed on each management channel.

Security groups for Avi Controller and Service Engines specify the protocol ports for which traffic is permitted between components, providing a defined port inventory that administrators use to scope surrounding network controls.

These capabilities apply at the application delivery boundary. Least-functionality controls for the underlying compute, storage, and network virtualization layers are provided by VCF, which is rated Meets for this control.

Control 4.1

> Establish and Maintain a Secure Configuration Process

SCF Controls: CFG-01, CFG-02, CFG-02.1, IAC-22

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.2

> Establish and Maintain a Secure Configuration Process for NetworkInfrastructure

SCF Controls: CFG-01, CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.3

> Configure Automatic Session Locking on Enterprise Assets

SCF Controls: CFG-02, IAC-24

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.4

> Implement and Manage a Firewall on Servers

SCF Controls: CFG-02, END-05, WEB-03

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.5

> Implement and Manage a Firewall on End-User Devices

SCF Controls: CFG-02, END-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.6

> Securely Manage Enterprise Assets and Software

SCF Controls: CFG-02, CFG-03, CRY-06, MNT-05, NET-04, TDA-02.6

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Meets)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the `advanced-system-config` ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.7

> Manage Default Accounts on Enterprise Assets and Software

SCF Controls: CFG-02, IAC-01, IAC-10.8

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.8

> Uninstall or Disable Unnecessary Services on Enterprise Assets and Software

SCF Controls: CFG-02, CFG-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Meets)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 4.9

> Configure Trusted DNS Servers on Enterprise Assets

SCF Controls: NET-10

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to DNS resolution security through DNS traffic inspection, domain-name-based policy enforcement, and DNS-based threat detection. vDefend does not operate DNS server infrastructure, but it inspects and filters DNS traffic and detects DNS-based threats as traffic traverses the virtual network.

The Distributed Firewall DNS Security Profile monitors DNS resolution by snooping DNS responses for virtual machines and groups of virtual machines on the transport node, associating fully qualified domain names with IP addresses. This approach guards against DNS-related attacks at the hypervisor level. Administrators can configure a TTL setting to control how long DNS cache entries are retained; the default cache timeout is 24 hours.

FQDN-based policy in the Distributed Firewall allows rules to reference domain names rather than static IP addresses. For FQDN-based rules to be enforced, DNS traffic must pass through a Distributed Firewall rule with the DNS Service defined. Virtual machines must use a dynamic DNS server for FQDN filtering to be effective; environments relying on static DNS entries will not benefit from this capability. The Distributed Firewall FQDN allowlisting and denylisting rules support both DNS-UDP and DNS-TCP services. When establishing a default-deny policy posture, administrators should include explicit allow rules for replication traffic between DNS servers and for all workloads to query the DNS service.

The vDefend gateway firewall extends domain-name-based controls to north-south and inter-tier traffic through Layer-7 Context Profiles. Gateway Firewall Context Profiles support both system-defined and user-defined FQDNs, with wildcard domain name format (*.hostname.domain) to cover domain hierarchies rather than individual hostnames.

Network Detection and Response (NDR), operating through the Security Services Platform, detects anomalies in DNS lookups performed by internal hosts that may indicate Domain Generation Algorithm (DGA) malware activity. The NDR Sensor appliance requires DNS server configuration to resolve hostnames for its detection functions.

vDefend does not provide DNS server infrastructure, DNSSEC validation, zone transfer protection, or cache poisoning mitigations. The underlying DNS servers and their hardening remain the responsibility of the organization's DNS infrastructure team.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer DNS capabilities that contribute to the design, implementation, and management of secure name and address resolution. The Avi DNS Virtual Service, hosted on Service Engines, functions as an authoritative DNS server for configured domains and forwards queries that do not match a local entry to back-end DNS pool servers.

At the security layer, the DNS Virtual Service supports policy-based filtering that can drop queries for domains not explicitly configured on the service, scoping its authority and limiting exposure to unsolicited resolution requests. DNS policies attach to DNS virtual services and enforce per-query rules based on criteria including client location and query type; supported actions include Allow/Drop Query, Query Response, Pool Switching, Rate Limiting, and GSLB Site selection, enabling operators to control which queries are answered and how responses are shaped.

Avi provides configurable security policies for DNS Amplification Egress DDoS protection. These policies attach exclusively to DNS virtual services (not to HTTP or other virtual service types) and help limit DNS query response sizes, reducing the risk of the service being used as an amplification vector.

For DNS resolver management, nameserver IP addresses (IPv4 or IPv6) are configured via DNS Resolvers in the Avi Controller for Service Engine-based resolution and are inherited by all Service Engines in the cloud. The `nameserver_ips` attribute governs FQDN resolution for pool members, external health monitors, and client log streaming operations. DNS resolution on

Service Engines is supported on VMware and No Orchestrator cloud deployments; a DNSResolver object must be configured in the cloud object for this capability.

The DNS Virtual Service also supports TXT record configuration for DNS-based service discovery and validation, and can be deployed in a high availability configuration on Service Engines.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.11

> Enforce Remote Wipe Capability on Portable End-User Devices

SCF Controls: AST-16, MDM-01, MDM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.12

> Separate Enterprise Workspaces on Mobile End-User Devices

SCF Controls: MDM-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.0

> Account Management: Use processes and tools to assign and manage authorization to credentials for user accounts, including administrator accounts, as well as service accounts, to enterprise assets and software.

SCF Controls: IAC-01, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory.

Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within

the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 5.1

> Establish and Maintain an Inventory of Accounts

SCF Controls: IAC-16, IAC-16.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the authorizedGroups field of the PAISConfiguration custom resource when activating Private AI Services in an organization namespace through kubectl, or through the oidc-authorized-groups setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as group-for-pais-access-01 or group-for-pais-access-02, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the grafana-oidc-role-mapping property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the harbor-pull-secret-readonly mechanism to control access to container images stored in private registries, and the oras login command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the `resource_permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a

vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including L4POLICYSET, WAFPOLICYPSMGROUP, PINGACCESSAGENT, NETWORKSERVICE, and NATPOLICY, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 5.2

> Use Unique Passwords

SCF Controls: IAC-10, IAC-10.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered authentication infrastructure that supports secure management of authenticators across the platform's components and the Kubernetes workload consumption layer, though the broader organizational policies governing authenticator lifecycle management require processes and governance beyond what VCF itself provides.

VCF Identity Broker integrates with a selected identity provider for user authentication, establishing trust through metadata exchange between the service provider and the identity provider. This centralized approach allows organizations to manage authenticators through their existing identity management systems rather than maintaining separate credential stores for each VCF component. VCF SSO provides a single sign-on environment where a user provides credentials once, and components in the environment perform operations based on the original authentication. Administrators can federate VMware vCenter with an enterprise identity provider, which enables multifactor authentication (MFA), automatic user provisioning and deprovisioning, and token-based authentication that reduces the risk of credential exposure. VCF SSO supports SCIM (System for Cross-domain Identity Management) for automating user identity exchange across identity domains, and named providers including Okta are supported through the identity provider federation mechanism. When configured for identity provider federation, the external provider handles all authentication mechanisms, including passwords, MFA, and biometrics, delegating full authenticator management to the organization's existing identity infrastructure. The Authorization Code grant type in VMware Identity Broker supports MFA workflows, while the Password OAuth 2.0 grant type is incompatible with MFA requirements, so organizations should use the Authorization Code flow when MFA is needed.

VMware Kubernetes Service (VKS) extends this identity architecture to the workload consumption layer. VKS clusters support two authentication methods: VCF SSO and any OIDC-compliant external identity provider, including Okta, so identity lifecycle management, including onboarding, offboarding, and group membership changes, can remain in the organization's central identity system. Users authenticated through an external identity provider are granted Kubernetes RBAC permissions using the `sso:<username>@<domain>` naming convention in `ClusterRoleBindings`. Custom `ClusterClass` configurations allow organizations to authenticate developers against existing corporate identity systems. When provisioning clusters based on a custom `ClusterClass`, the authentication Secret can be configured with multiple JWT issuers to support distinct identity providers simultaneously, such as Keycloak for contractors and Microsoft Entra ID for employees. At the `kube-apiserver` level, VKS supports multiple authenticator types: client certificates, bearer tokens, an authenticating proxy, and HTTP basic auth. The `--authentication-config` file provides structured control, allowing multiple JWT authenticators each with a unique issuer URL and discovery URL, and CEL expressions to map claims to user attributes and validate claims. When multiple authenticator modules are active, the first to successfully authenticate a request short-circuits further evaluation, making authenticator order significant; Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to simplify user management and reduce the risk of users retaining access after it is no longer needed. The `kube-apiserver` can also leverage existing authentication methods such as LDAP or Kerberos through plugins, and `kubectl` integrates with credential plugins for centralized operator credential management. The `system:auth-delegator` `ClusterRole` provides unified authentication and authorization flows for add-on API servers deployed into VKS clusters. Production VKS clusters should enable Kubelet authentication and authorization to restrict direct access to the kubelet API. For Windows node pools, VKS clusters support Group Managed Service Accounts (gMSA) for authenticating Windows nodes to Active Directory; gMSAs are managed by security groups that control password retrieval and delegation permissions, allowing Windows workloads to use Active Directory-managed identities.

Standard packages deployable on VKS clusters extend authenticator management to workload-level services. Argo CD, available as a standard package, supports local account authentication with global RBAC policies and OIDC authentication for federated identity, allowing GitOps workflow access to be governed through the same identity infrastructure used for cluster

access. The Harbor container registry package provides authentication and token management for artifact access, with role-based access control restricting image push and pull operations.

VCF Operations integrates with VCF SSO for centralized authentication through an identity provider. NSX Manager can be configured to authenticate users from identity management providers or through a directory service such as Active Directory over LDAP or OpenLDAP. NSX authentication best practices include integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions. NSX Manager requires authentication prior to establishing a management connection for administrative access. The VCF Automation Provider Management Portal supports authentication via local users and SAML users, and Organization Administrators use credentials configured during organization creation to access their respective organizations.

For local accounts, each VCF component enforces password complexity and lifecycle policies. NSX Manager requires passwords of at least 12 characters with uppercase, lowercase, numeric, and special character requirements, enforced through Linux PAM modules. Each NSX user password has an expiration date tracked by NSX, with a default expiration period of 90 days. Password expiration is configurable between 1 and 9,999 days. VCF Operations enforces a minimum of 15 characters with similar complexity rules. VCF Automation passwords must also be at least 15 characters in length.

VCF provides configurable account lockout policies across its components. VCF Operations locks accounts after five consecutive failed login attempts for 15 minutes. A separate policy locks VCF Operations accounts if a user enters an incorrect password three times within five minutes. VCF Automation supports account lockout in password policy system settings, which locks user accounts after a configurable number of invalid login attempts. VCF Automation also provides a configurable account lockout interval that specifies the duration before an account is automatically unlocked, and provider administrators can unlock a user account manually without waiting for that interval to expire.

For service-to-service authentication, VCF uses certificate-based credentials. VCF SSO supports X.509 certificate authentication, and vCenter extensions can authenticate using `loginExtensionByCertificate()` with an extension key certificate. Provider management accounts authenticate using API access tokens that rotate after each use. VCF Automation provides service accounts with the same access restrictions as user API tokens, so service accounts cannot perform user management or create refresh tokens. NSX supports Principal Identity certificates for cloud management platform integration, requiring SHA256-based certificates with RSA/DSA message algorithm and 2048-bit or larger key sizes. At the Kubernetes layer, service account authentication uses bearer token secrets generated automatically for service accounts. Kubernetes hardening guidance recommends setting short lifetimes on certificates and automating their rotation, and recommends using an authentication provider that controls how long issued tokens remain valid; using short-lived Secrets helps detect or limit the impact of credential exposure. The `system:masters` group functions as a break-glass super-user group that bypasses the RBAC authorization layer and should be reserved for emergency access scenarios only.

VCF Operations provides API endpoints for trusted certificate management and displays certificate expiration status for each workload domain through its Certificates tab. NSX supports non-disruptive certificate rotation in VCF and later, allowing certificate replacement without service interruption.

VCF also provides visibility into authenticator usage through audit logging. User authentication details are viewable in VCF Operations, including user name, successful or failed authentications, and events such as user login and guest operation authentication. This logging supports detection of compromised or misused authenticators.

While VCF provides the technical controls for authenticator strength, complexity, expiration, lockout, and rotation within its own components, as well as identity provider integration for MFA enforcement and centralized authentication, and the VKS consumption layer provides configurable multi-method kube-apiserver authentication, external identity provider integration, short-lived credential support, and gMSA for Windows workloads, the broader organizational policies for initial authenticator issuance, periodic credential rotation schedules, revocation upon personnel changes, and mapping authentication strength requirements to data classification levels require processes and governance outside VCF's scope.

VMware Private AI Services (PAIS) provides authentication mechanisms specific to its AI infrastructure components, integrating with externally managed identity systems to control access to AI services, model endpoints, and training data.

PAIS uses OIDC-based authentication as its primary access control mechanism. The PAISConfiguration custom resource configures the OIDC provider with issuerUrl, clientId, and scopes including openid, groups, and offline_access. Access is restricted to user accounts whose membership matches OIDC groups listed in the authorizedGroups field, and the Access Token carries a groups claim that PAIS validates against the authorized group list. The OIDC configuration also supports configurable group claim names and Extra Audiences for additional OAuth2.0 clients that PAIS will accept when validating the Access Token.

The PAISConfiguration custom resource supports client TLS for outbound authentication to the OIDC provider and Harbor registry, configured through the worker.clientTls.caBundleRefs field. This binds certificate-based trust to identity provider and registry connections so that authentication exchanges are integrity-checked against approved CAs.

Authenticator management for the Harbor registry that stores AI models and artifacts follows a credential-based pattern. The oras login command authenticates to a private Harbor registry using username and password credentials for artifact push operations, and docker login is used for pushing models to Harbor projects through the Model Gallery. Harbor project access capabilities restrict access to the sensitive data that is used to train and tune models. Model endpoints support authentication through harbor-pull-secret-readonly to control access to container images stored in private registries, and Harbor model retrieval requires certificate-based trust in addition to credential authentication.

Internal service-to-service authentication is addressed at the component level. PAIS authenticates to the OpenTelemetry Collector using a Kubernetes Secret containing Authorization Bearer tokens and custom headers, and the LLM Traces flow uses the same pattern with semi-colon separated headers. The PAIS MCP server supports custom HTTP headers including User-Agent and Authorization headers for API authentication, and remote MCP servers can optionally use static authentication tokens. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication.

For Knowledge Base data sources, PAIS supports authentication to Confluence using either a username and password or a personal access token, configured according to the Confluence administrator's settings. Personal access tokens are generated from user account settings and used for programmatic access to Knowledge Bases and data sources. Microsoft SharePoint data sources require username and password authentication, with support limited to SharePoint On-Premises deployments.

Deep Learning VMs deployed through self-service catalog items in VCF Automation, when configured with the PyTorch NGC software bundle, support optional JupyterLab authentication activation for interactive notebook access.

The underlying user accounts, credential storage, password policies, and OIDC provider administration are owned by VCF SSO or an external identity provider. PAIS configures and enforces authentication using those systems but does not manage authenticator lifecycle itself.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces password complexity, length, and lifespan requirements for its management interface accounts, contributing to the organization's password-based authentication posture.

Security Services Platform (SSP) is the centralized management console for vDefend. SSP enforces password policies for local user accounts: admin and audit user passwords require a minimum of 12 characters and a maximum of 128 characters, and must contain at least one uppercase letter, one lowercase letter, one numeric character, and one special character. The same complexity criteria apply during password changes and resets. Local user passwords are valid for 180 days; a notification banner appears in the SSP UI 30 days before expiration to prompt users to update their password. Installer user passwords are valid for 60 days. The License Hub component of SSP also enforces password complexity requirements during local password change operations.

SSP supports integration with directory services, including Active Directory over LDAP and OpenLDAP. When remote users or remote user groups are configured through LDAP, SSP applies the password expiration settings configured in the directory service; password expiry for these accounts cannot be modified from the SSP UI. SSP uses Authelia, an open-source authentication and authorization server, to handle authentication requests, including two-factor authentication and single sign-on.

For Identity Firewall, vDefend uses an LDAP password to authenticate connections to the directory service used for identity-based policy enforcement.

vDefend is a network security product and not a general-purpose identity management system. Its management interfaces enforce password complexity, length, and lifespan policies for vDefend administrative access. Satisfying this control fully requires applying equivalent password policies across all systems within the organization's environment, which is an organizational responsibility beyond vDefend's scope.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using scram-sha-256, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 5.3

> Disable Dormant Accounts

SCF Controls: IAC-15.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides account deactivation capabilities across its management components, but does not include a built-in automated mechanism to detect and disable accounts based on inactivity duration. The manual deactivation features across the platform supply the technical foundation that an organization can build upon to satisfy this control when paired with external identity governance processes or tooling.

NSX Manager ships with three default inactive local user accounts (audit, guestuser1, and guestuser2), which can be deleted, activated, or deactivated through the Local Users tab in the NSX Manager UI. The admin user or any user with the Enterprise Admin role can activate or deactivate any local user account except for the built-in admin account, which cannot be deactivated.

VMware vCenter supports account deactivation at both the VCF SSO and local user account levels. VCF SSO user accounts can be deactivated through the vCenter management interface; a deactivated account remains in the identity store but the user cannot log in until an administrator reactivates it. For vCenter local user accounts managed through the Appliance Shell, administrators can use the ``localaccounts.user.set --username <username> --status disabled`` command to disable a specific account, or restore access by setting the status back to enabled.

VCF Operations provides account activation and deactivation controls. Administrators can deactivate user accounts through the Activated field or a disable checkbox, which stops the user from accessing VCF Operations features. The account can be reactivated later if needed.

VCF Automation provides similar capabilities at both the user and user group level. Organization administrators can disable users, which deactivates their access to the organization and stops them from logging in. Provider-level users can also be deactivated, after which the user cannot log in to VCF Automation. Disabling a user in VCF Automation does not remove them from the organization, and their access can be reactivated at a later time. User accounts can also be deleted entirely when no longer required.

For service accounts, VCF implements automatic token expiration as a form of time-bound access control. Service accounts authenticate using API access tokens that rotate after each use. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days. Refresh tokens can be revoked earlier and optionally rotated with each access token request. This token lifecycle provides an automated mechanism that limits the duration of service account access without manual intervention.

Within the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor provide automated mechanisms for managing service account credential lifetimes. The Kubernetes control plane includes the LegacyServiceAccountTokenCleanup feature gate, which enables automatic purging of Secret-based service account tokens that have not been used within a configurable inactivity period. The inactivity window is set through the ``--legacy-service-account-token-clean-up-period`` flag on the kube-controller-manager, configurable via the ``LegacySATokenCleanerConfiguration.CleanUpPeriod`` field; the default retention period is one year. The companion LegacyServiceAccountTokenTracking feature marks unused auto-generated tokens as invalid when they are not mounted by any pods and have remained unused for the configured period, at which point the cleanup controller removes them. For workloads using projected service account tokens, the ``projected.sources.serviceAccountToken.expirationSeconds`` parameter sets a bounded validity window for each token, limiting its active lifetime regardless of usage patterns; organizations should prefer short-lived projected tokens over long-lived Secret-based tokens. For human user access to VKS clusters, VCF SSO is the default authentication backend and can integrate with Active Directory and LDAP systems; inactivity-based account disabling for human users is enforced at the identity provider level and flows through VCF SSO into the VKS authentication layer.

VMware ESX hosts provide time-based access controls for ESX Shell access. The ESX Shell availability timeout can be configured so that the service deactivates and prevents new logins after a specified period, and the idle timeout setting automatically logs out users from inactive interactive sessions. These settings limit the duration of shell access when manual deactivation has not been performed.

To fully satisfy this control, organizations should integrate VCF's identity sources with an external identity provider such as Active Directory, LDAP, or an OIDC provider that supports automated detection of inactive accounts and time-based disabling policies. VCF's local account deactivation features can then be used to enforce disabling actions identified by the external governance process, giving administrators the ability to respond to specific account management needs directly within the platform.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.4

> Restrict Administrator Privileges to Dedicated Administrator Accounts

SCF Controls: IAC-16, IAC-21, IAC-21.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the `authorizedGroups` field of the `PAISConfiguration` custom resource when activating Private AI Services in an organization namespace through `kubectl`, or through the `oidc-authorized-groups` setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as `group-for-pais-access-01` or `group-for-pais-access-02`, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the `grafana-oidc-role-mapping` property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the `harbor-pull-secret-readonly` mechanism to control access to container images stored in private registries, and the `oras login` command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, dsm_mgmt, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the resource `permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including `L4POLICYSET`, `WAFPOLICYPSMGROUP`, `PINGACCESSAGENT`, `NETWORKSERVICE`, and `NATPOLICY`, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Control 5.5

> Establish and Maintain an Inventory of Service Accounts

SCF Controls: IAC-02, IAC-05, IAC-16.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support inventorying privileged accounts and reviewing elevated access across platform components, though complete fulfillment of this control requires organizational processes for management validation and periodic review.

VCF Operations maintains an inventory of service and component credentials accessible through the /v1/credentials REST API endpoint. This endpoint can be queried with parameters such as resourceType and accountType to retrieve credentials for specific components, including VMware vCenter root accounts and VCF SSO administrator accounts. When VCF Operations is not operational, these credentials can also be retrieved from the file-based backup. VCF Operations itself maintains a root user account and a super user (vcf) account as its own privileged accounts.

vCenter implements role-based access control where privileges are fine-grained access controls grouped into roles, which are then mapped to users or groups on specific inventory objects. Administrators can review these assignments through the vCenter UI or the AuthorizationManager API, which can be used to grant permissions and associate them with managed entities in the inventory. The AuthorizationPrivilegeChecksFilterSpec structure allows filtering privilege checks by managed object IDs, request operation IDs, principal identities (users or groups), privileges, and sessions, providing a programmatic mechanism for auditing who holds what access across vCenter-managed objects. The Privilege Recorder ListAPI provides an additional mechanism for retrieving historical records of privilege checks, along with the corresponding sessions, users, managed objects, and operation IDs, supporting after-the-fact audits of what privileged operations were actually performed. The vSphere Web Services API documentation recommends that user accounts be given the minimal number of privileges required for their responsibilities.

VCF Operations enforces that each user account must have a unique identity and one or more roles assigned. User accounts are assigned to one or more user groups, and users inherit the roles and scopes associated with those groups. The platform supports importing user accounts from an authorization source and assigning role-based access control permissions. The administrators role should be assigned only to specific users who must access objects and perform actions across the entire environment. VCF Operations Identity and Access Management also supports assigning the administrator role to groups, granting all group members administrator privilege. User accounts can be associated with specific objects in the VCF Operations cluster to control the scope of access for users assigned particular roles.

Within VCF Automation, Organization Administrators can log in to view the rights associated with each role and create roles local to their organization. A System Administrator can create other system administrator and user accounts in the provider organization. Organization owners can add and manage other users, and global roles can be assigned to users in the organizations to which they are published, giving administrators visibility into role distribution across the platform. Service accounts are created by a system administrator with the View Service Accounts and Manage Service Accounts privileges, providing a defined process for service account lifecycle management.

NSX Manager supports role assignment for both local user accounts and LDAP user accounts. For LDAP integration, an LDAP identity source must be configured, and once authenticated, users are assigned roles corresponding to their LDAP group memberships. The admin user can manage local user account passwords, change user names, and add, delete, or deactivate user accounts through the CLI. The User Role Assignment tab in the UI enables administrators to locate and manage role assignments for specific accounts. Users with the Enterprise Administrator role can modify or delete objects owned by principal identities. User accounts must be created and activated before role assignments can be made.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer within the VCF consumption tier extends the privileged account surface into the Kubernetes domain. Access to Supervisor and VKS clusters is governed by vSphere Namespace permissions assigned through three explicit roles: Can View, Can Edit, and Owner. A VCF SSO user granted the Edit

permission on a vSphere Namespace is automatically assigned to the clusteradmin role for any VKS cluster deployed in that namespace, creating a direct mapping between namespace-level grants visible in VMware vCenter and cluster-level administrative access. The Owner role is available only through VCF SSO authentication, tying high-privilege Supervisor access to the identity provider. Specific vCenter-level privileges such as Manage Supervisor Services govern the ability to add or delete Supervisor Services on a vCenter system, and these privilege assignments are visible and auditable through the vCenter permission model. Within VKS clusters, Kubernetes RBAC objects including ClusterRoles, Roles, ClusterRoleBindings, and RoleBindings are stored in etcd as queryable API objects; administrators can enumerate all subjects holding elevated permissions across clusters and namespaces using `kubectl get clusterrolebindings` and `kubectl get rolebindings` commands. Kubernetes distinguishes ServiceAccounts from human user accounts: service accounts authenticate with a structured identity in the form `system:serviceaccount:(NAMESPACE):(SERVICEACCOUNT)` and belong to the `system:serviceaccounts` group, allowing enumeration of human and workload identities separately and supporting per-category access reviews. Kubernetes RBAC good practices recommend managing permissions per namespace rather than granting cluster-wide roles broadly, and cluster administrators should account for privilege escalation paths when designing the permission model to avoid granting excessive access that is difficult to track. Kubernetes also requires that user account names not be reused after a user is deleted, preventing a new user created with the same name from automatically inheriting the deleted account's role bindings and permissions. When VCF Services such as the Argo CD operator are deployed to VKS clusters, those tools define RBAC policy rules and group mappings through the `rbac.policy` field in the ArgoCD custom resource, providing per-service privilege enumeration alongside the platform-level grant inventory.

These capabilities create a defined set of privileged roles and accounts that an organization can enumerate across VCF components, including vCenter, VCF Operations, VCF Automation, NSX Manager, VKS clusters, and deployed VCF Services. However, VCF does not provide a consolidated, cross-component privileged account inventory dashboard or an automated management-approval workflow for elevated access. Kubernetes RBAC grants must be queried per-cluster and do not roll up automatically into a platform-wide inventory alongside the vCenter and VCF Operations grant sets. Organizations must implement their own processes for periodically reviewing privileged account assignments, validating that each person with elevated privileges is authorized by the appropriate level of management, and revoking access that is no longer justified. Pairing VCF's built-in role and account visibility with an external identity governance solution or PAM tool helps maintain a formal inventory of privileged accounts and conduct periodic access reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains a defined set of privileged local accounts within its management plane. SSP has two built-in local accounts: an admin user with the Enterprise Admin role and an audit user with the Auditor role. These accounts are system-defined and remain accessible even when external identity providers such as LDAP or OpenLDAP are unavailable, providing continuity of management access independent of external directory connectivity. The SSP Installer ships with the same two predefined local accounts (admin with full privilege and audit with auditor access) to support the deployment phase.

For broader access governance within SSP, vDefend implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; the Enterprise Admin role holds full access including deployment, management, upgrade, backup and restore, and authentication and authorization configuration. Accounts from external identity providers such as LDAP can be assigned to any of these roles. Administrators can view and manage all role assignments through the User Management interface, which requires Admin privileges to access.

vDefend's contribution to this control is bounded to its own management plane. SSP provides the technical mechanisms for inventorying and managing privileged access within vDefend itself, but inventorying privileged accounts across the broader organizational environment and validating that each account holder has been authorized by the appropriate level of organizational management are outside the product's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to this control through its role-based access control model, which defines a clear privileged account tier and supports integration with enterprise directory services.

DSM implements RBAC with two predefined roles. The DSM Admin role provides super-user access, allowing the account holder to view and manage all data services and objects in the DSM environment. The DSM User role restricts access to objects the user owns, with namespace-level access controls configurable during user creation. This structure makes it possible to identify all privileged accounts within DSM: any account assigned the Admin role holds elevated privileges.

DSM user accounts originate from one of two identity sources: a local database (Local users) or a configured LDAPS server (LDAPS users). Administrators can assign the Admin role to individual LDAPS users or to Directory Service Groups, which enables group-based access control when LDAPS is configured. When an organization manages DSM Admin assignments through an LDAPS group, changes to privileged access can be governed through the same directory management processes used elsewhere in the environment. The initial DSM administrator account is created as a Local user during deployment of the DSM Provider Appliance and cannot be deleted. A vSphere administrator must assign DSM Admin and DSM User roles to users before they can access DSM.

DSM also depends on platform-level privileged accounts. Deploying DSM requires a VMware vCenter (vCenter) administrator account with sufficient credentials to create a dedicated vCenter service account. DSM does not retain the vCenter administrator credentials after this step; they are discarded once the service account is created and plug-in registration completes. Administrators can verify and update the target vCenter service account credentials in Settings > System Settings under Target vCenter.

For SQL Server deployments, DSM introduces additional privileged account types that organizations must include in their inventory. DSM deactivates the default SQL Server sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login receives restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full sysadmin access. SQL Server deployments support two administrator user identity types: SQL User or Windows Principal, with the Windows Principal option available for clusters integrated with Active Directory. Organizations that configure the optional Active Directory privileged account for automated SPN and DNS record management must include that account in their inventory.

When self-service consumption is configured, a Cloud Administrator account must map to a DSM user account to install and operate the Consumption Operator. Organizations should include any such mapped accounts in their privileged account inventory based on the DSM role assigned to the mapping.

For this control to be fully met, organizations must establish processes outside DSM to enumerate all accounts assigned the Admin role (both local and LDAP-sourced), account for the vCenter service account, any SQL Server-specific privileged accounts, and any Active Directory accounts configured for SQL Server automation, and confirm that each privileged account has been authorized by the appropriate level of organizational management. DSM's RBAC model provides the technical structure to support that review, but the inventory compilation and authorization validation steps require organizational governance processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a user account management interface that supports the creation and review of a privileged account inventory within the Avi Controller. The Administration > Accounts > Users section lists all local user accounts with their assigned roles, tenant scopes, and Super User designations.

The built-in admin account is a unique privileged account used for initial setup and the highest-level configuration operations, including user creation and authorization, tenant creation, and all infrastructure associated with the admin tenant. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication, so it is always present in the local account inventory regardless of external identity provider availability. Additional Super User accounts can be created by enabling the Super User designation during account creation, granting those accounts the same privileges as the built-in admin account. Non-admin accounts can also be assigned super-user CLI privilege levels, which means privileged access extends to CLI sessions as well as the management UI.

The `aviDebugUser` account is a distinct sudo user on the Avi Controller that allows privileged command execution. This account represents a separate privileged identity that organizations should include in their account inventories alongside the standard admin and Super User accounts.

For externally authenticated users, Avi supports LDAP and Active Directory group-based auth mapping profiles that apply multiple role and tenant combinations to determine user privileges during login based on matched authorization rules. Each user account carries an explicit Tenant and Role assignment, where the role determines the scope of access (write, read, or no access) within the assigned tenant. Role assignments can be applied at account creation or updated at any time through the Role drop-down menu in the user account configuration.

In Kubernetes deployments using the Avi Kubernetes Operator (AKO), distinct roles are defined for privileged access: the ako-admin role is assigned to admin tenants, the ako-tenant role to billing tenants, and the ako-all-tenants-permission-controller role covers all tenants. These roles represent additional privileged identities that administrators should include in their account inventories when AKO is deployed.

In VCF Automation integration using organization-managed mode, the Provider or Load Balancer Administrator manages resource assignments to organizations to enforce quotas and resource boundaries. Each organization has an Organization or Load Balancer Administrator who manages load-balancing resources and capabilities within their assigned scope. These administrator roles within the VCF Automation context should be included in privileged account inventories.

The License Hub component includes two local user accounts with distinct privilege tiers: an Admin account with the enterprise_admin role for full access to manage the software subscription platform, and an Audit account with the auditor role for full access to APIs and services for system auditing. Both accounts are present as local accounts even when external identity providers such as LDAP or OpenLDAP are disconnected.

Organizations reviewing privileged access can use Administration > Accounts > Users to enumerate all accounts with elevated roles or Super User status and confirm that each account reflects current need. The organizational validation step, which involves confirming that each person with elevated privileges has been formally authorized by the appropriate level of management, is a governance process outside the scope of what Avi performs. Organizations must implement access review and approval workflows to satisfy that aspect of the control.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 5.6

> Centralize Account Management

SCF Controls: IAC-01, IAC-01.2, IAC-02, IAC-09, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS

supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events

generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions,

TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control 6.0

> Access Control Management: Use processes and tools to create, assign, manage, and revoke access credentials and privileges for user, administrator, and service accounts for enterprise assets and software.

SCF Controls: IAC-01, IAC-08, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory.

Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions,

TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control 6.1

> Establish an Access Granting Process

SCF Controls: IAC-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.2

> Establish an Access Revoking Process

SCF Controls: IAC-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.3

> Require MFA for Externally-Exposed Applications

SCF Controls: IAC-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.4

> Require MFA for Remote Network Access

SCF Controls: IAC-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.5

> Require MFA for Administrative Access

SCF Controls: IAC-06.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF supports multi-factor authentication (MFA) for privileged account access through identity provider federation. VCF does not include a built-in MFA mechanism, but its authentication architecture is designed to integrate with external identity providers that enforce MFA policies for all privileged users.

VCF SSO can be configured with an external identity provider using Generic SAML 2.0 or OIDC protocols. The VCF Identity Broker integrates with the selected identity provider for user authentication, enabling organizations to connect enterprise identity platforms such as Okta, Entra, or Ping to VCF SSO. Once configured, all VCF SSO-authenticated access to VCF management interfaces, including VMware vCenter, NSX Manager, and VCF Operations, flows through the external identity provider, which can enforce MFA as part of the authentication process. The identity provider must be configured for VCF SSO before enabling VCF SSO for VCF Operations and VCF Automation.

At the vCenter layer, identity provider federation provides the mechanism for MFA enforcement. Federating vCenter to an enterprise identity provider provides flexible authentication options, including MFA. The native vCenter MFA capability has been deprecated in favor of leveraging the external identity provider's authentication mechanisms, which can support passwords, MFA, and biometrics depending on the provider's configuration. The OAuth 2.0 Authorization Code grant type used in federated authentication is compatible with MFA. The VCF Identity Broker also supports the Authorization Code grant type, and it should be used instead of the Password grant type, which operates as a single-factor method and is incompatible with MFA requirements. When federation is configured with the Authorization Code flow, privileged users authenticating to vCenter through AD FS or other supported providers are subject to whatever MFA policies the identity provider enforces. Organizations should ensure that API integrations, automation workflows, and SDK clients use the Authorization Code grant type rather than the Password grant type when MFA is required.

VCF Automation supports integration with multiple identity provider types, including LDAP, SAML, OIDC, and VCF SSO, for user authentication and access control. Users can be imported from SAML, OIDC, or VCF SSO identity providers using the name identifier format supported by the SAML identity provider. VCF Automation also supports remapping users between SAML, LDAP, and OIDC identity provider types. When VCF Automation is configured to use a SAML identity provider for authentication, the MFA policies enforced by that provider apply to VCF Automation access as well.

VCF's role-based access control model defines several privileged roles across components. In vCenter, the Administrator system role includes all privileges including cryptographic operations, and the CloudAdmin role provides host switch-level and platform-level operations permissions. In VCF Automation, the Assembler Administrator role has full read/write access to the UI and API, and the cloud administrator role is required to manage cloud accounts and organizations. VCF Operations for Networks access requires the Cloud Administrator role. When identity federation is in place, users holding any of these privileged roles must authenticate through the federated identity provider, where MFA can be required.

Service-to-service authentication between VCF components uses certificate-based solution user accounts, which operate outside the federated authentication and MFA flow. These accounts are not interactive user sessions and are not subject to MFA policies.

To implement MFA for privileged accounts in a VCF environment, administrators should configure VCF SSO with an external identity provider that enforces MFA, federate vCenter to that identity provider, and ensure that all privileged user access routes through the federated authentication path. Because VCF does not enforce MFA itself, the organization must deploy, configure, and maintain the external identity provider with appropriate MFA policies.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.6

> Establish and Maintain an Inventory of Authentication and Authorization Systems

SCF Controls: AST-02, IAC-01, IAC-01.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA`

parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control 6.7

> Centralize Access Control

SCF Controls: IAC-02, IAC-13.1, IAC-13.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the

sso:<username>@<domain> convention. The AuthorizeWithSelectors feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include authorization.k8s.io/decision and authorization.k8s.io/reason, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubecttl auth whoami` for verification purposes. Administrators can use `kubecttl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (``pais-authentication-id``), and the scopes ``openid``, ``groups``, and ``offline_access``. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The ``authorizedGroups`` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, ``group-for-pais-access-01`` or ``group-for-pais-access-02``). The ``oidc-groups-claim`` setting names the claim used to identify group membership in the Access Token, and ``oidc-extra-audiences`` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the ``grafana-oidc-role-mapping`` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server

Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the dbo user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (dsm-auth-creds), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the enterprise_admin role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the auditor role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check

if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 6.8

> Define and Maintain Role-Based Access Control

SCF Controls: IAC-08

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization

User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the oidc-extra-audiences setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject,

and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 7.0

> Continuous Vulnerability Management: Develop a plan to continuously assess and track vulnerabilities on all enterprise assets within the enterprise's infrastructure, in order to remediate, and minimize, the window of opportunity for attackers. Monitor public and private industry sources for new threat and vulnerability information.

SCF Controls: VPM-01, VPM-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes

Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements to the kubernetes-announce mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security

Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations

targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a structured patch management lifecycle for both the Controller and Service Engine groups, supporting the application delivery layer's contribution to an organizational vulnerability management program. The CLI patch command offers distinct patching modes (Controller Patch, SE Group Patch, Disruptive Patch, and System Patch), giving administrators flexibility to apply patches to specific components or across the entire system without requiring a full upgrade cycle. The documentation recommends applying patches only to the Service Engine groups that require them, based on Service Engine group segmentation. Patch images are uploaded to the Controller and verified for inclusion in the image bundle before any upgrade operation proceeds.

Rollback capability is available for patch releases via CLI. The ``rollbackpatch controller`` command reverts the Controller to the previous patch version, while ``rollbackpatch system`` rolls back the Controller and all Service Engine groups simultaneously. Rollback transitions the system to the version without the specific patch and does not roll back to the previous major version. The Avi for VCF documentation recommends planning a remediation strategy before re-attempting an upgrade following a rollback. On restore operations, the Controller checks for patches applied as part of the restore to maintain version consistency.

For application-layer vulnerability management, Avi Load Balancer supports virtual patching through two complementary mechanisms. The Web Application Firewall (WAF) integrates with Dynamic Application Security Testing (DAST) scanners; the Avi SDK integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning, allowing scan results to be imported and used to identify application vulnerabilities and apply WAF-based protections while permanent code fixes are developed and deployed. The Live Security Threat Intelligence service, available through the Cloud Console, extends virtual patching coverage with an Application Rules service providing rules designed to block attacks on known application vulnerabilities, including many with associated CVEs. These rules cover over 5,000 applications including WordPress, Drupal, and Apache, and are automatically updated through continuous Application Rules Database synchronization, keeping WAF protections current.

An Application Security Report provides a downloadable PDF documenting security findings and pre-check results, supporting vulnerability management reporting and documentation. The alert automation infrastructure supports ControlScripts that alert actions can invoke to automatically add offending client IP addresses to a blocklist attached to a network security policy, enabling automated response to detected threats.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 7.1

> Establish and Maintain a Vulnerability Management Process

SCF Controls: VPM-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements to the kubernetes-announce mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor

Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a structured patch management lifecycle for both the Controller and Service Engine groups, supporting the application delivery layer's contribution to an organizational vulnerability management program. The CLI patch command offers distinct patching modes (Controller Patch, SE Group Patch, Disruptive Patch, and System Patch), giving administrators flexibility to apply patches to specific components or across the entire system without requiring a full upgrade cycle. The documentation recommends applying patches only to the Service Engine groups that require them, based on Service Engine group segmentation. Patch images are uploaded to the Controller and verified for inclusion in the image bundle before any upgrade operation proceeds.

Rollback capability is available for patch releases via CLI. The ``rollbackpatch controller`` command reverts the Controller to the previous patch version, while ``rollbackpatch system`` rolls back the Controller and all Service Engine groups simultaneously. Rollback transitions the system to the version without the specific patch and does not roll back to the previous major version. The Avi for VCF documentation recommends planning a remediation strategy before re-attempting an upgrade following a rollback. On restore operations, the Controller checks for patches applied as part of the restore to maintain version consistency.

For application-layer vulnerability management, Avi Load Balancer supports virtual patching through two complementary mechanisms. The Web Application Firewall (WAF) integrates with Dynamic Application Security Testing (DAST) scanners; the Avi SDK integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning, allowing scan results to be imported and used to identify application vulnerabilities and apply WAF-based protections while permanent code fixes are developed and deployed. The Live Security Threat Intelligence service, available through the Cloud Console, extends virtual patching coverage with an Application Rules service providing rules designed to block attacks on known application vulnerabilities, including many with associated CVEs. These rules cover over 5,000 applications including WordPress, Drupal, and Apache, and are automatically updated through continuous Application Rules Database synchronization, keeping WAF protections current.

An Application Security Report provides a downloadable PDF documenting security findings and pre-check results, supporting vulnerability management reporting and documentation. The alert automation infrastructure supports ControlScripts that alert actions can invoke to automatically add offending client IP addresses to a blocklist attached to a network security policy, enabling automated response to detected threats.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 7.2

> Establish and Maintain a Remediation Process

SCF Controls: VPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply

remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 7.3

> Perform Automated Operating System Patch Management

SCF Controls: VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized software and firmware patching across the entire infrastructure stack through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane. VCF Operations is the central orchestration point for patching and update operations, coordinating patch releases (such as 9.0.1.0100) that deliver time-sensitive fixes to security and operational issues between major, minor, and maintenance releases.

VCF uses a desired-state model for host remediation through vSphere Lifecycle Manager (vLCM). Administrators define a software specification for each cluster, and vLCM brings all hosts into compliance with that specification during remediation. This approach applies uniformly to VMware-supplied components and third-party solutions alike. To make a third-party solution available on a cluster, administrators create a software specification containing the solution and remediate all hosts with that image. vLCM manages software updates for VMware ESX hosts, including patches of the ESX base image, OEM additions, components from different software vendors, and VMware Tools updates. Dynamic patch baselines automatically adjust their contents based on specified criteria each time Update Manager downloads new patches, keeping remediation current without manual baseline maintenance. Fixed baselines are also available for environments that require explicit control over which patches are applied. Hardware Support Manager (HSM) plugins extend vLCM to manage vendor-specific firmware and driver updates alongside software patches, providing unified lifecycle management for both software and firmware from within the same interface. Firmware updates through Hardware Support Manager are only available for clusters and hosts managed with vSphere Lifecycle Manager images; hosts managed with baselines do not support firmware updates through this mechanism.

The remediation workflow is coordinated through multiple layers. Coordinator Manager runs pre-checks before remediation begins to evaluate how each host in the cluster is affected and whether additional steps are needed. Pre-checks verify component connectivity, version compatibility, and component status. The ESX Updater Manager then handles the actual remediation on each host. Coordinator Manager also allows administrators to query the status of the remediation operation for the cluster and for each individual host, providing centralized visibility into remediation progress. The VCF Operations cluster transition specification includes a remediationOptionsSpec with a configurable remediationFailureAction that supports automatic retry with adjustable retryCount and retryDelay parameters, allowing administrators to define consistent remediation behavior.

VCF Operations extends lifecycle management with patch planner functionality for VCF core components, including the ability to download and manage upgrade, patch, and install binaries. Pre-update validation performs health checks and compatibility verification before patches are applied, and component interdependency management helps maintain compatibility and stability across the infrastructure during updates. All dependent elements related to package objects are added to packages automatically to help maintain compatibility between versions. VCF Operations also provides compliance management capabilities that detect violations, highlight risk areas, and provide actionable remediation recommendations, with out-of-the-box workflows mapped to recommendations and associated with specific alerts for automated remediation.

VCF supports programmatic management of the patching process through multiple interfaces. The VMware vCenter patching API supports discovery of all available and applicable updates for vCenter instances in the environment, including minor in-place updates and major migration-based updates. REST API endpoints provide operations for checking pending updates, requirements checking, staging, and installation. The life cycle management API provides operations for listing all available updates and upgrades and generating a pre-check compatibility report before applying updates. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, and the Update-Entity operation remediates hosts by applying baselines with configurable failure handling and retry behavior. PowerCLI provides the Update Manager module with cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating hosts, including a Test-Compliance command to verify entities against

downloaded patches. The vCenter Appliance itself can be patched via the vCenter Appliance Management Interface (VAMI) or the appliance shell; VMware distributes vCenter patches in two forms, ISO-based and URL-based, and the `software-packages` utility in the appliance shell supports both methods, including staging patches from a repository URL, installing directly from a URL without staging, or installing from an attached ISO image. These interfaces enable integration with external change management and orchestration systems for automated remediation workflows.

VCF includes several capabilities to reduce patching risk and support continuity during updates. Live Patching updates and restarts discrete components without requiring host evacuation or reboot, as vSphere Lifecycle Manager does not place hosts into maintenance mode when a Live Patch is enforced. Snapshots should be created before patching VCF Operations fleet management to provide a rollback path. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, which evacuates data to maintain object accessibility during updates through durability components. The VCF Download Tool supports a patches-only option and offline depot configuration for managing patch binaries in air-gapped environments.

VCF Operations complements patch application with patch-gap detection for server firmware. It monitors hardware properties across the fleet, including BIOS version and BIOS release date, and provides dashboards that flag hosts running outdated server BIOS. This detection capability helps administrators identify hosts that require firmware patching before they become a compliance or security gap.

The VCF Consumption layer, implemented through vSphere Supervisor and VMware Kubernetes Service (VKS), extends this patching coverage to Kubernetes control plane components and cluster add-ons. VKS clusters use a rolling update model where updates are initiated by changing the cluster specification; the Supervisor reconciler applies changes node by node to maintain cluster availability during the process. This model covers control plane components including kube-apiserver, kube-controller-manager, kube-scheduler, etcd, kubelet configuration, and CoreDNS, all updated through the kubeadm upgrade mechanism. Kubeadm supports targeted patching of individual components through a patches directory; files named with the pattern `target[suffix][+patchtype].extension` (for example, `kube-apiserver0+merge.yaml` or `etcd.json`) apply strategic merge patches, merge patches, or JSON patches to the specified component. The patches mechanism is available through the InitConfiguration, JoinConfiguration, and UpgradeConfiguration APIs, providing consistent patching behavior across cluster initialization, node join, and upgrade operations. Instance-specific patches can also be applied over the base KubeletConfiguration through kubeadm customization.

VKS clusters support add-on management that enables installation and updates of standard packages through versioned add-on repositories. Administrators can track and update packages such as istio, harbor, sriov-network-device-plugin, windows-gmsa-webhook, and vsphere-pv-csi-webhook as new versions become available. For container image currency, Harbor is available as a Supervisor service and provides vulnerability scanning and content trust capabilities to help identify images that require patching. Admission controllers, including validating webhooks and image pull policies, can be configured to restrict deployment of images that have not passed vulnerability scanning or that contain known vulnerabilities, integrating image patch compliance into the workload deployment workflow. Content library VM images deployed in the vSphere Supervisor environment should be created with the latest patches and required security settings aligned with organizational security policies. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS node releases (VKRs), providing prescriptive hardening guidance that defines what patches and configurations constitute a compliant deployment for the Kubernetes consumption layer.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with

a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.4

> Perform Automated Application Patch Management

SCF Controls: VPM-05, VPM-05.1, VPM-05.2, VPM-05.4

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized software and firmware patching across the entire infrastructure stack through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane. VCF Operations is the central orchestration point for patching and update operations, coordinating patch releases (such as 9.0.1.0100) that deliver time-sensitive fixes to security and operational issues between major, minor, and maintenance releases.

VCF uses a desired-state model for host remediation through vSphere Lifecycle Manager (vLCM). Administrators define a software specification for each cluster, and vLCM brings all hosts into compliance with that specification during remediation. This approach applies uniformly to VMware-supplied components and third-party solutions alike. To make a third-party solution available on a cluster, administrators create a software specification containing the solution and remediate all hosts with that image. vLCM manages software updates for VMware ESX hosts, including patches of the ESX base image, OEM additions, components from different software vendors, and VMware Tools updates. Dynamic patch baselines automatically adjust their contents based on specified criteria each time Update Manager downloads new patches, keeping remediation current without manual baseline maintenance. Fixed baselines are also available for environments that require explicit control over which patches are applied. Hardware Support Manager (HSM) plugins extend vLCM to manage vendor-specific firmware and driver updates alongside software patches, providing unified lifecycle management for both software and firmware from within the same interface. Firmware updates through Hardware Support Manager are only available for clusters and hosts managed with vSphere Lifecycle Manager images; hosts managed with baselines do not support firmware updates through this mechanism.

The remediation workflow is coordinated through multiple layers. Coordinator Manager runs pre-checks before remediation begins to evaluate how each host in the cluster is affected and whether additional steps are needed. Pre-checks verify component connectivity, version compatibility, and component status. The ESX Updater Manager then handles the actual remediation on each host. Coordinator Manager also allows administrators to query the status of the remediation operation for the cluster and for each individual host, providing centralized visibility into remediation progress. The VCF Operations cluster transition specification includes a remediationOptionsSpec with a configurable remediationFailureAction that supports automatic retry with adjustable retryCount and retryDelay parameters, allowing administrators to define consistent remediation behavior.

VCF Operations extends lifecycle management with patch planner functionality for VCF core components, including the ability to download and manage upgrade, patch, and install binaries. Pre-update validation performs health checks and compatibility verification before patches are applied, and component interdependency management helps maintain compatibility and stability across the infrastructure during updates. All dependent elements related to package objects are added to packages automatically to help maintain compatibility between versions. VCF Operations also provides compliance management capabilities that detect violations, highlight risk areas, and provide actionable remediation recommendations, with out-of-the-box workflows mapped to recommendations and associated with specific alerts for automated remediation.

VCF supports programmatic management of the patching process through multiple interfaces. The VMware vCenter patching API supports discovery of all available and applicable updates for vCenter instances in the environment, including minor in-place updates and major migration-based updates. REST API endpoints provide operations for checking pending updates, requirements checking, staging, and installation. The life cycle management API provides operations for listing all available updates and upgrades and generating a pre-check compatibility report before applying updates. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, and the Update-Entity operation remediates hosts by applying baselines with configurable failure handling and retry behavior. PowerCLI provides the Update Manager module with cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating hosts, including a Test-Compliance command to verify entities against

downloaded patches. The vCenter Appliance itself can be patched via the vCenter Appliance Management Interface (VAMI) or the appliance shell; VMware distributes vCenter patches in two forms, ISO-based and URL-based, and the `software-packages` utility in the appliance shell supports both methods, including staging patches from a repository URL, installing directly from a URL without staging, or installing from an attached ISO image. These interfaces enable integration with external change management and orchestration systems for automated remediation workflows.

VCF includes several capabilities to reduce patching risk and support continuity during updates. Live Patching updates and restarts discrete components without requiring host evacuation or reboot, as vSphere Lifecycle Manager does not place hosts into maintenance mode when a Live Patch is enforced. Snapshots should be created before patching VCF Operations fleet management to provide a rollback path. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, which evacuates data to maintain object accessibility during updates through durability components. The VCF Download Tool supports a patches-only option and offline depot configuration for managing patch binaries in air-gapped environments.

VCF Operations complements patch application with patch-gap detection for server firmware. It monitors hardware properties across the fleet, including BIOS version and BIOS release date, and provides dashboards that flag hosts running outdated server BIOS. This detection capability helps administrators identify hosts that require firmware patching before they become a compliance or security gap.

The VCF Consumption layer, implemented through vSphere Supervisor and VMware Kubernetes Service (VKS), extends this patching coverage to Kubernetes control plane components and cluster add-ons. VKS clusters use a rolling update model where updates are initiated by changing the cluster specification; the Supervisor reconciler applies changes node by node to maintain cluster availability during the process. This model covers control plane components including kube-apiserver, kube-controller-manager, kube-scheduler, etcd, kubelet configuration, and CoreDNS, all updated through the kubectl upgrade mechanism. Kubectl supports targeted patching of individual components through a patches directory; files named with the pattern `target[suffix][+patchtype].extension` (for example, `kube-apiserver0+merge.yaml` or `etcd.json`) apply strategic merge patches, merge patches, or JSON patches to the specified component. The patches mechanism is available through the InitConfiguration, JoinConfiguration, and UpgradeConfiguration APIs, providing consistent patching behavior across cluster initialization, node join, and upgrade operations. Instance-specific patches can also be applied over the base KubeletConfiguration through kubectl customization.

VKS clusters support add-on management that enables installation and updates of standard packages through versioned add-on repositories. Administrators can track and update packages such as istio, harbor, sriov-network-device-plugin, windows-gmsa-webhook, and vsphere-pv-csi-webhook as new versions become available. For container image currency, Harbor is available as a Supervisor service and provides vulnerability scanning and content trust capabilities to help identify images that require patching. Admission controllers, including validating webhooks and image pull policies, can be configured to restrict deployment of images that have not passed vulnerability scanning or that contain known vulnerabilities, integrating image patch compliance into the workload deployment workflow. Content library VM images deployed in the vSphere Supervisor environment should be created with the latest patches and required security settings aligned with organizational security policies. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS node releases (VKRs), providing prescriptive hardening guidance that defines what patches and configurations constitute a compliant deployment for the Kubernetes consumption layer.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) Installer provides a Package Management interface that supports uploading upgrade bundles from a local file or URL to install and upgrade the installer and SSP components. Before an upgrade proceeds, SSP performs prechecks of its components during upgrade validation to verify health. The upgrade process allows selection of the target platform version from a drop-down menu, with available versions determined by the bundles uploaded during upgrade preparation; those bundles are downloaded from the Broadcom support portal and uploaded to the SSP Installer by an administrator. These platform upgrade workflows are primarily administrator-initiated rather than fully automated, and full platform-level upgrade orchestration requires external tooling.

For threat detection content, vDefend provides genuine automated update mechanisms. The IDS/IPS signature management interface supports an Auto Update option that, when enabled, checks the vTIS portal for new intrusion detection signatures every four hours and installs them automatically. In multi-site deployments, the Global Manager's Auto Update mode propagates signature bundle updates to mapped Local Manager sites without additional administrator action. The Auto Update toggle can be disabled for environments that require administrator review before signature changes are applied, enabling manual signature bundle management in place of automatic downloads.

The Gateway Firewall GeoIP bundle supports configurable automatic updates through an Auto Update setting that can be toggled on or off, providing automated geographic IP data refresh for GeoIP-based policy enforcement.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 7.5

> Perform Automated Vulnerability Scans of Internal Enterprise Assets

SCF Controls: VPM-06, VPM-06.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.6

> Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets

SCF Controls: VPM-06, VPM-06.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.7

> Remediate Detected Vulnerabilities

SCF Controls: VPM-02, VPM-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply

remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 8.0

> Audit Log Management: Collect, alert, review, and retain audit logs of events that could help detect, understand, or recover from an attack.

SCF Controls: MON-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter

Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as `SUCCESS`, `NOT_ENOUGH_BASELINE`, and `FAILURE`.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 8.1

> Establish and Maintain an Audit Log Management Process

SCF Controls: MON-01.8, MON-02, MON-04, MON-10

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpdx.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKR 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to execute while logging each to syslog or auditd; an `audit.json` seccomp profile can log all syscalls of a process for detailed syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with local buffering at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response (NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the

ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of

security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control 8.2

> Collect Audit Logs

SCF Controls: MON-01, MON-01.4, MON-02, MON-02.7, MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states

(Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service,

allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.llmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 8.3

> Ensure Adequate Audit Log Storage

SCF Controls: MON-02, MON-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides several log storage capacity management mechanisms for its security event data.

At the Distributed Firewall (DFW) layer, packet logging uses bounded log rotation: the `DFWPKTLOGS.log` file rotates at a 50 MB per-file limit, and the system retains a maximum of 10 log files at a time. This bounds DFW packet log storage on transport nodes while retaining sufficient history for troubleshooting and forensic analysis.

vDefend IDS/IPS includes an automated protective mechanism that handles high-volume event scenarios. When incoming IDS/IPS events and PCAP data would otherwise exhaust memory, the mechanism selectively drops non-critical events and

PCAPs to maintain system stability. Administrators can observe event volumes through the IDS/IPS Security Dashboard and Security Overview Dashboard.

IDS/IPS event data can be forwarded to external syslog consumers by enabling the `ids_events_to_syslog` setting under IDS/IPS Settings. Exporting events externally offloads local storage consumption so that log accumulation on transport nodes is bounded by the rotation policy rather than event volume. Remote syslog must be configured on the ESX host to receive IDS/IPS events exported directly from ESX hosts. vDefend components write logs to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts.

Guest Introspection Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts, with each log message including a timestamp, ContextMUX identifier, and thread ID.

The Security Services Platform (SSP), which hosts Security Intelligence and Network Detection and Response analytics, has documented storage sizing baselines for capacity planning. Each SSP controller node requires 225 GB of storage and each worker node also requires 225 GB. Storage requirements scale with worker node count, adding approximately 155 GB per additional worker node. For a maximum configuration of 10 worker nodes (14 total nodes), the recommended persistent volume claim is 3,545 GB. These sizing baselines enable administrators to allocate storage capacity appropriately at deployment time.

vDefend logs can be forwarded to VCF Log Management by configuring it as a syslog server. VCF Log Management provides a centralized log management framework and supports querying log data by time range through Interactive Analytics.

These mechanisms address event log storage capacity for vDefend's security event data. Broader log storage governance across the VCF platform, including infrastructure-wide capacity monitoring and centralized retention policies, is handled by VCF Log Management and VCF Operations.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable log storage settings and two-tier capacity alerting that support proactive management of event log storage.

DSM Provider logging includes configurable log storage settings accessible through the Provider interface under Storage Settings. Administrators configure the Provider Log Repo URL to direct logs to an S3-compatible object storage repository and bucket; the Bucket Name and optional Region settings complete the S3 object store configuration. Gateway audit log files are stored locally on the Provider VM at `/var/log/tdm/provider/audit/` using filenames in the format `gateway-audit-timestamp.log`, and are archived periodically to an S3 subpath named `gateway audit` when a provider log repository is configured. The Provider VM ships with a default storage configuration of three disks totaling 595 GB (80 GB, 15 GB, and 500 GB), which can be sized for the anticipated log and backup volume at deployment time.

DSM includes two-tier capacity alerting to notify administrators before storage is exhausted. The `data-disk-warning-threshold` setting governs a WARNING global alert when data disk usage reaches 70%; the `data-disk-critical-threshold` setting governs a CRITICAL global alert at 90%. When either threshold is breached, administrators can increase the storage allocation using the `storage-amount` setting. These alerts are visible to DSM administrators and prompt timely remediation before log capacity is exceeded.

For SQL Server databases, DSM exposes the `errorLog.numErrorLogs` custom engine setting, which controls how many error log files are retained before recycling. Configuring this setting allows administrators to manage database-engine-level log storage consumption directly.

S3-compatible storage sizing for DSM depends on the volume of data backups and the configured retention policy. Organizations must assess their log generation rates, retention requirements, and backup volumes to right-size the S3 repository. DSM does not automatically provision or expand storage capacity, so organizational processes for periodic capacity review and storage expansion remain necessary to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as ``event_id=CONFIG_CREATE`` or ``event_id=CONFIG_UPDATE`` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control 8.4

> Standardize Time Synchronization

SCF Controls: MON-02, MON-07.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API

endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) requires configuration of a Network Time Protocol (NTP) service with a reliable time source to synchronize the clocks of all deployed VMs. This requirement is documented as a deployment prerequisite in the DSM installation guide. The Provider Appliance and all managed database instances must use the same NTP server, enforcing clock uniformity across the entire DSM environment.

NTP server configuration is managed through the DSM System Settings interface. The Provider VM's System Settings panel includes an NTP Servers field where administrators specify one or more NTP servers as a list of IP addresses or fully qualified domain names. DSM applies NTP settings from the system configuration to synchronize database time with system time, helping maintain consistent timekeeping across the Provider Appliance and all managed database VMs.

DSM monitors time synchronization health through its global alerts system. When Provider NTP synchronization fails, DSM generates an `NTP_SYNC_FAILED` alert. At the database level, DSM generates an `NTP_NOT_APPLIED` alert when NTP settings from the system configuration have not been applied to a database instance, indicating that the system is not synchronizing database time. NTP synchronization failures can result in authentication failures, backup and restore corruptions, and certificate errors, which is why DSM enforces NTP synchronization as a deployment prerequisite rather than a recommendation. Administrators can configure webhooks to receive notification of these alerts. When `NTP_SYNC_FAILED` is triggered, DSM documentation directs administrators to verify and correct any invalid entries in the NTP Servers field in System Settings.

DSM uses Coordinated Universal Time (UTC) for system-generated timestamps, including timestamps on downloaded support bundles. Maintenance Policy schedules for software updates also require start time specification in UTC, reinforcing consistent time reference across operational activities.

DSM does not provision or manage the authoritative time source itself, which is standard for any product that synchronizes to an external NTP server. Organizations establish and maintain the NTP infrastructure that DSM references.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the ``log()`` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as ``event_id=CONFIG_CREATE`` or ``event_id=CONFIG_UPDATE`` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware vDefend. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 8.5

> Collect Detailed Audit Logs

SCF Controls: MON-02, MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware

Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API

endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control 8.6

> Collect DNS Query Audit Logs

SCF Controls: MON-02, MON-02.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API

endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the ``log()`` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service

client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event\_id=CONFIG\_CREATE` or `event\_id=CONFIG\_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.7

> Collect URL Request Audit Logs

SCF Controls: MON-02, MON-02.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API

endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service

client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event\_id=CONFIG\_CREATE` or `event\_id=CONFIG\_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.8

> Collect Command-Line Audit Logs

SCF Controls: MON-02, MON-03.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) logs all access events by default; this audit logging cannot be disabled. Log entries include the username of the actor, along with timestamp, component, subcomponent, and log level, which allows actions to be attributed to specific privileged accounts. The SSP provides two predefined local accounts: an admin account with the Enterprise Admin role (full platform management access) and an audit account with the Auditor role (read-only access to APIs and services for system auditing). The Auditor role grants read-only access to view information and track activity without the ability to make changes.

In VMware vDefend, Unified Security Logs in VCF Log Management consolidate log messages from the Distributed Firewall (DFW), Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering. Logs from vDefend can be forwarded to VCF Log Management by configuring it as a syslog server, which provides a centralized view of security policy enforcement activity across vDefend components. The SSP also supports remote logging to external syslog servers with configurable protocol, log level, and message ID filtering (SECURITY, MONITORING).

The vDefend distributed firewall supports per-rule logging with custom tags to track allowed and denied traffic for audit purposes; this logging is off by default and must be enabled on rules where traceability of network activity is required. vDefend IDS/IPS logs are accessible for compliance review of intrusion detection and prevention activities. Logging verbosity for Guest Introspection components such as the Host Agent (MUX) can be configured using the `nsxcli` command at multiple levels (off, fatal, error, warn, info, debug, trace) to capture additional service-level detail during investigation.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 generates audit event records for actions performed by both its Administrator and User role accounts, capturing activity through the DSM UI, API, and Gateway Kubernetes interface. These audit events are accessible through the System Audit Events section in the DSM interface and through the Gateway Audit Logs capability, which records read and write operations against data services and infrastructure objects.

Each audit log entry captures the Source field, which identifies either the email address of the DSM user who initiated the operation or "System" when DSM acted autonomously. Additional fields include Event Type (the category of the audited operation), Status (the outcome), and Event Details (operation-specific context). This structured record allows administrators to reconstruct what actions were taken, by whom, and with what result. Gateway audit log files are written to the Provider VM at `/var/log/tdm/provider/audit/` using timestamped filenames.

DSM generates service account rotation logs that can be checked to verify service account management activities, providing a record of privileged system-level operations beyond user-initiated actions.

For database-level activity, DSM-managed PostgreSQL databases include the pgaudit extension, which provides detailed audit logging of database operations. PostgreSQL log files are stored in the `/pgsql/logs/postgres` directory when the `logging_collector` is activated. MySQL databases on DSM use GTID-based logging activated through the `gtid_mode` setting. SQL Server databases in DSM include an Enable Auditing setting that allows administrators to select the level of audit logging for system logins and configure the log retention period at the database engine level.

DSM supports log forwarding to external destinations through the log-forwarding setting under Managing Settings. This allows audit and system log data to be sent to a centralized log aggregation platform where privileged activity records can be reviewed alongside logs from other infrastructure components. The System Logs view in the Provider interface provides an additional surface for system log collection management.

DSM's Administrator role has broader access than the User role, and the Permissions view in the dashboard enables creation, monitoring, and management of configured users. The DSM console restricts views and actions available to users based on their role, providing differentiated access at the UI level. However, DSM does not implement a dedicated privileged-account audit channel that distinguishes Administrator-role actions from User-role actions at the logging level. The full privileged functions logging requirement, including periodic review of audit records, assignment of review responsibilities, and retention of records for a defined period, depends on organizational processes and the external log management tooling to which DSM forwards its audit data.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the ``log()`` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service

client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as ``event_id=CONFIG_CREATE`` or ``event_id=CONFIG_UPDATE`` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control 8.9

> Centralize Audit Logs

SCF Controls: MON-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API

endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service

client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event\_id=CONFIG\_CREATE` or `event\_id=CONFIG\_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.11

> 8. Conduct Audit Log Reviews

SCF Controls: MON-02.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. The syslog firewall ruleset must be explicitly enabled on ESX hosts to permit outbound log traffic. ESX syslog messages conform to RFC 3164, providing a standardized format for ingestion by central log management platforms. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands, and the syslog directory location is controlled through the `Syslog.global.logDir` parameter. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage. ESX also maintains a distinct audit record subsystem that specifically tracks security-related activity on the host, separate from general syslog messages. Remote transmission of these audit records to syslog collectors is controlled by the `Syslog.global.auditRecord.remote` parameter, and local storage of audit records is enabled via `esxcli system auditrecords local enable`; both can be configured independently of each other.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter supports syslog forwarding to a maximum of three remote servers, using TCP, UDP, TLS, and RELP protocols. The remote syslog target must be a server running rsyslog. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and NSX includes correlation fields (`reqId`, `splitId`, `splitIndex`) to track and reassemble multi-part audit events. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration, with editable log sources allowing administrators to control which systems feed into the central repository. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for

centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. VCF Operations records audit events for platform interactions including searches, logins, logouts, capability checks, and configuration modifications. Audit events can be viewed, filtered, and searched through the console interface, with filtering options by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. All audit log data can be exported in CSV format for offline analysis or ingestion into external SIEM platforms. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations also includes dedicated audit reporting capabilities. The User Activity Audit report provides traceability of user activities including logging in, actions on clusters and nodes, changes to system passwords, certificate activation, and logging out. The User Permissions Audit report provides traceability of user accounts, their roles, access groups, and access privileges. Both report types can be downloaded in PDF or XLS format. System Audit reports can be downloaded from the Administration, Control Panel, Audit, System Audit tab.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog, and audit logs capture actions from the API, the user interface, and the CLI. Audit logs are accessible on the Settings page with access controlled by user role, and all audit log data can be exported in CSV format for review and analysis.

VCF Automation maintains its own audit log accessible through the Infrastructure tab under Activity, Audit Log. It generates audit log entries for create, delete, and update operations on property groups, feature toggles, policies (including Day 2 actions, lease, and approval policies), event subscriptions, blueprint deployments, catalog item deployments, and resource changes. Each entry contains information such as a timestamp, message, user name, project name, and trace ID value. VCF Automation audit logs can be filtered, searched, displayed, and exported in CSV format. The Organization Administrator and Organization Auditor roles have access to view these logs.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. vSphere Supervisor can forward control plane VM system logs to external syslog servers through Fluent Bit configuration, using RFC 5424 syslog format with TCP mode. Fluent Bit pods in the `vmware-system-logging` namespace manage log forwarding and configuration, and their logs can be queried using `kubectl` commands to monitor audit log streaming status. VCF Identity Broker supports log collection as well.

VCF logs auditable events across the platform to align with global compliance frameworks. This baseline of audit event generation feeds into the centralized collection and analysis mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend generates and manages multiple categories of audit-relevant records that feed into centralized collection and analysis platforms, and provides domain-specific centralized analysis capabilities for network security events across the VCF environment.

vDefend supports configurable rule logging using labels for audit and troubleshooting purposes. When logging is enabled on a firewall rule, each matched connection generates a log entry that includes the rule ID, source and destination addresses, ports, protocol, and the custom label. These log entries are forwarded via syslog to centralized log management platforms such as VCF Log Management, where they can be searched, correlated, and analyzed alongside records from other VCF

components. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts, providing standard-format log records compatible with most centralized log management platforms.

Security Intelligence, hosted within the Security Services Platform, provides centralized analysis of network traffic flows collected from across the vDefend-protected environment. It analyzes east-west traffic patterns, identifies unprotected flows, generates policy recommendations based on observed activity, and produces downloadable reports. Security Intelligence also performs infrastructure classification, automatically identifying server roles and grouping workloads based on their observed network behavior over the preceding 30 days. These analysis capabilities operate across multiple segments and workload groups simultaneously, providing a consolidated view of network security posture.

The Security Services Platform Rule Analysis feature generates downloadable CSV reports covering detected anomalies across firewall rules, including shadowed rules, redundant rules, and conflicting rules. The Auditor role within Security Services Platform has full access to view and download rule analysis results. Security Services Platform includes a dedicated local Audit account with the auditor role that has full access to APIs and services for system auditing. The Security Segmentation scoring and reporting capabilities allow compliance officers to review segmentation posture and monitor security policy coverage.

vDefend IDS/IPS event correlation produces structured event records with signature metadata including severity levels and threat categories. IDS/IPS events can be exported to syslog by enabling the `ids_events_to_syslog` setting; remote syslog must be configured on ESX hosts to receive events exported directly from those hosts. IDS/IPS audit logs record the specific logical entity where inspection occurred, such as Tier-0 Gateway, Host Transport Node, or Kubernetes Cluster Nodes, providing traceability to the detection point.

Malware Prevention analysis reports include file reputation information, process analysis results, ATT&CK technique mappings for observed malicious behaviors, and links to third-party threat intelligence on the VirusTotal portal. The Security Overview Dashboard provides a breakdown of file inspections by analysis type, including local file analysis and cloud file analysis, enabling operators to monitor the scope of malware detection activity. Security Services Platform captures detailed audit log fields for process-based malware monitoring, including verdict of in-memory script execution, SHA-256 hash of the process binary, and parent process ID.

vDefend Identity Firewall Event Log Sources can be configured to collect logs from Active Directory event sources or VCF Log Management, and supports integration with VCF Log Management for centralized logging and monitoring.

vDefend is not itself the centralized log aggregation platform (that role belongs to VCF Log Management), but it is a significant source of auditable security event data and provides domain-specific centralized analysis capabilities for network security events, traffic flows, and firewall policy.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates audit records from multiple internal sources and provides mechanisms to centrally view, access, and export those records for review and analysis. The platform captures audit events covering user actions performed through the DSM UI and API, as well as actions that DSM itself initiates. This includes administrative operations, database lifecycle events, and system-level activities. The System Audit Events view, accessible through the System Audit section of the Provider interface, is the central location for tracking non-database-related operations and tasks.

The audit records generated by DSM contain structured fields that support systematic review. Each audit event includes a Component field identifying which DSM component performed the operation, an Event Type field identifying the category of the event, an Event Details field providing operation-specific context, Event Time in UTC, a Status field, and a Source field identifying either the user identifier (Email ID) that initiated the operation or "System" when DSM itself initiated it. Gateway audit log files are stored on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and contain standard Kubernetes audit events. When a default S3 provider log repository is configured, DSM automatically archives gateway audit log files to that repository on a periodic basis to an S3 subpath named "gateway audit," providing an off-platform collection point.

For database-level audit logging, PostgreSQL databases provisioned by DSM include the pgaudit extension, which provides audit logging capabilities across all supported PostgreSQL versions. The pgaudit extension captures database-level audit events separately from the gateway-level audit trail, giving administrators visibility into both infrastructure-level operations and database operations as distinct audit sources. SQL Server databases provisioned by DSM include configurable server auditing with preset audits for login tracking and log retention. The Login Auditing option automatically creates an audit for login events, and DSM supports the T-SQL CREATE AUDIT and CREATE AUDIT SPECIFICATION DDL for custom audit definitions. These SQL Server capabilities add a third distinct audit source alongside gateway and PostgreSQL audit streams.

DSM supports audit record export in CSV and XLSX formats through the ACTIONS dropdown in the System Audit Events view. Exports include all audit events visible to the current user regardless of pagination limits. DSM also supports log forwarding via syslog, enabling organizations to route audit data to external log management and SIEM platforms for automated collection and analysis across multiple sources. VI administrators can monitor PostgreSQL and MySQL clusters deployed by DSM using VCF Operations, which automatically discovers clusters in the Ready state and displays performance data at the cluster, node, and database levels.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.12

> 8. Collect Service Provider Logs

SCF Controls: MON-02, MON-02.1, MON-02.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend Network Detection and Response (NDR) correlates detection events into campaigns, comparing new detection data against existing events to identify related activity. Campaigns provide a view of a threat by correlating detection events to identify the different stages of an attack, and security analysts can view and triage threat campaigns through a campaign timeline. NDR supports SIEM integration, sending campaign and event logs to a connected SIEM in real time, allowing network security event data to be exported for broader correlation with other enterprise data sources.

Security Intelligence detects and categorizes suspicious events using MITRE ATT&CK tactics and techniques, recording event occurrences during selected time periods, and provides a View Full Event History capability that displays all events associated with a given signature ID and intrusion severity. Security Intelligence also correlates IDS events from the same source and destination hosts to connect related events and build a broader picture of an attack. This structured, MITRE-tagged event data can support SIEM-based analysis and enterprise-wide threat correlation.

The Security Services Platform (SSP) can be configured to forward log messages to external syslog servers for centralized log collection. SSP syslog configuration supports TCP, TLS, and UDP protocols and allows administrators to specify server address and port, integrating with existing SIEM ingestion pipelines. NDR Sensors report metrics covering health, traffic trends, and data processing activity, available as point-in-time measurements or aggregated data over time.

vDefend correlates only technical network security data and has no capability to ingest or correlate non-technical information such as HR records, physical access logs, or operational data. Satisfying the full scope of this control, which requires correlation of both technical and non-technical information across the enterprise, requires an external SIEM or equivalent platform.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 9.0

> Email and Web Browser Protections: Improve protections and detections of threats from email and web vectors, as these are opportunities for attackers to manipulate human behavior through direct engagement.

SCF Controls: CFG-04.2, END-08, HRS-05.2, IRO-15, NET-18, SAT-02.2

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides several networking capabilities that contribute to an organization's ability to enforce DNS and content filtering for internet-bound traffic, though it does not include a standalone URL content filtering or DNS filtering solution.

NSX, the networking component of VCF, includes a DNS forwarding service that can be configured with a default DNS zone and up to five FQDN-based zones. DNS queries are forwarded to the servers specified in matching zones, or to the default zone when no match is found. When configuring a DNS zone, administrators can specify a source IP for the forwarder to use when forwarding queries to an upstream DNS server, and if no source IP is specified, the query packet's source IP defaults to the forwarder's listener IP. The DNS forwarding service supports queries over both TCP and UDP. This DNS forwarding capability gives administrators control over how name resolution traffic flows within the VCF environment and can direct queries to DNS servers that enforce filtering policies.

vDefend supports FQDN-based firewall rules that allow administrators to permit or reject traffic destined for specific domains, enabling domain-level traffic control at the Distributed Firewall layer. vDefend can process DNS response packets containing canonical names (CNAMEs), so FQDN-based rules resolve correctly even when domains use aliased records. To use FQDN-based filtering, administrators configure a high-priority rule with a DNS App ID for the designated DNS servers on port 53, which allows vDefend to inspect DNS traffic and enforce FQDN-based policies. vDefend drop rules can also block ingress or egress traffic, providing a foundation for restricting outbound connections to unapproved destinations.

Multiple VCF components support proxy configuration for routing internet-bound traffic through a policy enforcement point. NSX Manager supports proxy settings to route HTTP and HTTPS management traffic through a designated proxy server. vCenter supports HTTPS proxy configuration via the Cluster Management API for Supervisor workloads. VCF Operations supports HTTP proxy configuration for outbound settings, and VCF Operations for Networks supports web proxy settings that require specification of a proxy type, IP address or FQDN, port number, and nickname. The VCF Download Tool also accepts proxy parameters (including --proxy-server, --proxy-https, --proxy-user, and --proxy-user-password-file) for environments where internet access is only available through a proxy.

For URL content filtering and deep traffic inspection, VMware vDefend extends VCF's NSX networking layer with Gateway Firewall L7 Access Profiles. These profiles can be applied to both Tier-0 and Tier-1 gateway firewall rules or to layer 7 distributed firewall rules. L7 Access Profiles support URL category filtering with over 80 categories (including social media, banking, and phishing), URL reputation levels (High Risk, Suspicious, Moderate Risk, Low Risk, Trustworthy, and Unknown), and custom URLs with regular expression matching. Configurable rule actions include Allow, Reject, or Reject with Response for matched traffic. vDefend DNS Security profiles guard against DNS-related threats and attacks, providing inline DNS inspection at the firewall layer. The vDefend distributed firewall also supports rules with context profiles covering sources, destinations, services, and rule direction parameters. The Stateful Gateway Firewall, which provides stateful inspection at the gateway tier, requires a vDefend license. These vDefend capabilities are separate from VCF and require additional licensing.

To implement a complete DNS and content filtering solution as described in this control, organizations should deploy a dedicated DNS filtering service or secure web gateway appliance and use NSX networking capabilities to route internet-bound traffic through that enforcement point. vDefend FQDN-based rules and Gateway Firewall policies can enforce that all outbound DNS and HTTP/HTTPS traffic traverses the designated proxy or filtering infrastructure. VCF's DNS forwarding and proxy routing capabilities across multiple components provide the traffic steering foundation, while the filtering service itself provides the URL categorization, reputation scoring, and policy enforcement that VCF does not natively include.

VMware vDefend (Meets)

VMware vDefend provides URL content filtering and FQDN-based traffic control capabilities that directly address the core intent of this control: limiting workload connections to dangerous or prohibited internet destinations.

The vDefend gateway firewall includes URL Filtering that controls access to websites based on three criteria: URL categories, URL reputation, and custom URLs. URL categories allow administrators to block or allow broad classes of websites such as gambling, malware, and social media sites, while URL reputation scores provide a risk-based assessment of individual sites. Custom URLs, configured through a Layer-7 context profile, allow organizations to define site-specific allow or deny rules. These URL filtering capabilities are enforced through L7 access profiles applied to gateway firewall rules, and gateway firewall rules using an L7 access profile must have the rule action set to Allow, with the actions in the L7 access profile determining how traffic is processed. URL filtering operates on both HTTPS and HTTP traffic. When a TLS Inspection policy is enabled, the Gateway Firewall decrypts HTTPS traffic to perform full URL path inspection rather than relying on hostname-level matching alone. URL filtering addresses a broad range of web-delivered threats including phishing attempts and spyware distribution sites. When URL Filtering blocks a request, the Gateway Firewall returns a response page for HTTP traffic containing the URL (first 10 bytes), the applicable category, the source IP address, and configurable message text. In addition, the Gateway Firewall supports Geo-IP Filtering, allowing administrators to restrict traffic based on geographic origin alongside URL category and reputation controls.

The vDefend Security Overview Dashboard provides monitoring of URL filtering activity, including inspected FQDNs grouped by top URL categories, the highest-severity URLs with date and time, distribution of URLs by severity rating, and the top URL categories with the greatest number of blocked requests. A per-gateway metric (gfw.url_filtering_rules) tracks the number of active URL filtering rules applied to each gateway, supporting operational visibility and policy validation.

At the distributed firewall layer, vDefend provides FQDN filtering that allows administrators to create rules controlling outbound traffic based on fully qualified domain names. FQDN filtering operates at Layer 7 and supports wildcard domain patterns, including standard asterisk wildcards such as *.office365.com*, *.teams.microsoft.com*, and **.sharepoint.com*, as well as a caret (^) suffix wildcard for single-word domain matching. FQDN filtering rules are configured using a system-generated DNS context profile that is available in the deployment by default, and they support allowlisting or denylisting with source groups, destination groups, and DNS services (DNS-TCP and DNS-UDP). For FQDN filtering to function correctly, virtual machines must use a dynamic DNS server for domain resolution; static DNS entries are not supported. vDefend also supports overriding DNS TTL values through a DNS security profile, giving administrators additional control over caching behavior for domain-based policy enforcement.

Together, these capabilities allow vDefend to act as a policy enforcement point within the virtual network, screening traffic based on URL reputation, URL category, domain name, and geographic origin. However, vDefend does not function as a standalone proxy device or provide dedicated DNS filtering infrastructure such as DNS sinkholing or recursive DNS resolver filtering. Organizations typically pair vDefend's URL and FQDN filtering with a dedicated secure web gateway or DNS filtering solution to achieve the full scope of proxy-based and DNS-based filtering described in this control.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.1

> Ensure Use of Only Fully Supported Browsers and Email Clients

SCF Controls: CFG-04.2, CFG-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.2

> Use DNS Filtering Services

SCF Controls: NET-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several networking capabilities that contribute to an organization's ability to enforce DNS and content filtering for internet-bound traffic, though it does not include a standalone URL content filtering or DNS filtering solution.

NSX, the networking component of VCF, includes a DNS forwarding service that can be configured with a default DNS zone and up to five FQDN-based zones. DNS queries are forwarded to the servers specified in matching zones, or to the default zone when no match is found. When configuring a DNS zone, administrators can specify a source IP for the forwarder to use when forwarding queries to an upstream DNS server, and if no source IP is specified, the query packet's source IP defaults to the forwarder's listener IP. The DNS forwarding service supports queries over both TCP and UDP. This DNS forwarding capability gives administrators control over how name resolution traffic flows within the VCF environment and can direct queries to DNS servers that enforce filtering policies.

vDefend supports FQDN-based firewall rules that allow administrators to permit or reject traffic destined for specific domains, enabling domain-level traffic control at the Distributed Firewall layer. vDefend can process DNS response packets containing canonical names (CNAMEs), so FQDN-based rules resolve correctly even when domains use aliased records. To use FQDN-based filtering, administrators configure a high-priority rule with a DNS App ID for the designated DNS servers on port 53, which allows vDefend to inspect DNS traffic and enforce FQDN-based policies. vDefend drop rules can also block ingress or egress traffic, providing a foundation for restricting outbound connections to unapproved destinations.

Multiple VCF components support proxy configuration for routing internet-bound traffic through a policy enforcement point. NSX Manager supports proxy settings to route HTTP and HTTPS management traffic through a designated proxy server. vCenter supports HTTPS proxy configuration via the Cluster Management API for Supervisor workloads. VCF Operations supports HTTP proxy configuration for outbound settings, and VCF Operations for Networks supports web proxy settings that require specification of a proxy type, IP address or FQDN, port number, and nickname. The VCF Download Tool also accepts proxy parameters (including --proxy-server, --proxy-https, --proxy-user, and --proxy-user-password-file) for environments where internet access is only available through a proxy.

For URL content filtering and deep traffic inspection, VMware vDefend extends VCF's NSX networking layer with Gateway Firewall L7 Access Profiles. These profiles can be applied to both Tier-0 and Tier-1 gateway firewall rules or to layer 7 distributed firewall rules. L7 Access Profiles support URL category filtering with over 80 categories (including social media, banking, and phishing), URL reputation levels (High Risk, Suspicious, Moderate Risk, Low Risk, Trustworthy, and Unknown), and custom URLs with regular expression matching. Configurable rule actions include Allow, Reject, or Reject with Response for matched traffic. vDefend DNS Security profiles guard against DNS-related threats and attacks, providing inline DNS inspection at the firewall layer. The vDefend distributed firewall also supports rules with context profiles covering sources, destinations, services, and rule direction parameters. The Stateful Gateway Firewall, which provides stateful inspection at the gateway tier, requires a vDefend license. These vDefend capabilities are separate from VCF and require additional licensing.

To implement a complete DNS and content filtering solution as described in this control, organizations should deploy a dedicated DNS filtering service or secure web gateway appliance and use NSX networking capabilities to route internet-bound traffic through that enforcement point. vDefend FQDN-based rules and Gateway Firewall policies can enforce that all outbound DNS and HTTP/HTTPS traffic traverses the designated proxy or filtering infrastructure. VCF's DNS forwarding and proxy routing capabilities across multiple components provide the traffic steering foundation, while the filtering service itself provides the URL categorization, reputation scoring, and policy enforcement that VCF does not natively include.

VMware vDefend (Contributes)

VMware vDefend provides URL content filtering and FQDN-based traffic control capabilities that directly address the core intent of this control: limiting workload connections to dangerous or prohibited internet destinations.

The vDefend gateway firewall includes URL Filtering that controls access to websites based on three criteria: URL categories, URL reputation, and custom URLs. URL categories allow administrators to block or allow broad classes of websites such as gambling, malware, and social media sites, while URL reputation scores provide a risk-based assessment of individual sites. Custom URLs, configured through a Layer-7 context profile, allow organizations to define site-specific allow or deny rules. These URL filtering capabilities are enforced through L7 access profiles applied to gateway firewall rules, and gateway firewall rules using an L7 access profile must have the rule action set to Allow, with the actions in the L7 access profile determining how traffic is processed. URL filtering operates on both HTTPS and HTTP traffic. When a TLS Inspection policy is enabled, the Gateway Firewall decrypts HTTPS traffic to perform full URL path inspection rather than relying on hostname-level matching alone. URL filtering addresses a broad range of web-delivered threats including phishing attempts and spyware distribution sites. When URL Filtering blocks a request, the Gateway Firewall returns a response page for HTTP traffic containing the URL (first 10 bytes), the applicable category, the source IP address, and configurable message text. In addition, the Gateway Firewall supports Geo-IP Filtering, allowing administrators to restrict traffic based on geographic origin alongside URL category and reputation controls.

The vDefend Security Overview Dashboard provides monitoring of URL filtering activity, including inspected FQDNs grouped by top URL categories, the highest-severity URLs with date and time, distribution of URLs by severity rating, and the top URL categories with the greatest number of blocked requests. A per-gateway metric (gfw.url_filtering_rules) tracks the number of active URL filtering rules applied to each gateway, supporting operational visibility and policy validation.

At the distributed firewall layer, vDefend provides FQDN filtering that allows administrators to create rules controlling outbound traffic based on fully qualified domain names. FQDN filtering operates at Layer 7 and supports wildcard domain patterns, including standard asterisk wildcards such as *.office365.com*, *.teams.microsoft.com*, and **.sharepoint.com*, as well as a caret (^) suffix wildcard for single-word domain matching. FQDN filtering rules are configured using a system-generated DNS context profile that is available in the deployment by default, and they support allowlisting or denylisting with source groups, destination groups, and DNS services (DNS-TCP and DNS-UDP). For FQDN filtering to function correctly, virtual machines must use a dynamic DNS server for domain resolution; static DNS entries are not supported. vDefend also supports overriding DNS TTL values through a DNS security profile, giving administrators additional control over caching behavior for domain-based policy enforcement.

Together, these capabilities allow vDefend to act as a policy enforcement point within the virtual network, screening traffic based on URL reputation, URL category, domain name, and geographic origin. However, vDefend does not function as a standalone proxy device or provide dedicated DNS filtering infrastructure such as DNS sinkholing or recursive DNS resolver filtering. Organizations typically pair vDefend's URL and FQDN filtering with a dedicated secure web gateway or DNS filtering solution to achieve the full scope of proxy-based and DNS-based filtering described in this control.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.3

> Maintain and Enforce Network-Based URL Filters

SCF Controls: NET-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several networking capabilities that contribute to an organization's ability to enforce DNS and content filtering for internet-bound traffic, though it does not include a standalone URL content filtering or DNS filtering solution.

NSX, the networking component of VCF, includes a DNS forwarding service that can be configured with a default DNS zone and up to five FQDN-based zones. DNS queries are forwarded to the servers specified in matching zones, or to the default zone when no match is found. When configuring a DNS zone, administrators can specify a source IP for the forwarder to use when forwarding queries to an upstream DNS server, and if no source IP is specified, the query packet's source IP defaults to the forwarder's listener IP. The DNS forwarding service supports queries over both TCP and UDP. This DNS forwarding capability gives administrators control over how name resolution traffic flows within the VCF environment and can direct queries to DNS servers that enforce filtering policies.

vDefend supports FQDN-based firewall rules that allow administrators to permit or reject traffic destined for specific domains, enabling domain-level traffic control at the Distributed Firewall layer. vDefend can process DNS response packets containing canonical names (CNAMEs), so FQDN-based rules resolve correctly even when domains use aliased records. To use FQDN-based filtering, administrators configure a high-priority rule with a DNS App ID for the designated DNS servers on port 53, which allows vDefend to inspect DNS traffic and enforce FQDN-based policies. vDefend drop rules can also block ingress or egress traffic, providing a foundation for restricting outbound connections to unapproved destinations.

Multiple VCF components support proxy configuration for routing internet-bound traffic through a policy enforcement point. NSX Manager supports proxy settings to route HTTP and HTTPS management traffic through a designated proxy server. vCenter supports HTTPS proxy configuration via the Cluster Management API for Supervisor workloads. VCF Operations supports HTTP proxy configuration for outbound settings, and VCF Operations for Networks supports web proxy settings that require specification of a proxy type, IP address or FQDN, port number, and nickname. The VCF Download Tool also accepts proxy parameters (including --proxy-server, --proxy-https, --proxy-user, and --proxy-user-password-file) for environments where internet access is only available through a proxy.

For URL content filtering and deep traffic inspection, VMware vDefend extends VCF's NSX networking layer with Gateway Firewall L7 Access Profiles. These profiles can be applied to both Tier-0 and Tier-1 gateway firewall rules or to layer 7 distributed firewall rules. L7 Access Profiles support URL category filtering with over 80 categories (including social media, banking, and phishing), URL reputation levels (High Risk, Suspicious, Moderate Risk, Low Risk, Trustworthy, and Unknown), and custom URLs with regular expression matching. Configurable rule actions include Allow, Reject, or Reject with Response for matched traffic. vDefend DNS Security profiles guard against DNS-related threats and attacks, providing inline DNS inspection at the firewall layer. The vDefend distributed firewall also supports rules with context profiles covering sources, destinations, services, and rule direction parameters. The Stateful Gateway Firewall, which provides stateful inspection at the gateway tier, requires a vDefend license. These vDefend capabilities are separate from VCF and require additional licensing.

To implement a complete DNS and content filtering solution as described in this control, organizations should deploy a dedicated DNS filtering service or secure web gateway appliance and use NSX networking capabilities to route internet-bound traffic through that enforcement point. vDefend FQDN-based rules and Gateway Firewall policies can enforce that all outbound DNS and HTTP/HTTPS traffic traverses the designated proxy or filtering infrastructure. VCF's DNS forwarding and proxy routing capabilities across multiple components provide the traffic steering foundation, while the filtering service itself provides the URL categorization, reputation scoring, and policy enforcement that VCF does not natively include.

VMware vDefend (Contributes)

VMware vDefend provides URL content filtering and FQDN-based traffic control capabilities that directly address the core intent of this control: limiting workload connections to dangerous or prohibited internet destinations.

The vDefend gateway firewall includes URL Filtering that controls access to websites based on three criteria: URL categories, URL reputation, and custom URLs. URL categories allow administrators to block or allow broad classes of websites such as gambling, malware, and social media sites, while URL reputation scores provide a risk-based assessment of individual sites. Custom URLs, configured through a Layer-7 context profile, allow organizations to define site-specific allow or deny rules. These URL filtering capabilities are enforced through L7 access profiles applied to gateway firewall rules, and gateway firewall rules using an L7 access profile must have the rule action set to Allow, with the actions in the L7 access profile determining how traffic is processed. URL filtering operates on both HTTPS and HTTP traffic. When a TLS Inspection policy is enabled, the Gateway Firewall decrypts HTTPS traffic to perform full URL path inspection rather than relying on hostname-level matching alone. URL filtering addresses a broad range of web-delivered threats including phishing attempts and spyware distribution sites. When URL Filtering blocks a request, the Gateway Firewall returns a response page for HTTP traffic containing the URL (first 10 bytes), the applicable category, the source IP address, and configurable message text. In addition, the Gateway Firewall supports Geo-IP Filtering, allowing administrators to restrict traffic based on geographic origin alongside URL category and reputation controls.

The vDefend Security Overview Dashboard provides monitoring of URL filtering activity, including inspected FQDNs grouped by top URL categories, the highest-severity URLs with date and time, distribution of URLs by severity rating, and the top URL categories with the greatest number of blocked requests. A per-gateway metric (gfw.url_filtering_rules) tracks the number of active URL filtering rules applied to each gateway, supporting operational visibility and policy validation.

At the distributed firewall layer, vDefend provides FQDN filtering that allows administrators to create rules controlling outbound traffic based on fully qualified domain names. FQDN filtering operates at Layer 7 and supports wildcard domain patterns, including standard asterisk wildcards such as *.office365.com*, *.teams.microsoft.com*, and **.sharepoint.com*, as well as a caret (^) suffix wildcard for single-word domain matching. FQDN filtering rules are configured using a system-generated DNS context profile that is available in the deployment by default, and they support allowlisting or denylisting with source groups, destination groups, and DNS services (DNS-TCP and DNS-UDP). For FQDN filtering to function correctly, virtual machines must use a dynamic DNS server for domain resolution; static DNS entries are not supported. vDefend also supports overriding DNS TTL values through a DNS security profile, giving administrators additional control over caching behavior for domain-based policy enforcement.

Together, these capabilities allow vDefend to act as a policy enforcement point within the virtual network, screening traffic based on URL reputation, URL category, domain name, and geographic origin. However, vDefend does not function as a standalone proxy device or provide dedicated DNS filtering infrastructure such as DNS sinkholing or recursive DNS resolver filtering. Organizations typically pair vDefend's URL and FQDN filtering with a dedicated secure web gateway or DNS filtering solution to achieve the full scope of proxy-based and DNS-based filtering described in this control.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.4

> Restrict Unnecessary or Unauthorized Browser and Email Client Extensions

SCF Controls: CFG-04.2, CFG-05.2, HRS-05.1, HRS-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.5

> Implement DMARC

SCF Controls: NET-10.3, NET-20.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.6

> Block Unnecessary File Types

SCF Controls: END-08, IRO-15, NET-03, NET-08

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides networking infrastructure and monitoring capabilities that support boundary protection at both external network boundaries and key internal boundaries within the virtual environment.

At the external boundary, NSX Edge nodes serve as the communication gateway for inter-location and northbound traffic, establishing a defined perimeter through which external communications traverse. NSX Edge supports policy-based and route-based IPsec VPN services on Tier-0, Tier-0 VRF, and Tier-1 gateways, enabling secure connectivity between sites and to external networks. NAT rules can be configured at the VPC level to perform IP translation between internal and external networks, controlling which workloads are reachable from outside the environment. External IP configurations allow outside connectivity for virtual machines on private networks by performing address translation through 1:1 NAT, granting access to specific workloads rather than exposing entire network segments.

For internal boundary control, VCF provides several layers of network segmentation. NSX segments, VLANs, and Private VLANs (PVLANS) allow administrators to create logical network boundaries that separate traffic at Layer 2. VMware distributed virtual switches support Private VLAN and VLAN-based SPAN for virtual distributed port mirroring. ESX port groups function as communication boundaries and can be configured with security policies to segment traffic between different groups of virtual machines. vSphere Distributed Switch port groups also support a Traffic Filtering and Marking Policy, which can permit or stop traffic on a per-port-group or per-port basis; port blocking policies provide a complementary mechanism to selectively prevent individual distributed ports from sending or receiving data. vSphere Distributed Switches provide centralized management of these boundaries across all hosts in a workload domain, applying consistent VLAN configurations and traffic shaping rules.

VCF supports multiple distributed switch models that isolate traffic at the physical layer. The Storage Separation Distributed Switch model isolates storage traffic onto a separate vSphere Distributed Switch from management and virtual networking traffic. The Workload Separation Distributed Switch model isolates VM Management traffic onto a separate switch from ESX Management, vMotion, Storage, and Virtual Networking traffic. In secure environments, these separation models can provide physical air-gapped separation of network traffic.

NSX Virtual Private Clouds (VPCs) provide isolated network environments within a shared infrastructure. VPCs support on-demand logical networks that can be advertised as public subnets or exposed through networking services like External IPs or NAT, providing project-level boundary isolation with their own topology, IP address management, and permission models. VCF Automation maintains secure organizational boundaries that isolate tenants from one another, providing additional logical separation within the environment.

Network I/O Control (NIOC) determines the bandwidth that different network traffic types are given on a vSphere distributed switch. When NIOC is enabled, distributed switch traffic is divided into predefined network resource pools covering Fault Tolerance, iSCSI, vMotion, management, vSphere Replication, NFS, and virtual machine traffic. Bandwidth reservation and shares allocation enforce performance boundaries between traffic types under contention. Avi Load Balancer provides Layer 4 load balancing for services, distributing traffic across server pools with configurable load balancing algorithms and health monitoring.

VCF provides network monitoring through multiple components. NSX supports IPFIX profile configuration on segments to enable flow-based network monitoring, giving administrators visibility into traffic traversing the network. At the vSphere layer, NetFlow can be enabled on individual distributed port groups or ports through the vSphere Distributed Switch monitoring policy, providing IP packet flow data independent of NSX. The pktcap-uw command-line utility on ESX hosts supports packet capture at specific points in the network stack, including at physical adapters and at the boundary between the distributed

switch and physical adapters, enabling packet-level traffic inspection without additional tools. NSX Manager monitors control plane connections between transport nodes and manager nodes, providing awareness of the network infrastructure state.

VCF Operations extends monitoring capabilities with network metrics including inbound and outbound connection tracking (net|allInboundTotal and net|allOutboundTotal). The Management Pack for Network Devices provides alerts and notifications for key network events including throughput totals and packet counts, and monitors outgoing errors on network interfaces. VCF Operations can detect protected flows, identifying traffic that has a specific firewall rule associated with it beyond a default allow-all policy, which helps administrators understand which communications are governed by explicit security policies. Outbound flow limits serve as a protection mechanism, with TCP flows limited to 1,000 allowed and 50 denied outbound, and UDP flows limited to 500 allowed and 50 denied outbound. VCF Operations also supports firewall hardening that restricts network access to its own internal services, demonstrating boundary protection for management interfaces.

VCF Operations for Networks adds flow analysis and troubleshooting capabilities, including application discovery based on flows, network topology visualization through the Topology Graph Widget, and traffic flow visualization between applications, application tiers, shared services, and the Internet. VCF Operations for Networks provides intents for network design and verification, helping validate that the network configuration matches the intended design. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU verification, while vSAN network partition health checks detect VLAN misconfigurations and uplink losses. VCF Operations for Networks also provides visibility into vDefend distributed firewall rule activity, including identification of inactive rules that have had no matching flows.

VMware Kubernetes Service (VKS) clusters and the vSphere Supervisor control plane extend boundary protection to the workload consumption layer. Within VKS clusters, Kubernetes NetworkPolicy objects provide declarative packet-filtering rules at OSI Layer 3 and Layer 4, defining permitted ingress and egress traffic based on pod label selectors, namespace selectors, and CIDR blocks. By default, pods accept all traffic; NetworkPolicy objects restrict communication to only the flows required for each workload or namespace, establishing internal boundaries between application tiers. Antrea, the CNI plugin integrated with Supervisor in NSX VPC deployments, enforces these NetworkPolicy rules and exposes NetworkPolicyStats, giving administrators measurable visibility into how boundary controls are applied across cluster-internal traffic. At the cluster perimeter, distributed firewall isolation rules on cluster nodes block external networks from reaching VKS cluster pods by default; Supervisor control plane nodes can reach cluster pods, but traffic originating outside the Supervisor control plane is dropped. Connections from worker nodes and pods to the Kubernetes API server use the API server's secure port by default, and SSH tunnels restrict control plane-to-node communications from exposure outside the cluster network. Kubernetes Ingress resources backed by ingress controllers perform TLS termination and route external requests to backend services, establishing a defined and controlled entry point at each cluster's external-facing edge. Network segmentation and firewall rules are applied to secure inter-component communication within Supervisor Service deployments such as Argo CD.

For stateful firewall inspection, microsegmentation, IDS/IPS, and deep packet inspection at network boundaries, organizations can deploy VMware vDefend, which extends VCF's networking foundation with Layer 2 through Layer 7 firewall capabilities and advanced threat prevention. VCF's networking layer provides the segmentation, routing, and monitoring infrastructure on which boundary enforcement policies operate, but the active enforcement of traffic at those boundaries requires either vDefend or integration with external security tools. Organizational processes for defining boundary policies, reviewing traffic logs, managing firewall rule sets, and maintaining network diagrams are also required.

VMware Private AI Services (PAIS) contributes to boundary protection through AI-infrastructure-specific network isolation patterns for both connected and air-gapped deployments. The core boundary enforcement capabilities, including distributed firewall rules, IDS/IPS inspection, and traffic analysis, are provided by VCF and VMware vDefend.

PAIS setup is configured according to environment Internet connectivity, supporting either connected or disconnected air-gapped deployment models. In a disconnected air-gapped environment, files are downloaded from the Internet to a bastion host VM and then transferred to an admin host VM that has no Internet access, from which VI administrators interact with the environment. This pattern removes direct Internet exposure from the AI infrastructure components and constrains the path by which external content enters the trusted enclave.

In air-gapped deployments, PAIS configures components to pull container images from a local internal registry rather than from public sources. The NVIDIA GPU Operator deploys validator, operator, driver, manager, toolkit, and devicePlugin components as separate container images pulled from the local registry. PAIS model endpoints authenticate to private registries through harbor-pull-secret-readonly to control access to container images.

PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, providing an internal boundary between AI workload data stores and other platform consumers. PAIS uses a CA trust bundle for secure communication with external services and databases.

The NSX Edge cluster or Virtual Network Appliance (VNA) cluster provides two-tier north-south routing for the Supervisor instance and the workloads it runs, while the Workload Domain NSX Manager provides VPC networking services to private AI workloads. VPC networking for the VCF Automation organization is configured with a Public IP range, a transit gateway IP range, and a VPC private IP range to delineate external, transit, and internal address space for AI tenants.

Organizations should refer to the VCF and vDefend Coverages for the underlying boundary monitoring and enforcement infrastructure.

VMware vDefend (Meets)

VMware vDefend provides monitoring and control of communications at both external and internal network boundaries within the virtual infrastructure through stateful firewall inspection, microsegmentation, and behavioral traffic analysis.

At the external boundary, vDefend enforces zone boundaries and provides stateful North-South traffic inspection at the network perimeter. Gateway Firewall policies apply to traffic entering and leaving edge gateways, and Gateway Firewall IDS/IPS events can be monitored on nodes, providing inspection-layer visibility at the external boundary.

At internal boundaries, vDefend enforces East-West traffic policies between virtual machines, containers, and workloads regardless of their physical location. Distributed Firewall rules operate at the vNIC level, creating per-workload enforcement points that function as internal boundary controls. Distributed Firewall manages East-West traffic control for both inter-VPC and intra-VPC communication within Organizations, and Distributed Firewall rules protect traffic between objects within a VPC, enforcing boundaries within project-scoped network environments. This microsegmentation approach allows organizations to define fine-grained internal boundaries beyond traditional VLAN-based segmentation. The policy-level Applied-To field defines a clear boundary around a set of VMs, such as an entire application, allowing targeted policies for specific zones, tenants, or applications without interfering with policies defined for other applications, tenants, or zones. Distributed Firewall policies can explicitly block unsecure protocols such as Telnet, FTP, and TFTP across the data center, supporting protocol-level boundary enforcement. Distributed Firewall also supports targeted deny rules scoped to infrastructure groups via the Applied-To field to protect critical services, facilitating phased Zero Trust adoption. Distributed Firewall governance implements least-privilege security by preventing overly permissive rules such as any-to-any-allow configurations. Distributed Firewall policies manage security for Bare Metal servers through traffic-control rules, extending boundary enforcement beyond virtual workloads. For federated environments, Distributed Firewall policies applied globally allow sources or destinations to be any object without span restrictions, supporting multi-site boundary enforcement.

Security Services Platform adds environment-level boundary enforcement through Protection Rules, which define how traffic flows between environment pairs such as production, development, and test. Protection Rule actions can be set to Drop or Reject to block all traffic between specified environment pairs, or Allow for more selective enforcement. Security Services Platform Environment Protection evaluates whether workloads are protected by environment-specific segmentation policies and measures coverage including the percentage of environment pairs in blocked mode. Application Protection in Strict Mode enforces application-level firewall rules on all application workloads except infrastructure, with scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence, a capability within Security Services Platform, defines private IP ranges as the boundary for internal workloads, treating traffic that crosses this boundary as external. The Secure External Communications project identifies workloads with inbound or outbound connections to external IP addresses to mitigate vulnerability to attacks. Security Intelligence recommends identifying all inter-environment flows and securing them with specific policies before enforcing strict block rules, supporting a methodical approach to boundary hardening.

Network Detection and Response (NDR) monitors traffic across boundaries and collects detection events representing security-relevant activity that has occurred in the network. NDR can be integrated with SIEMs to send security event logs about network infrastructure for centralized boundary monitoring. In sensitive or classified environments, NDR can be configured for air-gapped networks, executing all detection, correlation, and response activities entirely within closed networks using local storage and processing without requiring external connectivity. NDR remediations for events detected on the Gateway Firewall are applied on the Distributed Firewall, providing a unified enforcement response across both the internal and external boundary layers.

vDefend does not define which boundaries an organization should establish or set the policies governing boundary placement decisions. Those are organizational architecture and governance responsibilities. The underlying networking infrastructure of VCF, comprising NSX segments, VLANs, and edge gateways, provides the segmentation and routing fabric on which vDefend's boundary enforcement operates.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides boundary protection mechanisms at the application delivery layer for traffic it proxies. Network Security Policies in Avi evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. These policies apply IP-based traffic filtering at the virtual service level; a deny rule stops further policy evaluation, preventing downstream HTTP Security, Request, or Response policies from executing for that traffic. Network security policies are configurable per virtual service and per Virtual IP address, giving administrators auditable and consistent access controls across the deployment.

Avi's Web Application Firewall (WAF) inspects application-layer traffic at the proxy boundary using positive and negative security models. Positive Security rules define what constitutes allowed application behavior and enforce restrictions on traffic that does not conform to that model. WAF Application Rules provide protection against known attack patterns, including rules targeting specific CVEs; rules are automatically updated through the Controller Cloud Services connection, and existing rules continue to protect applications when that connection is unavailable. WAF rule actions support pass and deny options for controlling traffic based on policy matches. Administrators can also enable the Application Rules service through the Avi Cloud Console, which delivers automatically updated CVE-targeted rules directly to Avi Controllers.

For DDoS mitigation, Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework. This includes protection against DNS Reflection Ingress attacks, which involve sending DNS queries with spoofed IP addresses to flood a victim with unsolicited DNS server responses.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) extends boundary controls to Kubernetes ingress traffic. The L4 Rule custom resource definition (CRD) in AKO allows administrators to express custom Security Policies applied to virtual service traffic, including configuration for DDoS attack detection and mitigation. The `'insecureEdgeTerminationPolicy'` setting in AKO controls handling of insecure traffic, with a redirect option that enforces secure traffic routing through HTTP Request policies applied per FQDN.

Avi Service Engines implement traffic isolation between the data plane and the management and control plane using a dedicated management vNIC bound to the default Linux network namespace, with health monitor traffic further isolated through Linux network namespace features in the kernel. Service Engine IP addresses egressing the Data Plane vNIC are routed through the external network and subjected to routing isolation and ACL/firewalling controls present in that external network. A dedicated management network is required for communication between Avi Controllers and Service Engines. In isolated network deployments, each Avi Controller supports a second management IP address or DNS-resolvable FQDN for Service Engines connecting from an isolated segment, configured via the `'isolated-network-management-address'` setting.

In VCF deployments using the Avi-for-VCF integration, the Management Network hosts the Avi Controller and provides connectivity to vCenter, ESX hosts, and Supervisor control plane nodes, maintaining a defined boundary between management and workload traffic.

Incoming HTTP(S) traffic can be replicated to logging and sideband servers at the protocol level via the Virtual Service Sideband Profile, enabling deep traffic inspection by external appliances such as web application firewalls and supporting compliance and auditing requirements.

Avi also supports a Firewall Sandwich Topology, where virtual services and firewall pool members are chained so that application traffic traverses configured firewall members on its path from the Internet to internal servers. In this topology, a sample of traffic is inspected by the firewall while remaining traffic considered trusted is directly routed to the internal network.

Boundary protection for segments and layers outside Avi's application delivery scope, including network-level perimeter controls, east-west enforcement between application tiers, and internal boundary protection across the broader VCF environment, requires the VCF networking infrastructure and VMware vDefend, which is a separate product.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.7

> Deploy and Maintain Email Server Anti-Malware Protections

SCF Controls: END-08, IRO-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.0

> Malware Defenses: Prevent or control the installation, spread, and execution of malicious applications, code, or scripts on enterprise assets.

SCF Controls: END-01, END-02, END-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.1

> Deploy and Maintain Anti-Malware Software

SCF Controls: END-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.2

> Configure Automatic Anti-Malware Signature Updates

SCF Controls: END-04.1

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to automatic antimalware signature updates through two distinct mechanisms: IDS/IPS signature management and the Malware Prevention Service. Both operate with automated update capabilities that reduce the operational burden of keeping threat detection current.

The vDefend IDS/IPS component supports automatic signature bundle retrieval from the VMware vDefend Threat Intelligence Service (vTIS), the cloud-hosted signature service. Administrators can configure the Global Manager to manage signature updates across Local Manager sites using either an Auto Update mode, which pushes new signature bundles automatically to all mapped Local Manager sites, or a manual update mode for environments that require change-control oversight before deployment. The download interval for automatic updates is configurable. When the Auto Update toggle is turned off, administrators can manually download the IDS signature bundle (.zip) file and upload it to the system. vDefend IDS/IPS also supports custom signature bundles that administrators can manage through the NSX Manager interface under Security > IDS/IPS & Malware Prevention. Before uploading a new custom bundle, administrators should export the existing bundle, as uploading a new custom bundle replaces all previously uploaded custom signatures. The interface displays counts of new, deleted, and existing signatures when re-uploading bundles. Administrators can also bulk-edit system signatures to update actions or toggle signature state across the signature set.

The Malware Prevention Service provides a separate signature-based detection and prevention capability. The service deploys a service virtual machine (SVM) on each host in a vSphere cluster and uses Guest Introspection thin agents installed on guest virtual machines to perform file inspection at the hypervisor layer. Malware prevention signatures are retrieved automatically through internet connectivity to the NSX management plane; unlike IDS/IPS signatures, malware prevention signatures cannot be uploaded manually and require internet access from the NSX environment. When signatures identify a file as malicious, Malware Prevention can take remediation actions including denying access to the file or deleting it. Malware Prevention signature bundles also support file magic matching to identify files by their binary content signatures rather than relying on file extensions alone.

In vDefend, the Malware Prevention Service adds support for fileless malware detection on Windows endpoints. Rather than relying solely on file hash-based signature matching, the service monitors behavioral Indicators of Compromise (IoC) to identify process-based threats. Analysis reports generated by the service include signature activity detail that identifies malicious subjects, supporting post-incident review.

vDefend does not replace a general-purpose endpoint antimalware product. Its signature update capabilities are specific to network-level IDS/IPS and the Malware Prevention Service for file-based and fileless threat detection at the hypervisor layer. Organizations deploying guest-level antimalware agents remain responsible for those agents' signature update mechanisms independently of vDefend.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.3

> Disable Autorun and Autoplay for Removable Media

SCF Controls: CFG-02, END-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 10.4

> Configure Automatic Anti-Malware Scanning of Removable Media

SCF Controls: CFG-02, END-02, END-04, END-04.7

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 10.5

> Enable Anti-Exploitation Features

SCF Controls: CFG-02, END-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 10.6

> Centrally Manage Anti-Malware Software

SCF Controls: END-04.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides infrastructure-level capabilities that support the centralized management of antimalware technologies, though it does not itself function as a general-purpose endpoint antimalware solution. VCF's contribution spans host integrity management, guest introspection frameworks for third-party security integration, distributed malware prevention through VMware vDefend, agent deployment infrastructure, and operational monitoring.

VMware vCenter provides centralized management of the virtualization environment, including host attestation monitoring and Secure Boot enforcement. vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image, enabling desired-state configuration with drift detection. Upon remediation, the defined image is installed on all hosts in the cluster, and the manager can compare the current image on a host against a desired image to define the compatibility status. VCF Operations displays drift status for vSphere clusters that have vSphere Configuration Profiles enabled, with a collection cycle that updates drift data every eight hours. These capabilities help maintain a known-good baseline across all hosts, supporting antimalware efforts by detecting unauthorized changes to host software.

NSX includes a Guest Introspection framework that enables third-party endpoint security products to operate within the virtualized environment. The NSX Guest Introspection Agent is installed in each guest virtual machine to provide security context, including user identity information. Security administrators are responsible for ensuring the agent is installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This framework allows third-party antimalware products (such as Symantec Endpoint Protection, which provides anti-malware, intrusion prevention, and firewall capabilities) to integrate with the NSX platform for centralized deployment and policy enforcement.

vSphere also supports enabling Virtualization-Based Security (VBS) on Windows guest virtual machines with VMware ESX 6.7 and later compatibility, allowing administrators to configure features such as Device Guard and Credential Guard from VM hardware settings. Device Guard provides a set of hardware and software features designed to help prevent malware from running on Windows systems, and these protections are available to Windows workloads through centrally managed VM configurations.

VMware vDefend extends VCF's networking foundation with distributed malware detection and prevention, IDS/IPS, and network detection and response capabilities. The NSX Application Platform hosts the Malware Prevention for vDefend feature, and Malware Prevention can be deployed and managed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine is deployed on each host. vDefend is managed centrally through NSX Manager, which provides a single management interface for security policy configuration and enforcement across multiple locations. NSX Manager supports activation of distributed security on selected clusters and provides APIs for malware prevention and security intelligence integration. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned. Malware Prevention logging is available at defined log file paths on the NSX Application Platform worker nodes for operational visibility.

ESX Agent Manager provides infrastructure for deploying and configuring agent virtual machines on ESX hosts. Solutions integrated with ESX Agent Manager can pass configuration properties (such as IP addresses and credentials) so that agents connect back to their management solution. When a user adds a host to a cluster of hosts that require an ESX agent, ESX Agent Manager deploys the required agents on the new host automatically. This mechanism supports centralized deployment of third-party security agents alongside the antimalware capabilities provided by vDefend.

VCF Operations contributes additional monitoring capability by discovering and monitoring application services on endpoint virtual machines where agents are installed. Guest operation privileges in VCF Operations are required to install agents on endpoint virtual machines, and the platform displays guest OS services authentication status for visibility into agent health.

General-purpose endpoint antimalware management, including agent deployment to guest operating systems, signature distribution, scan scheduling, and quarantine management, requires separate tooling outside of VCF. Organizations must select, deploy, and centrally manage an antimalware product that integrates with VCF's Guest Introspection framework and ESX Agent Manager infrastructure.

VMware vDefend (Contributes)

VMware vDefend contributes to centralized management of antimalware technologies through the Security Services Platform and NSX Manager, which together provide a single management interface for deploying, configuring, and maintaining network-based malware prevention across the data center.

The Distributed Malware Prevention service is deployed and managed centrally through NSX Manager. Administrators activate malware prevention on selected ESX host clusters, and the platform handles deployment of a service virtual machine (SVM) on each host in the cluster. The Guest Introspection framework extends this architecture by deploying lightweight thin agents on protected guest VMs; these agents intercept file activity within the guest and route it to the host-resident SVM for inspection and analysis, enabling centrally managed malware detection without requiring independent endpoint agent management on each guest. Guest Introspection supports thin agents on both Windows and Linux virtual machines, with the Host Agent (MUX) component running on ESX hosts to coordinate introspection functionality. Security policies and malware prevention rules are authored in NSX Manager and published from the management plane to host clusters, providing consistent policy enforcement without per-host configuration. The Malware Prevention Service can also be deployed on Gateway Firewalls for north-south traffic inspection; both deployment models are configured through the Security > IDS/IPS & Malware Prevention > Settings interface in NSX Manager.

The Security Services Platform coordinates malware analysis across the environment. Deployment status can be monitored per cluster and by individual transport nodes within the cluster. When a file is identified as suspicious or malicious, the platform can enforce remediation actions on the endpoint, including denying access to the file or deleting it. The Malware Prevention Service also includes fileless malware detection to identify threats that operate within system memory and use existing binaries and in-memory operations. A dashboard and logs are available for Security Operations teams to extract artifacts associated with in-memory malware execution, providing visibility into the antimalware policy outcomes across the environment.

For IDS/IPS, vDefend supports centralized management through a Global Manager that manages custom signatures across multiple Local Managers, enabling consistent signature distribution in multi-site deployments.

vDefend's centralized management scope is limited to network-based malware detection and prevention for virtual workloads. General-purpose endpoint antimalware management, including agent deployment, signature distribution for host-based antivirus, scan scheduling, and quarantine management, requires separate endpoint protection tooling outside of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.7

> Use Behavior-Based Anti-Malware Software

SCF Controls: END-04.4

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend provides several heuristic and nonsignature-based detection capabilities spanning malware analysis, behavioral detection, and network traffic anomaly identification.

The Malware Prevention Service performs both static analysis heuristics and dynamic analysis of files and scripts to identify malware, including threats for which no existing signatures exist. Local file analysis combines static analysis heuristics with antivirus signatures and file hash detection, providing multiple inspection layers beyond signature-only matching. The service uses Guest Introspection thin agents deployed on guest VMs, with a service virtual machine (SVM) installed on each cluster host, to intercept file operations and generate file events in distributed east-west traffic. When files are identified as malicious or suspicious, the service provides remediation interfaces including denying access to suspicious files or deleting files confirmed as malicious.

Malware Prevention also includes Fileless Malware Detection, which identifies script-based attacks that operate within system memory without leaving executable artifacts on disk. Rather than relying on file hashes, this capability monitors behavioral Indicators of Compromise (IoC) to detect malicious activity on Windows endpoints. The service intercepts in-memory scripts through Microsoft's Antimalware Scan Interface (AMSI), capturing execution traces of scripts running directly within process memory such as PowerShell, VBScript, and JScript, then submits them to the malware analysis pipeline for static and dynamic analysis. Administrators enable this capability by selecting the Script file category when configuring Malware Prevention rules. The service also extracts artifacts and in-memory script buffers, allowing security teams to define incidents of compromise and create detection rules for similar future threats.

Security Intelligence includes configurable suspicious traffic detectors designed to identify anomalous traffic patterns across the network. These detectors map to MITRE ATT&CK categories and techniques and operate through behavioral analysis of network traffic flows rather than signature matching. Security Intelligence categorizes detected events by detector technique or tactic in the Suspicious Traffic Summary view. Detectors report execution status including NOT_STARTED, SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE, indicating that the system builds behavioral baselines against which it measures anomalous activity.

Network Detection and Response (NDR) correlates individual detection events into campaigns, aggregating new detection data with existing events to build a broader picture of attacker activity. Detection events that do not correlate with any other detection are not included in a campaign. NDR provides filtering of the unified event list by MITRE ATT&CK tactic using histogram visualization, and supports filtering by Signature Type to include or exclude results from built-in or custom intrusion detection signatures.

The combination of static analysis heuristics and dynamic malware analysis in the Malware Prevention Service, behavioral IoC monitoring for fileless threats, behavioral traffic analysis via Security Intelligence, and campaign correlation in NDR provides a substantial set of heuristic and nonsignature-based detection capabilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides heuristic and nonsignature-based detection mechanisms at the application delivery layer. The Bot Management feature applies a multi-stage detection pipeline to incoming requests: a heuristic scan of User-Agent strings for attack indicators such as SQL injection patterns, a lookup against the User-Agent Database (populated by Avi Load Balancer Pulse), and pattern matching against known browser user agents. The Bot Decision Component can function as a consolidator, user-agent detector, IP-reputation detector, or IP-location detector, and requests are classified as Bot, Human, or Undetermined based on the combined result. Requests matching bot indicators are classified as `dangerous_bot`, and HTTP security policy rules can be configured to act on that classification. The `System-BotDetectionPolicy` can be bound to virtual services through the Controller UI under Administration > External Services > CloudServices. Kubernetes-hosted services

deployed through the Avi Kubernetes Operator can reference a BotDetectionPolicy via the botPolicyRef parameter in L7 CRD rules, extending bot detection coverage to K8s ingress traffic.

Avi's Web Application Firewall (WAF) extends behavioral detection through rule-based analysis of request structure. The WAF applies ModSecurity-compatible SecRule syntax with operators such as @rx, @contains, and @startswith to match against variable collections representing parsed parts of incoming requests. Positive Security Groups allow configuring behavioral allowlisting criteria against variable collections. Custom rules can be defined to address specific application patterns while managing false positives from the Core Rule Set engine. The WAF supports both Detection mode, where rules are evaluated without blocking to tune for false positives, and Enforcement mode; individual rules can be placed in either mode independently through partial detection configuration, enabling incremental rollout of new behavioral rules before committing to blocking.

Avi's scan detection system also dynamically tunes client group membership in response to changes in traffic patterns and website behavior, adjusting automatically to reduce false positives when mass failures occur.

Organizations should be aware that Avi's heuristic and behavioral detection applies to application-layer traffic passing through Avi virtual services. The Avi documentation recommends that a dedicated virus and malware scanning tool be deployed on application upload directories to detect malicious uploads containing malware, ransomware, viruses, and file-based exploits, because the WAF does not perform file-content scanning. Antimalware detection at the host, hypervisor, and network layers is handled by the underlying VCF platform and by endpoint security tooling deployed separately.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.0

> Data Recovery: Establish and maintain data recovery practices sufficient to restore in-scope enterprise assets to a pre-incident and trusted state.

SCF Controls: BCD-01, DCH-01, END-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern

which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Control 11.1

> Establish and Maintain a Data Recovery Process

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting

both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.2

> Perform Automated Backups

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds.

VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a

separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages,

including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30

minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage

target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 11.3

> Protect Recovery Data

SCF Controls: BCD-11.1, BCD-11.4, BCD-12, BCD-13, DCH-01

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression,

and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The etcdctl snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During kubeadm upgrades, backup folders for etcd state and cluster manifests are written automatically to /etc/kubernetes/tmp with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides VolumeSnapshotContent and VolumeSnapshot resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a PersistentVolumeClaim using a VolumeSnapshotClass that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new PersistentVolumeClaim with the target VolumeSnapshot as its dataSource, referenced via the snapshot.storage.k8s.io API group. Kubernetes PersistentVolumes have a configurable reclaim policy; setting the policy to Retain preserves volume data in a Released state after the associated PersistentVolumeClaim is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 11.4

> Establish and Maintain an Isolated Instance of Recovery Data

SCF Controls: BCD-14

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides file-based and image-based backup capabilities for its core management components, with support for directing backup data to storage locations outside the production environment. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. VCF Operations configures NSX Manager backup during the bring-up process, and file-based backup jobs for VCF Operations and vCenter are configured separately. Backup destinations include FTP servers, SSH servers, and local file servers, allowing organizations to store backup data at locations separated from the production infrastructure. vCenter file-based backup supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, and SMB as destination protocols, and backup data is not stored on the vCenter appliance itself. Optional encryption of backup files with a password can be configured to protect data at the remote destination; that password is required for any subsequent restore operation, and organizations using vSphere Native Key Provider should note that backup files contain the Key Derivation Key and must be stored securely.

For management component recovery, file-based backups of VCF Operations, vCenter, and VCF Identity Broker are restored onto newly deployed appliances, providing a clean recovery path that is inherently separated from the failed production environment. When restoring a vCenter instance from file-based backup, the administrator must have a valid backup file that matches the same version as the target vCenter appliance. After a successful vCenter restore, administrators verify that the VCF Operations inventory is consistent with the recovered VMs by using the Supportability and Serviceability tool (SoS) and the patch/upgrade precheck function. The vCenterManagement API also supports restoring a vCenter instance from a backup copy programmatically.

VCF Operations supports regular backups of both custom and out-of-the-box content, with backup storage options that include local storage, SSH servers, and FTP servers. It is recommended to take the VCF Operations cluster offline during backup. VCF Operations for Networks supports backup and restore of deployment data to remote storage locations, enabling recovery when the existing setup is unrecoverable.

VCF includes Application Disaster Recovery capabilities that enable failover to a secondary site to maintain operations during major disruptions. Data replication to a secondary site provides recovery options in the event of catastrophic failure at the primary location. Recovery plans can be executed using Site Recovery Manager to migrate virtual machines from a primary site to a recovery site through either planned migration or disaster recovery workflows. Running a protection plan on SRM moves virtual machines to the recovery site and removes them from the primary site. When configuring recovery sites, administrators can set up network configurations that mirror or differ from the protected site, and recovery plans can be tailored to accommodate network changes at the recovery location. These capabilities allow organizations to establish a secondary recovery environment that is physically and logically separated from production.

vSAN stretched clusters extend site-level resilience by maintaining synchronous data replication between two geographically separated locations. Data is synchronously replicated bidirectionally between the preferred site and the secondary site. If the preferred site fails or loses network connection to the secondary site and witness host, the secondary site continues storage operations as long as it remains connected to the witness host. The secondary site can also be designated as the preferred site through configuration changes, providing flexibility in recovery operations.

VCF Operations HCX supports inter- and intra-VCF mobility for workloads, enabling the movement of workloads between separate VCF environments. This capability can be used to relocate workloads to a separate recovery environment. VKS cluster management supports directing backup data to S3-compatible storage locations that organizations create and maintain in their own cloud provider accounts. This self-provisioned backup storage model allows backup data to reside at locations separate from the production VCF environment.

The vSphere Supervisor control plane can also be backed up and restored using vCenter file-based backup from the Workload Management UI, extending backup coverage to container orchestration infrastructure.

While VCF provides the backup, restore, disaster recovery, and multi-site mechanisms needed to support an isolated recovery environment, the platform does not itself provision or enforce the isolation of that environment. The organization is responsible for establishing the non-production recovery environment, defining isolation boundaries, selecting off-site or cloud storage targets, and implementing procedures for periodic recovery testing. VCF's backup and DR features provide the technical foundation, but the architectural decisions around environment isolation and operational governance fall outside the product's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) is architected around isolated recovery environments, with protected and recovery sites operating as separate infrastructure that can be located in geographically distinct facilities.

The recovery site in PNR should be in a facility unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site. The recovery site must have its own hardware, network, and storage resources capable of supporting the same virtual machines and workloads as the protected site. This fundamental separation between protected and recovery sites provides the isolated, off-site recovery environment the control requires.

PNR supports cloud-based recovery sites in addition to on-premises facilities. Recovery sites can be deployed on Google Cloud VMware Engine private clouds, providing off-site and cloud-based recovery options for on-premises protected sites. PNR also supports offline mode operation using an offline license key, enabling the product to function without cloud connectivity for environments that require air-gapped recovery operations.

Cyber Recovery within PNR provides a purpose-built clean room environment designed for ransomware recovery scenarios. The clean room uses an isolation model in which virtual machines are partitioned from each other and from outside communication. Configurable network isolation rules determine the level of network access within the clean room, with options including Isolated (fully isolated with no network access) and Quarantined + Analysis (access only to integrated analysis services). The clean room is used for powering on virtual machine snapshots from before a ransomware event, analyzing them for compromise, and staging them for production return only after the Recover operation confirms they are ready to restore. PNR supports multiple topology options for cyber recovery, including sharing a vault and clean room with an existing disaster recovery site or deploying a fully isolated and dedicated cyber recovery site.

For recovery plan testing, PNR can automatically create an isolated network on the recovery site. The isolated test network is the default configuration and allows recovery plan tests to proceed without adding traffic to the production network on the recovery site. Recovery plans can recover virtual machines across multiple recovery site hosts in a quarantined test network, with no lasting effects on either the protected or recovery site.

In shared recovery site configurations, PNR supports creating isolated resources and mapping protected site resources to dedicated resources on the shared recovery site, maintaining customer separation when multiple organizations use the same recovery infrastructure.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.5

> Test Data Recovery

SCF Controls: BCD-11.1, BCD-11.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides backup and restore capabilities for its management components and workload layers, along with monitoring features that support organizations in verifying backup reliability. Routine backup testing itself requires organizational processes beyond what the platform automates.

VCF supports file-based and image-based backup methods for its core management components, including VMware vCenter, VCF Operations, and NSX Manager. VCF Operations automatically configures NSX Manager backup during the initial bring-up process, while file-based backup jobs for VCF Operations and vCenter must be configured separately. vCenter file-based daily backups are configured through the vCenter Management Interface of each vCenter instance. File-based backups can be stored on FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB servers, and the backup can optionally include Stats, Events, and Tasks data from the vCenter database to preserve historical audit records. Backup files support optional encryption with a password that must be provided again during the restore procedure. The platform recommends creating coordinated backup jobs that capture the state of related management components at a common point in time, so that restores can proceed from a consistent baseline. Scheduled backups should be implemented to prepare for critical failure scenarios, component upgrades, or certificate updates. vSphere Supervisor control plane backup and restore is activated through the vCenter backup feature in the vCenter Management Interface, which also protects VMware Kubernetes Service (VKS) cluster node VMs; this backup is accessible from the Workload Management UI. VKS cluster backup and restore operations for workloads and namespaces are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. This interface supports backup and restore of the entire cluster, selected namespaces from a backup, or specific resources identified by a label, and provides a "Restore from another cluster" function that allows a backup from a source cluster to be applied to a different target cluster. For Kubernetes workloads running on VKS, volume backup status and failures can be confirmed using the Velero CLI with the details flag.

Workload data on VKS clusters is protected through Velero integration. Velero supports two backup strategies: vSphere Plugin Snapshot, which captures persistent volumes at the block level and writes data directly to object storage without requiring a backup repository, and CSI Snapshot combined with File System Backup, which captures data at the file-system level with support for deduplication, compression, and encryption when those repository features are required. The CSI Snapshot and File System Backup methods also support incremental backup, where files that have not changed since the last backup are not re-uploaded. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. Third-party backup software can integrate with the CSI snapshot API to perform volume backup and restore operations against VKS clusters. Velero supports scheduled backup operations, enabling organizations to automate regular backup cadences as a foundation for routine testing.

Velero provides inspection capabilities that support backup verification. The `velero backup describe` command with the details flag reports completed and failed Restic volume backup entries along with source file references and pod identifiers, allowing administrators to diagnose backup failures before depending on a given backup for recovery. VKS cluster backup logs record backup failures with detailed error messages that include the process ID, user ID, group ID, and timestamp of the lock holder when a backup cannot proceed due to an existing exclusive lock. Scheduled backups relying on a deleted data protection account credential will fail on their next execution, and this failure creates a detectable gap in backup execution history visible in the backup monitoring interfaces.

For Kubernetes cluster state, etcd serves as the backing store for all cluster configuration and API objects. etcd supports two backup methods: built-in snapshot via the `etcdctl snapshot save` command (specifying the endpoint, CA certificate, client certificate, and client key) and volume snapshots. Snapshots can be restored from a previous backup file or from a remaining data directory, with cross-patch-version restore supported for the same major.minor etcd version. During `kubeadm` upgrades, VKS automatically writes time-stamped backup folders for etcd data and control plane manifests to `/etc/kubernetes/tmp`,

providing a rollback point that can be exercised as part of upgrade validation. Kubernetes guidance recommends that clusters verify backup restorability at regular intervals.

The platform includes built-in integrity verification as part of the restore process. Before restoring a vCenter instance from a file-based backup, the administrator must verify that the vCenter version retrieved from VCF Operations matches the version associated with the backup file. The backup must be of the same version as the vCenter appliance on which the restore will be performed. These version-matching checks help confirm that the backup data is consistent and compatible before a restore operation proceeds. Management component restore operations for VCF Operations, vCenter, and NSX can be tested by performing actual restores to validate backup data integrity.

VCf Operations provides monitoring capabilities that track backup success and failure across the environment. Backup failures are counted over time and grouped by error code, giving administrators visibility into recurring issues. Successful and failed inventory backups are also monitored. NSX tracks the total number of times backup configuration was updated, as well as backup successes and failures for both cluster backups and inventory backups. Alert notifications can be configured for backup failures under Platform Health Alerts, and administrators can track backup and restore process failures on the Infrastructure page under Settings, Infrastructure and Support, Overall Health section. NSX generates a BackupFailure alert when a scheduled backup operation fails. After resolving errors in VCF components, administrators can take on-demand manual backups to verify that the backup process is functioning correctly.

The VCF documentation recommends performing an initial on-demand backup after configuring VCF Operations to verify that backups complete successfully. This practice of performing a test backup after configuration is a form of validation, but it is a one-time recommendation rather than an automated recurring test.

For workload-level data protection, vSAN Data Protection allows snapshots to be managed through protection groups with configurable retention policies (duration and time units) and scheduling intervals. Native snapshots in vSAN Express Storage Architecture (ESA) use a B-tree structure instead of a chain structure, allowing more frequent backups and faster recovery than traditional vSphere snapshots. The native Snapshot Service is supported by vSAN ESA but not by vSAN Original Storage Architecture (OSA). Snapshot restore operations can be tested to validate data integrity.

VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions. VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VM Service VMs on a Supervisor. These partner solutions typically include their own backup verification and integrity checking capabilities.

The vCenter API provides the RecoveryBackupJobBackupRequest data structure for programmatic backup operations, specifying backup location, protocol, and authorization details. The `com.vmware.appliance.recovery.backup.validate` appliance API command validates backup job parameters without starting the job, allowing administrators to confirm that backup configuration is correct before execution. This API access enables organizations to build automated backup testing workflows that trigger backups and verify completion status programmatically.

VCf directly provides backup scheduling, backup monitoring with failure alerting, on-demand backup testing, version-matching integrity checks, restore capabilities, workload-level snapshot management, and VKS cluster backup and restore through the VCF Automation Tenant Portal. Establishing a routine cadence for testing backup reliability and validating restore procedures requires organizational processes, runbooks, and scheduling that go beyond the platform's built-in automation.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform (SSP) provides backup and restore capabilities for the security platform itself, offering several mechanisms that support routine verification of the backup process.

SSP includes a configurable backup schedule that supports recurring backups, which can be toggled on or off. Backup frequency can be set as weekly on a selected day and time, or as an interval-based schedule ranging from a minimum of 6 hours to a maximum of 720 hours. The SSP Backup History section displays backup operation status, showing Completed when a backup operation is successful, giving operators direct visibility into whether scheduled backups are completing. When a scheduled backup fails, SSP generates a Scheduled Backup Error alarm to notify operators of the failure.

Backup and restore operations generate pod logs that record detailed error messages, including database query failures and volume attachment errors, supporting diagnosis of backup failures. If an operation becomes stuck in a FAILED or QUEUED state, operators can inspect cluster-api pods and backup pod status to troubleshoot the condition.

The SSP Installer data backup produces duplicate platform configuration data that can be restored in the event of hardware malfunctions, software malfunctions, data corruption, malware incidents, or unintentional data deletion. Restore operations require adequate storage on the target server, the same NSX instance that was onboarded at the time of backup, and the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored SSP environments is required to avoid service disruptions, including disruptions to NDR Sensors.

vDefend's contribution is to the operational health and backup completion visibility of the security platform itself. The control asks whether the organization routinely tests backups for reliability and integrity; vDefend provides the scheduling, status tracking, and alerting mechanisms that support such testing, but automated restoration testing and integrity validation of backup content require supplemental organizational procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing capabilities that exercise the recovery process and verify the integrity and availability of replicated data at the recovery site. The cadence and scope of routine testing remain an organizational practice.

Recovery plan tests run virtual machines on a test network and against a temporary snapshot of replicated data at the recovery site, isolating test execution from production data and from ongoing operations at either site. Tests can be run as often as needed and cancelled at any time without impacting production systems. Testing exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. PNR documentation recommends testing recovery plans before use for planned migration or disaster recovery to validate functionality before production execution, as failure to test may result in data loss during an actual disaster recovery. After a reprotect operation completes, running a test recovery verifies that errors are resolved before running a planned migration or disaster recovery. After testing completes, the cleanup capability removes test artifacts so they do not persist in the recovery environment.

Recovery plan testing can be configured to replicate recent changes to the recovery site so that the test exercises the latest copy of protected virtual machines, though this may increase synchronization time. PNR can generate and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup for audit trail purposes, providing a record of testing activity that administrators can reference.

PNR monitors protection group and recovery plan health, detecting critical issues including loss of connectivity to protected or destination sites, snapshot replication failure, and recovery plan malfunction. The Protection and Recovery management pack integrates with VCF Operations to enable data collection from PNR Cloud instances and provide centralized dashboarding of recovery telemetry.

Traditional backup testing capabilities, including platform component backup validation and VADP-based third-party backup verification, are provided by the underlying VCF platform (see VCF Coverage). Establishing a routine test schedule, defining acceptance criteria, and recording test outcomes for audit are organizational responsibilities that sit outside PNR's automated scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides automated backup capabilities, backup health monitoring, integrity-verification mechanisms, and on-demand restore tooling that support an organization's routine backup verification practices. A formal backup testing program itself requires organizational process.

DSM supports automated backups for databases with configurable backup schedules and retention periods. PostgreSQL databases use configurable settings for backup location, retention period, and backup schedule, controlled by the Enable Automated Backups setting during database creation or through database settings afterward. DSM data service policies can be configured to require automated backups, allow them as optional, or disallow them, giving administrators a way to enforce backup coverage on databases under a policy. High Availability clusters require automated backups to be enabled before

databases can be provisioned. Backup chain integrity depends on retaining the last full backup and all subsequent incrementals. If any incremental in the chain is deleted, DSM cannot restore the full data, which is a consideration when designing retention policy and backup chain management procedures.

Backup health is actively monitored. DSM validates the connection and operational status of the backup storage repository, verifies the bucket name, checks credential expiration, confirms certificate expiration dates, and validates that there is sufficient available repository space. Scheduled backup failure alerts notify administrators when a scheduled backup operation fails, and the monitoring framework supports metrics-based and status-condition alerts that identify critical failure conditions including database engine degradation, non-operational status, and automated or transaction log backup failure. Webhook payloads triggered by data service operation failures can be validated using the TEST function before deployment so that failure notifications reach the intended target. A trusted root certificate must be configured for each backup location used by a data service policy that requires or allows automated backups.

For data integrity verification, DSM PostgreSQL distributions include the amcheck extension at versions 1.2, 1.3, and 1.4 across the supported PostgreSQL builds, which provides functions for verifying relation integrity directly inside the database. Administrators can use amcheck to spot-check that a restored database's internal structures are sound after a recovery exercise, giving the testing program a database-engine-level data integrity check.

Administrators have several mechanisms to verify recoverability. DSM supports point-in-time recovery (PITR) that restores a backup at a specific point in time to a new database instance, with restoration possible to any point within the configured backup retention period. The restore creates a new database VM with a user-specified name and datastore location, so the test restore does not affect the source database. Deleted database backups remain available and can be restored to a newly created database VM at the most recent timestamp or to a specific point in time, supporting test restores of historic state. On-demand backups can be triggered manually for primary PostgreSQL databases to capture a known-good state before a planned change or verification exercise. DSM Provider VM recovery from backup is supported through the restore-provider command with the pgbackrest.conf path, which restores the Provider VM to the latest timestamp after a terminal failure during non-upgrade operations. The Provider VM requires a Provider Backup Repo to be configured before recovery is possible. Tenants can also restore a database to a specified restore point through the VCF Automation UI when DSM is consumed through VCF Automation.

While DSM provides the backup infrastructure, monitoring, validation, integrity-verification, and restore capabilities that form the technical foundation of a backup testing program, the organization must conduct scheduled restore tests against non-production environments to validate actual data recoverability, document the results, and maintain a formal testing cadence. DSM does not automate test restores to a separate environment, so these organizational procedures are required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides backup and restore capabilities for the Avi Controller configuration, including automated scheduling, multiple storage destinations, pre-restore integrity validation, and post-restore verification.

The Controller backup scheduler automates periodic backup operations. Configuration data can be written to local storage on the Controller with a configurable retention count, or to a remote backup destination. Configuring a remote backup destination is recommended to protect against scenarios where the Controller cluster fails in a non-recoverable fashion. In VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path; by default, Avi Load Balancer backups are stored on the same server where VCF Operations appliance backups are stored. For single-node Controller deployments and when recovering from a complete VM or disk failure, enabling periodic external configuration backups is mandatory. Administrators can use the `show backups` CLI command to list available backup files, and the `export` command to capture a full system configuration or individual virtual service configurations. A backup must be verified as taken prior to initiating any upgrade operation. After upgrades, backups should be stored with clear labeling that includes version and date.

Restore operations can be initiated through the CLI using the `import` command with the `keep_uuid` option to restore to an empty Controller, or through the REST API by attaching a configuration backup file and providing the decryption passphrase.

Before any restore proceeds, the Avi Controller performs pre-restore validation checks that verify Controller Cluster readiness, upgrade operation status, ServiceEngineGroup upgrade status, backup configuration version compatibility, FIPS mode alignment between the backup and the target environment, the presence of required file objects, and configuration validity. These checks are logged with timestamps, including FIPS configuration status and image validation state. In VCF-integrated environments, the restored Controller instance must remain synchronized with the VCF Operations lifecycle.

After a restore completes, the Controller performs post-restore validation tasks that verify the successful restoration of configuration objects, including counts of restored Clouds and ServiceEngineGroups. This confirms that backup data has been correctly applied before the system returns to service.

Organizations should establish a defined process to periodically execute test restores, verify that recovered configurations are complete, and record results as evidence of backup program effectiveness.

Control 12.0

> Network Infrastructure Management: Establish, implement, and actively manage (track, report, correct) network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

SCF Controls: NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 12.1

> Ensure Network Infrastructure is Up-to-Date

SCF Controls: NET-01, VPM-04, VPM-04.1, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network

Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 12.2

> Establish and Maintain a Secure Network Architecture

SCF Controls: NET-01, NET-02, SEA-01, SEA-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network

Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 12.3

> Securely Manage Network Infrastructure

SCF Controls: CRY-06, MNT-05.3, NET-01

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network

Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) requires TLS for all non-console administrative access, with no unencrypted remote management paths available by default. The minimum TLS protocol version is configurable through the envoy-proxy-config.json file, and any change to the minimum protocol version must be applied consistently across all applicable locations in the system. This allows organizations to align PNR's management channel encryption with their security policy requirements.

The PNR Appliance Management Interface and web-based management consoles operate over HTTPS. Admin credentials are required to access reconfiguration functions and service management operations, including Global Console disconnect and appliance unregistration. SSH access to the PNR appliance can be activated or deactivated for administrative management; when SSH is deactivated, remote administrative access is limited to the encrypted HTTPS-based management interface.

The Clean Room Orchestrator component of PNR, used for ransomware recovery workflows in the isolated recovery environment, uses TLS for secure communication between management components.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a `NetworkOverlapFound` alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the `network.tlsProtocols` custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the `Modify Network Security ACL` endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Control 12.4

> Establish and Maintain Architecture Diagram(s)

SCF Controls: AST-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of

members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at ports.broadcom.com, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 12.5

> Centralize Network Authentication, Authorization, and Auditing (AAA)

SCF Controls: IAC-01.2, IAC-02, IAC-03, IAC-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in Authenticate, Authorize, and Audit (AAA) capabilities across its component stack, giving organizations a strong technical foundation for governing AAA within the platform.

For authentication, VCF SSO is the centralized identity broker. VMware vCenter can be federated with an external enterprise identity provider, which handles authentication in a federated model and enables flexible options such as multifactor authentication, automatic user registration, and termination of users across services. Named external identity providers supported for vCenter federation include Okta, with provider-specific configuration procedures available for each. NSX Manager supports local authentication, LDAP authentication, and OIDC authentication with configurable identity provider selection. VCF Automation allows organizations to define a shared identity provider and authenticate users through configurable authentication mechanisms, including redirections to external identity providers. The Identity API in VCF Automation provides programmatic management of authentication and authorization providers. The vCenter Client Credentials grant type also allows application-to-identity-provider authentication without a human user present, supporting machine-to-machine authentication scenarios. VMware ESX and vCenter validate user credentials against configured identity stores.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support two authentication methods: VCF SSO and OIDC-compliant external identity providers. Administrators register an external provider by configuring the identity provider issuer URL, client credentials, and certificate authority through the Supervisor, enabling providers such as Okta. DevOps users then authenticate to the cluster using their identity provider credentials, keeping cluster authentication federated to a centrally managed identity store rather than relying on cluster-local accounts. Kubernetes hardening guidance recommends external authentication sources such as OIDC for production clusters with multiple users accessing the Kubernetes API directly. OIDC authentication is distributed to developer workstations through kubeconfig files, and custom ClusterClass configurations can be used to authenticate developers using existing corporate identity systems. Argo CD, when deployed as a Supervisor Service, supports PKCE-enabled OIDC authentication through the `enablePKCEAuthentication` field in the `spec.oidc` configuration, extending federated identity management to continuous delivery workflows. Infrastructure credentials, including service account tokens, can be configured to use short-lived certificates with automated rotation.

For authorization, VCF implements a permissions-based model across its components. Authenticated users on VMware ESX and vCenter can view objects or invoke operations depending on the permissions associated with their account. The vCenter authorization model provides consistent security control regardless of how users connect to the environment. NSX authentication best practices include defining access controls based on user roles and permissions and integrating with identity providers.

At the Kubernetes layer, the Supervisor exposes the full Kubernetes RBAC model through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings, which control what authenticated principals can do within a cluster or namespace. The Node authorizer supports TokenReviews and SubjectAccessReviews for delegated authentication and authorization checks. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege across workloads. Kubernetes service accounts provide identity for Pods, allowing security software to group Pods into distinct security contexts. The Secret Store Supervisor Service enforces role-based access control for administrators, DevOps engineers, and application tenants managing and distributing sensitive data. Harbor Registry, deployable as a standard package on VKS clusters, secures container artifacts with policies and role-based access control, and its administrative interface allows administrators to verify authentication and access control configurations.

Audit capabilities are built into the platform at multiple levels. All API calls to NSX Manager are subject to authentication and authorization and generate audit logs. NSX supports audit data generation as a security functional requirement. NSX Manager

and NSX Edge both include a dedicated audit role with separate credentials. The NSX Manager audit user has read-only privileges to the NSX environment and is not active by default; it must be explicitly activated after installation by an admin through the CLI. This separation of the audit role from administrative roles supports segregation of duties for audit functions. Within VCF SSO, NSX-related audit access is controlled through the `NsxAuditors` group, alongside `NsxAdministrators` and `NsxViAdministrators`, providing structured group-based assignments for NSX roles within the identity provider. NSX Manager exposes API endpoints (`/api/v1/node/aaa/auth-policy` and related paths) that return authentication policy settings, allowing administrators to validate authentication configuration across nodes programmatically. VCF Operations generates audit events across categories including access, access control, account management, configuration, data access, network, notification, permissions, session, system, policy, and firewall actions. These audit events are accessible through the Security menu and can be filtered, searched, and reviewed in detail.

The Kubernetes API server includes built-in audit logging. Audit events include an `authenticationMetadata` object that records how each request was authenticated, and when a request uses constrained impersonation the event includes an `impersonationConstraint` field that records which constrained impersonation verb authorized the request. Audit annotations capture `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, recording authorization outcomes and their justifications in the audit log. `ValidatingAdmissionPolicy` objects emit audit annotations constructed from the policy name and a qualified key, with the annotation key included in the audit event, giving administrators a policy-level audit trail for admission control decisions. Separating service account creation from human user onboarding makes it easier to maintain distinct audit strategies for workloads and individuals.

Organizations looking to govern AAA within VCF should configure identity provider federation for vCenter and NSX Manager to centralize authentication through their enterprise identity provider. At the Kubernetes layer, configuring OIDC on VKS clusters and registering the same enterprise identity provider keeps workload cluster authentication aligned with the platform's identity governance. Enabling the NSX audit user and configuring audit logging across all components, including the Kubernetes API server, provides the audit leg of the AAA triad. The platform's support for multiple authentication methods (local, LDAP, OIDC) and its role-based authorization model give administrators the technical controls needed to enforce AAA policies. However, the governance policies themselves, including which AAA solutions to use, how to review and approve AAA configurations, and how to handle AAA for external service providers, must be established and maintained as organizational processes outside the platform.

VMware Private AI Services (PAIS) provides authentication and authorization mechanisms for its AI-specific services that organizations integrate into a broader AAA governance framework.

PAIS authentication uses OIDC. During service activation, an administrator configures the OIDC issuer URL, the client ID (`pais-authentication-id`), and the required scopes (`openid`, `groups`, `offline_access`). The configuration also accepts the OIDC issuer certificate and supports an `Extra Audiences` setting that allows PAIS to accept access tokens minted for additional OAuth 2.0 clients when the OIDC provider requires it. PAIS requires HTTPS-based communication for the OIDC integration, and activation must be coordinated with the OIDC provider administrator to establish the identity and access management relationship.

Access to PAIS is governed by the `authorizedGroups` setting, which restricts service access to user accounts that are members of specified OIDC groups (for example `group-for-pais-access-01`). Group-based authorization routes identity decisions made in the OIDC provider directly into PAIS access control without separate per-service user provisioning.

PAIS supports CA trust bundle management to establish certificate-validated communication with the OIDC provider, Harbor registries, content management systems, and external knowledge base sources. The Grafana observability integration uses OIDC for metrics visualization access and should enable PKCE and refresh tokens for its own authentication flow. Harbor registry access uses credential-based authentication via `oras login` for artifact push and model pull operations, and PAIS is compatible with OCI-compliant registries from other vendors. Knowledge Bases that ingest from Confluence authenticate using either a username and password or a personal access token. Remote MCP servers connected to PAIS can optionally use static authentication tokens. Air-gapped deployments require the self-hosted registry location and login credentials when the registry requires authentication.

Identity and access management for PAIS must be configured in coordination with an external OIDC provider administrator. PAIS provides the integration hooks and access enforcement mechanisms; the OIDC provider itself, including group lifecycle management and policy enforcement, is operated and governed separately by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to AAA governance through built-in controls in Security Services Platform (SSP) and through network-layer enforcement capabilities in the Distributed Firewall.

SSP implements authentication using local accounts or directory-managed accounts. The platform uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities, alongside an Authserver that handles authentication requests and manages credentials. For directory integration, SSP supports Active Directory over LDAP or OpenLDAP, with only one identity source configured at a time. These capabilities apply across both the SSP platform itself and its License Hub component.

For authorization, SSP ships with two predefined local user accounts that enforce separation of duties: an admin user with the Enterprise Admin role for full management access, and an audit user with the Auditor role for read-only access to APIs and services for system auditing. These accounts are present in the SSP platform, the SSP Installer, and License Hub. The audit user's password must meet required criteria and can be reset by the admin user through the User Management interface.

For auditing, SSP provides a purpose-built audit user account scoped to compliance review and system inspection. All access events to License Hub are logged in audit logs that are enabled by default and cannot be disabled, providing a persistent access record for that management component.

At the network enforcement layer, vDefend microsegmentation policies restrict which systems can reach AAA infrastructure such as identity providers, directory services, and authentication servers, reducing the exposure of those services to lateral movement. Identity Firewall (IDFW) extends enforcement by using Active Directory user and group membership directly as the basis for firewall rule decisions. IDFW detects user logins by monitoring login events in domain controller event log servers, then applies security policies based on AD group membership. This allows network access rules to follow user identity across virtual desktops (VDI), Remote Desktop Sessions (RDSH), and physical machines. IDS/IPS profiles can detect attempts to exploit vulnerabilities in authentication services.

These controls do not replace organizational AAA governance policies or manage AAA solutions across the broader environment. They implement authentication, authorization, and audit mechanisms within the vDefend management layer and provide network-layer protection for AAA infrastructure that supports organizational governance objectives.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the `AutoprotectEnabledRpEvent` entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in authentication, authorization, and audit capabilities that support an organization's AAA governance requirements for the database-as-a-service layer.

For authentication, DSM supports two user authentication modes for access to the management interface: local user accounts and LDAPS-integrated accounts. Local users authenticate using an email address and password. LDAPS users authenticate with their directory service credentials at the DSM login screen, and DSM falls back to local user authentication when directory service credentials are non-functional. Organizations can integrate DSM with an LDAP or Active Directory server for both authentication and authorization, with the DSM appliance communicating with directory service servers for credential validation. This configuration is available under Managing LDAP Users in the DSM administration interface.

At the database level, DSM supports configurable host-based authentication (HBA) rules for PostgreSQL database instances. PostgreSQL instances use an ordered rule set in `pg_hba.conf` that matches connection type, client address, requested database, and user name to determine the authentication method applied. Custom HBA entries support the `scram-sha-256`, `reject`, and `cert` authentication methods; both a UI and an API are available for configuring these options. SQL Server databases use contained database users that authenticate directly against the database, with identity information stored within the database itself.

For authorization, DSM can be configured to use an LDAP server for both authentication and authorization, allowing role assignments and access decisions to be managed through the organization's existing directory infrastructure. Data service policies can be enforced consistently across different tenants, supporting a uniform security posture. Integration channels for metrics forwarding support configurable authentication: VCF Operations integration requires mutual TLS (mTLS) authentication, while Prometheus forwarding supports no authentication, certificate-only, basic authentication, or a combination of certificate and basic authentication. Webhook integrations support basic authentication with configurable Authorization User and Authorization Password credentials, so event notification channels can be secured. The DSM Consumption Operator uses a dedicated authentication secret (`dsm-auth-creds`) to authenticate with the DSM infrastructure for Kubernetes-native consumption paths.

For audit, DSM provides a System Audit capability on the Provider VM that monitors system audit events, accessible through the DSM administration interface. PostgreSQL database instances include the `pgaudit` extension, providing database-level audit logging of query and object access activity. SQL Server deployments include configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create an audit for login events.

Governing the use of these AAA mechanisms, establishing organizational policies for when LDAPS integration is required versus local accounts, defining retention and review requirements for audit logs, and extending governance to any External Service Provider hosting components of the AAA infrastructure remain organizational responsibilities. DSM provides the technical controls; organizational processes determine how strictly they are applied and monitored.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides AAA mechanisms at two layers: the administrative control plane for governing access to the Avi Controller itself, and the application delivery layer for governing client authentication to applications served through virtual services.

At the administrative control plane, Avi Load Balancer maintains user accounts in two categories: local users and remote users, with remote users authenticated through an external authentication, authorization, and accounting (AAA) server. User accounts can be validated through a local database or a remote directory service such as LDAP, limited to a specific tenant, and assigned specific roles or access levels. LDAP authentication profiles are configured via `Templates > Security > Auth`

Profile with Type set to LDAP. The documentation recommends federated authentication as the preferred pattern, delegating authentication to an external identity provider rather than managing it locally. OAuth 2.0 and OpenID Connect (OIDC) are supported for Controller client authentication, introducing an authorization layer that allows an identity provider to issue tokens to third-party applications with user approval without requiring direct credential sharing.

The Avi License Hub provides a distinct AAA surface for license management. It supports user authentication via Active Directory and OpenLDAP identity sources. The License Hub includes a dedicated Audit account with the auditor role that has full access to APIs and services for system auditing; the Admin user can reset the Audit account password. Passwords for License Hub accounts, including the audit user role, must meet specified complexity criteria.

Authorization at the administrative control plane is enforced through role-based access control. When remote authentication is configured, the Controller requires assignment of roles and tenants for every user login through authorization mapping rules configured in the Auth Mapping Profile. User accounts can be scoped to a specific tenant and assigned specific roles or access levels. The `allow_local_user_login` setting controls whether local login remains enabled alongside external authentication methods.

At the application delivery layer, virtual services can be configured with an access policy to enforce OAuth or OIDC authentication at the proxy boundary, configured under Policies > Access on a virtual service. The OAuth/OIDC flow uses an authorization server to authenticate the client, validate the authorization code, and issue access tokens. OIDC logout support includes RP-Initiated Logout, configurable per virtual service. Client LDAP authentication is also supported for virtual services, with client authorization enforced through OAuth access tokens that allow applications to act on behalf of users without direct credential sharing.

For audit logging, Avi Load Balancer requires that all external communication-related authentication failures, including those for SSH and TLS connections, be logged and persisted for auditing purposes. These records are accessible via Application Monitoring > Audit Logging.

Control 12.6

> Use of Secure Network Management and Communication Protocols

SCF Controls: NET-01, NET-04, SEA-01, TDA-02.1, TPM-04.2

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network

Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) publishes the network ports and connectivity requirements that an external service provider operating the disaster recovery infrastructure can identify, document, and justify. The PNR Security Reference section in the product documentation describes the configurable network ports that PNR Servers use to communicate with clients and other servers, and states that network firewall policies must enable traffic between local and remote PNR Servers, VMware vCenter, VMware ESX hosts, and storage arrays. Replication-specific connectivity requirements include enhanced replication traffic on TCP port 32032 between ESX hosts at the source site and the ESX hosts of the cluster containing the target datastore, a dedicated replication network with direct connectivity to all ESX servers, and three separate networks for management, replication, and edge proxy communication when PNR is deployed with VCF Automation. The Cyber Recovery Connector that fronts the isolated recovery environment requires outbound access on specified ports and fully qualified domain names through the corporate firewall, and the firewalls where the connector is deployed must allow incoming HTTP transfers up to 2 GB for connector upgrades. Configurable values such as the Lookup Service port (default 443) used by the PNR import and export tool and the syslog forwarding port (default 514) on the PNR Appliance are documented so administrators can record the exact values their environment uses. This published catalog of ports, protocols, and services gives an organization a concrete inventory it can require an external service provider to acknowledge and justify in their connectivity documentation, while the organization remains responsible for the contracts, service agreements, and onboarding workflows that enforce that documentation requirement.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool

specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Control 12.7

> Ensure Remote Devices Utilize a VPN and are Connecting to an Enterprise's AAA Infrastructure

SCF Controls: NET-14, NET-14.1, NET-14.2, NET-14.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in mechanisms for controlling and securing remote access to infrastructure components across the platform.

Centralized identity and authentication. All administrative access to VCF components flows through authenticated interfaces with centralized identity management via VCF SSO. VCF SSO supports identity provider federation, allowing vCenter to replace its built-in identity source with an external identity provider such as AD FS, Azure AD, or Okta. This integration enables organizations to enforce their existing authentication policies, including multi-factor authentication, across VCF management interfaces. VCF SSO provides centralized authentication that reduces the need for direct ESX host login with local credentials.

SSH access controls. ESX hosts include the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. SSH access is also available for NSX Manager, VCF Operations appliances, and cloud proxy instances. VCF Operations Cloud Proxy disables SSH by default, requiring initial access through the vCenter console before SSH can be enabled. When SSH is active on VCF Operations nodes, a restricted access banner is displayed to users upon connection. ESX host advanced options allow administrators to configure shell timeouts and host client session timeouts, limiting the duration of interactive remote sessions. For VCF Automation deployments, remote access supports both password and public-private key authentication via SSH, providing a stronger alternative to password-based login. VCF Operations orchestrator can also register a public key on an SSH host to enable key-based authentication.

DCUI and lockdown mode. ESX supports configuration of the DCUI.Access setting, which specifies which users can override lockdown mode and access the Direct Console User Interface. When lockdown mode is enabled, this restricts the set of accounts that can interact with the host locally or through the DCUI, reducing the available remote management surface. ESX hosts support an Exception Users list for lockdown mode, providing granular control over which accounts retain access during restricted operation. ESX supports two lockdown mode levels: Normal mode keeps the DCUI service running and allows local console access alongside vCenter management, while Strict mode stops the DCUI service entirely and restricts access to vCenter only. ESX Shell and SSH services operate independently of lockdown mode and must be separately deactivated, since lockdown mode itself does not restrict those services.

Console and management access. Access to ESX hosts requires login at the host's HTTPS URL as a user with the Administrator role. Virtual machine console access via the VNC protocol can be individually enabled or disabled through the RemoteDisplay.vnc.enabled setting in vCenter, giving administrators control over which remote console methods are available. The virtual serial port proxy can act as a gateway to enforce security policies for remote serial port connections. Management port access on network devices within the VCF environment must be password protected, and console port access must require authentication.

Role-based access control for remote sessions. Role-based access control governs what authenticated users can do once connected. vCenter allows creation of custom roles with granular privilege assignment and permission propagation to vSphere objects. The CloudAdmin role model in VCF Automation restricts administrative scope. NSX implements RBAC to restrict system access to authorized users by assigning roles with specific permissions, including the ability to create custom roles that suit operational requirements. NSX Federation also supports RBAC across federated environments. These layered RBAC controls enforce granular permissions on remote sessions across the platform.

Remote access to provisioned workloads. Remote sessions to provisioned machines in VCF Automation for VM Apps require connecting to the machine's IP address or FQDN and authenticating with a username and password. VCF Automation cloud templates also support remoteAccess authentication using public-private key pairs with SSH key input parameters.

These controls give administrators granular ability to enable, disable, and restrict specific remote access methods across VCF infrastructure. However, defining which remote access methods are organization-approved, establishing policies governing their use, and conducting periodic reviews of remote access configurations are organizational responsibilities that fall outside VCF's scope.

VMware Private AI Services (PAIS) provides mechanisms for controlling remote access to its AI workload components, supporting the organizational processes for defining and reviewing approved access methods.

PAIS enforces user access through OIDC group-based authorization. Access is granted only to user accounts belonging to groups listed in the `authorizedGroups` configuration (and the `oidc-authorized-groups` setting when activation is performed through the VCF Automation UI). Group names such as `group-for-pais-access-01` are specified on the OIDC provider, and HTTPS-based communication to the OIDC provider is required. PAIS also uses a CA trust bundle (`ca-trust-bundle`) for secure communication with external services and databases, including Harbor registries and MCP servers. When PAIS is consumed under VMware vCenter 8.x, VCF SSO must be configured to access Private AI Services namespaces and their resources from VCF Automation; under vCenter 9.x or later this SSO step is not required.

Deep Learning VMs (DL VMs) deployed through VCF Automation require user password configuration and support optional SSH public key authentication for remote administrator access. DL VMs are exposed through LoadBalancer services that provide public IP addresses and mapped ports for SSH on port 22 and JupyterLab notebook access on port 8888. DL VMs that include the NVIDIA Triton Inference Server use the same password and SSH public key authentication pattern, and are accessed over SSH as the `vmware` user. The PyTorch profile for DL VMs restricts JupyterLab to the local machine only by default, listening on port 9400, which reduces the remote attack surface for development notebooks.

API access to PAIS administrative endpoints goes through authenticated channels. The VCF Consumption CLI authenticates to VCF Automation endpoints using an API token, the FQDN or IP address of the endpoint, and an optional CA certificate for TLS verification. The `vcf context create` command issued through this CLI requires the same credentials, and VCF Automation Provider Management exposes an API Token endpoint that allows provider administrators to create and manage API tokens. VCF Automation organization administrator access tokens are obtained through a POST request to a sessions endpoint using Basic authentication. PAIS provides a dedicated VCF Automation API endpoint for registering vCenter instances using Bearer token authentication, and Broadcom recommends using the FQDN of the vCenter instance rather than its IP address when registering it.

For AI agent and knowledge base integrations, PAIS adds review controls on remote endpoints. Remote MCP servers connected to PAIS must be accessible over HTTP or HTTPS using the Streamable HTTP or Server-Sent Events transport, can optionally use static authentication tokens, and require examination and approval of their tools and capabilities before use in agents. The PAIS Agent Builder maintains a list of approved tools for use in AI agents when connecting to MCP servers, giving administrators a control point over which remote services agents are allowed to call. Microsoft SharePoint data sources used as PAIS Knowledge Bases require username and password authentication and are limited to SharePoint On-Premises deployments.

For model artifact distribution, the PAIS Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, and the `oras login` command authenticates to a private Harbor registry using username and password credentials before any push operations.

VMware vDefend (Contributes)

VMware vDefend contributes to remote access governance through network-level enforcement and behavioral detection. The Distributed Firewall (DFW) can enforce policies controlling which sources and protocols, such as SSH and RDP, may reach management interfaces, while Identity Firewall (IDFW) adds user-aware policy enforcement for remote user groups. IDFW supports Virtual Desktop Infrastructure (VDI) environments, Remote Desktop Session Hosts (RDSH), and physical machines, where multiple users may log in simultaneously; in RDSH deployments, administrators create Active Directory security groups to allow or deny user access to application servers through DFW rules based on the user's assigned role. IDFW supports the multi-user RDSH use case for both TCP and UDP protocols.

The Security Services Platform (SSP) includes Security Intelligence, which detects suspicious behavior for remote connections such as telnet, SSH, and VNC, providing visibility into remote access activity. SSP also correlates lateral movement events with subsequent infection-type activity, such as detecting RDP connections from one workload to another followed by command-and-control activity originating from the destination.

SSH access to Malware Prevention Service virtual machines is disabled by default and must be explicitly activated by the vCenter administrator. SSH to these service VMs uses key-based authentication with a public-private key pair; a public key is required at deployment time and a private key is required to initiate an SSH session. Administrators should deactivate SSH access once troubleshooting or debugging tasks are complete.

Role-based access control within SSP limits which users can administer vDefend components remotely. SSP defines five built-in roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles can be assigned to individual remote users or remote user groups, including Active Directory groups, integrating with existing enterprise directory services for remote administrator management. CLI commands for Distributed IDS/IPS must be run on ESX hosts, with available commands and viewable modes differing based on the user's assigned role.

Defining organization-approved remote access methods, VPN provisioning, and centralized remote access governance remain outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) applies cryptographic protection to the channels through which it manages paired sites and moves data between them. PNR uses TLS certificates and private keys to protect network communication and to authenticate with peer servers. The Protection and Recovery Appliance terminates TLS through an envoy proxy, and the minimum TLS protocol version is configurable by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file. Replication of virtual machine data between sites supports optional network-level encryption, and PNR can protect and recover virtual machines that are themselves encrypted, applying that protection through both array-based protection groups and vSphere Replication protection groups.

Authentication to vCenter and to remote PNR sites is brokered through VCF SSO. PNR acquires a holder-of-key SAML token from VCF SSO and presents it in cryptographically signed requests to remote services. The Configure Remote Site workflow imports certificates of the remote vCenter to establish trust for the cross-site connection, and the appliance prompts for VCF SSO credentials when an operator initiates operations that affect both sites.

PNR does not provide the network-layer VPN that connects paired sites. The product documentation requires that the connection between the local and remote sites of a Protection and Recovery pair be private, such as a VPN provisioned outside PNR. For isolated recovery environments used during cyber recovery operations, VMware recommends that workload user access be performed through VPN or a Remote Desktop Client rather than direct public internet exposure of recovered services.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several native mechanisms for controlling remote administrative access to the Controller and Service Engines. Administrators reach the Avi Controller through SSH for command-line management or through the HTTPS-based web UI and REST API. SSH is also the secure channel used between the Controller and Service Engines for management communication.

To restrict which hosts may initiate remote access sessions, the Client Management Access feature allows configuration of separate IP allowlists for SSH clients, CLI shell clients, external HTTP(S) clients, and external SNMP clients. Each allowlist accepts individual IP addresses, ranges, or IP groups. Separate IP access lists must be configured per management interface to restrict access through each channel individually. The web interface, SSH daemon, CLI Shell, and SNMP each require their own access list configuration.

SSH management sessions also support configuration of allowed HMAC algorithms. Administrators can restrict which HMAC algorithms are accepted for SSH clients rather than relying on the default of allowing all standard HMACs. This capability restricts the set of cryptographic options available during SSH session establishment.

For Service Engine remote access, Avi supports SSH key-based authentication. By default, Service Engines allow direct SSH access using the system's admin credentials; this default should be reviewed and restricted through allowlists and key-based authentication to align with site access policies.

For identity binding, Avi supports remote authentication through LDAP, TACACS+, and SAML. Administrators configure an Authentication Profile and, optionally, a Mapping Profile that binds enterprise directory group membership to Avi roles. When remote authentication is active, local user login can be retained as a fallback for emergency access or deactivated entirely to enforce remote authentication for all administrator logins.

In Kubernetes deployments, Avi Kubernetes Operator (AKO) Custom Resource Definitions (CRDs) can be governed through Kubernetes Role-Based Access Control (RBAC) policies to restrict which users and groups may configure ingress routing rules and load balancing resources.

The organization must designate approved remote access methods in policy, document them, and conduct periodic reviews to verify that allowlists, HMAC algorithm restrictions, and authentication profiles remain consistent with current access requirements.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 12.8

> Establish and Maintain Dedicated Computing Resources for AllAdministrative Work

SCF Controls: IAC-20.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF concentrates all platform administration into a small number of centralized management interfaces, primarily VCF Operations and VMware vCenter. These interfaces are the sole points of control for infrastructure provisioning, configuration, and lifecycle operations. This architectural approach supports an organizational strategy of restricting administrative access to dedicated machines by limiting the network endpoints that need to reach management planes.

VCF supports network-level isolation of management interfaces through its networking architecture. Management components can be deployed on a dedicated distributed port group with a dedicated VLAN on the management vCenter vSphere Distributed Switch, separating management traffic from workload traffic. For separation between the workload and management planes, organizations can use vSphere Zones where the Supervisor runs for the management plane only and assign different vSphere Zones to vSphere Namespaces. Network access for VCF Operations and vCenter requires HTTPS on TCP port 443, and organizations can define firewall rules and access control lists that limit connectivity to these management endpoints to designated source IP addresses or network segments. This allows organizations to enforce a policy where only traffic from dedicated administrative machines or jump hosts can reach infrastructure management planes. The vSphere documentation recommends that in especially sensitive environments, organizations configure a controlled gateway or require administrators to connect through a VPN before reaching the management network, providing an additional layer of access control beyond firewall rules alone. VCF Operations also supports SSH access for appliance-level administrative operations, authenticated with the vcf user account.

VCF enforces granular role-based access control (RBAC) across its management stack to restrict who can execute administrative tasks. The administrators role in VCF Operations should be assigned only to specific users who must access objects and perform actions across the entire environment. User accounts should be given the minimal number of privileges on the system that they require to do their jobs. When predefined roles do not meet operational needs, administrators can define new custom roles containing only the minimum set of required privileges. Access to vCenter for the management domain requires authentication as a user with the Administrator role, and VCF Operations requires a user with the ADMIN role to perform administrative operations. Within the VCF SSO domain, members of the SystemConfiguration.Administrators group have access to Appliance Management APIs but are restricted from those APIs that modify critical system configurations, providing granular privilege separation at the appliance management layer.

VCF Automation extends this task-level restriction through its authorization model. Organization administrators can create custom roles to grant selected users permissions to perform specific tasks or access content outside of their default organization roles. Project-related tasks are restricted to users who are project administrators or members. Users who need to design and run workflows and actions in VCF Operations orchestrator must be explicitly assigned those permissions. For scheduled automation jobs, users must hold the Manage Job Schedules permission, configured through Administration, Control Panel, Access Control, and the Roles tab under the Automation Central category. VCF Automation for VM Apps further restricts operational actions through role-based policy assignment, where users must be explicitly entitled to run specific actions.

For cryptographic operations, VCF provides specialized administrative separation. Only administrators with explicit encryption privileges can perform encryption and decryption tasks on virtual machines. Administrators can clone the No cryptography administrator role and create a custom role with only selected Cryptographic Operations privileges, restricting what individual users can do with virtual machine encryption and decryption. This separation of cryptographic duties from general administration supports the principle of task-specific access controls.

While VCF provides the RBAC framework, centralized management interfaces, and network segmentation capabilities that restrict administrative tasks to authorized users, the platform does not itself enforce the use of dedicated administrative

machines or privileged access workstations. Organizations must provision and maintain dedicated jump servers, privileged access workstations, or similar controls and configure the corresponding network policies, firewall rules, and VPN configurations that limit which physical or virtual machines can reach VCF Operations, vCenter, and other management endpoints.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to this control through network-level enforcement mechanisms that can restrict which sources and identities are permitted to reach management interfaces, supporting a dedicated administrative machine model.

The vDefend distributed firewall (DFW) and Gateway Firewall can restrict which source IP addresses or network segments are permitted to reach management services. Enterprise Administrators can configure Gateway Firewall rules to deny inter-project communication except for designated infrastructure protocols such as DHCP, DNS, NTP, and ICMP, creating network-level isolation boundaries that help confine administrative access to designated network segments.

The Identity Firewall (IDFW) extends enforcement to user identity. Administrators create security groups in Active Directory (AD) and configure IDFW rules to allow or deny users access to application servers based on their role. This identity-aware enforcement restricts management interface access to users in designated administrative groups, complementing source-address restrictions with user group membership criteria.

The Security Services Platform (SSP) implements Role-Based Access Control (RBAC) that limits system access based on user roles. The Enterprise Admin role has Full Access permissions covering deployment, management, upgrade, authentication and authorization configuration, server configuration, backup and restore, and activation of Security Intelligence and Malware Prevention Service. The SSP License Hub includes two predefined local user accounts: Admin with the enterprise_admin role for full platform access, and Audit with the auditor role for system auditing. The SSP Installer similarly requires Admin privileges for access and package management operations.

vDefend does not itself provision or manage dedicated administrative workstations; the control's requirement for physical or logical separation of administrative machines remains an organizational responsibility outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to this control through mechanisms that restrict from where administrative access to the Controller and Service Engine management plane may originate.

The Avi Controller supports configuration of allowed administrative source IP address ranges. By scoping these ranges to the IP addresses of designated administrative workstations or jump servers, organizations can limit Controller API and UI management operations to those originating from approved hosts. The Controller can also be configured to deny access to users without a defined role, and Auth Mapping rules can be configured to explicitly deny privileges to specific users or groups upon login, preventing them from obtaining any role or tenant access.

At the Service Engine level, the admin_ssh_enabled parameter (under serviceengineproperties > se_runtime_properties) can be set to false using the 'no admin_ssh_enabled' CLI command, disabling direct SSH administrative access to Service Engines and routing management interaction through the Controller. Management and control processes on the Avi Service Engine that communicate with the Controller are bound to the dedicated management vNIC interface, isolating management traffic from application data-plane traffic at the network level.

In the Avi for VCF integration in 9.1, the role hierarchy further limits administrative scope. Organization-Managed Mode assigns organization administrators responsibility for Service Engine Group configurations and infrastructure settings, while Project Administrators can deploy and manage load balancing for their applications but are restricted from altering Service Engine Group properties such as capacity, placement, or scaling. This separation limits which roles can perform infrastructure-level administrative operations and channels infrastructure changes through specifically authorized administrator accounts.

Designating the specific machines approved for administrative access, maintaining the list of allowed source IP ranges, and controlling network reachability to the management network remain organizational decisions outside Avi's scope. Host-level access controls on the Controller and Service Engine VMs depend on the VCF platform.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.0

> Network Monitoring and Defense: Operate processes and tooling to establish and maintain comprehensive network monitoring and defense against security threats across the enterprise's network infrastructure and user base.

SCF Controls: MON-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter

Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as `SUCCESS`, `NOT_ENOUGH_BASELINE`, and `FAILURE`.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 13.1

> Centralize Security Event Alerting

SCF Controls: MON-02, NET-18, NET-18.1, WEB-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend provides URL content filtering and FQDN-based traffic control capabilities that directly address the core intent of this control: limiting workload connections to dangerous or prohibited internet destinations.

The vDefend gateway firewall includes URL Filtering that controls access to websites based on three criteria: URL categories, URL reputation, and custom URLs. URL categories allow administrators to block or allow broad classes of websites such as gambling, malware, and social media sites, while URL reputation scores provide a risk-based assessment of individual sites. Custom URLs, configured through a Layer-7 context profile, allow organizations to define site-specific allow or deny rules.

These URL filtering capabilities are enforced through L7 access profiles applied to gateway firewall rules, and gateway firewall rules using an L7 access profile must have the rule action set to Allow, with the actions in the L7 access profile determining how traffic is processed. URL filtering operates on both HTTPS and HTTP traffic. When a TLS Inspection policy is enabled, the Gateway Firewall decrypts HTTPS traffic to perform full URL path inspection rather than relying on hostname-level matching alone. URL filtering addresses a broad range of web-delivered threats including phishing attempts and spyware distribution sites. When URL Filtering blocks a request, the Gateway Firewall returns a response page for HTTP traffic containing the URL (first 10 bytes), the applicable category, the source IP address, and configurable message text. In addition, the Gateway Firewall supports Geo-IP Filtering, allowing administrators to restrict traffic based on geographic origin alongside URL category and reputation controls.

The vDefend Security Overview Dashboard provides monitoring of URL filtering activity, including inspected FQDNs grouped by top URL categories, the highest-severity URLs with date and time, distribution of URLs by severity rating, and the top URL categories with the greatest number of blocked requests. A per-gateway metric (gfw.url_filtering_rules) tracks the number of active URL filtering rules applied to each gateway, supporting operational visibility and policy validation.

At the distributed firewall layer, vDefend provides FQDN filtering that allows administrators to create rules controlling outbound traffic based on fully qualified domain names. FQDN filtering operates at Layer 7 and supports wildcard domain patterns, including standard asterisk wildcards such as *.office365.com*, *.teams.microsoft.com*, and **.sharepoint.com*, as well as a caret (^) suffix wildcard for single-word domain matching. FQDN filtering rules are configured using a system-generated DNS context profile that is available in the deployment by default, and they support allowlisting or denylisting with source groups, destination groups, and DNS services (DNS-TCP and DNS-UDP). For FQDN filtering to function correctly, virtual machines must use a dynamic DNS server for domain resolution; static DNS entries are not supported. vDefend also supports overriding DNS TTL values through a DNS security profile, giving administrators additional control over caching behavior for domain-based policy enforcement.

Together, these capabilities allow vDefend to act as a policy enforcement point within the virtual network, screening traffic based on URL reputation, URL category, domain name, and geographic origin. However, vDefend does not function as a standalone proxy device or provide dedicated DNS filtering infrastructure such as DNS sinkholing or recursive DNS resolver filtering. Organizations typically pair vDefend's URL and FQDN filtering with a dedicated secure web gateway or DNS filtering solution to achieve the full scope of proxy-based and DNS-based filtering described in this control.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The *SrmDpxAgentUser* role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations.

Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 13.2

> Deploy a Host-Based Intrusion Detection Solution

SCF Controls: END-07

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides several capabilities at the hypervisor, virtual networking, and operations layers that contribute to host-based intrusion detection and prevention, though organizations will need to supplement these with dedicated endpoint security solutions for in-guest monitoring.

NSX, the networking component of VCF, provides the hypervisor-level host switch that anchors distributed security at the virtual NIC level on each host. VMware vDefend, a separate product that extends NSX, delivers Distributed IDS/IPS, Identity Firewall, Layer 7 Application ID, Fully Qualified Domain Name (FQDN) Filtering, Security Intelligence, Malware Prevention, and Guest Introspection on VDS-backed clusters. Because these capabilities operate within the hypervisor, they inspect traffic at the point where it enters and exits each virtual machine, providing visibility into east-west flows between workloads on the same host or across hosts in the cluster.

vDefend IDS/IPS and distributed malware prevention can be configured on discovered clusters through the NSX UI or API. NSX Application IDs enable network traffic classification and control based on application identity rather than port or protocol alone, reducing the attack surface for both north-south and east-west traffic. vDefend signature-based identification and enforcement provides visibility into, or restriction of, protocols with known vulnerabilities across all deployed applications and their east-west flows within the data center. This signature-based approach addresses lateral movement detection by inspecting inter-VM traffic that traditional perimeter-based tools cannot see.

NSX also provides network-level visibility through features such as TraceFlow for traffic path analysis, IP Discovery, and Spoof Guard. Spoof Guard authenticates the MAC and IP addresses of packets on each network adapter, helping detect unexpected or spoofed network behavior on hosts. These capabilities can be configured on discovered clusters alongside vDefend DFW and IDS/IPS using the NSX UI or API.

vDefend, available as a separate product, extends these NSX networking foundations with Advanced Threat Prevention (ATP). ATP combines multiple detection technologies including IDS/IPS, Network Sandboxing, and Network Traffic Analysis (NTA) with aggregation, correlation, and context engines from Network Detection and Response (NDR). The vDefend distributed firewall can be configured on VDS in data centers and workloads where segmentation, visibility, or advanced security capabilities are desired. When Distributed Malware Prevention is activated on host clusters, a service virtual machine (SVM) is deployed on each host to perform local malware analysis, and remote logging can be configured on each SVM for centralized alerting. vDefend also integrates a Malicious IP Feed that downloads known malicious IP addresses from the NTICS cloud service, allowing administrators to create groups and firewall rules that block access to those addresses.

The NSX Application Platform hosts additional vDefend services including Security Intelligence, vDefend Network Detection and Response, Malware Prevention for vDefend, and NSX Metrics. These services provide behavioral analysis and correlation capabilities that complement signature-based IDS/IPS detection.

Guest Introspection provides a framework through which third-party endpoint security products can integrate at the hypervisor level. The Guest Introspection Agent is installed in each guest VM to provide identity and security context. This allows agentless or thin-agent endpoint protection solutions to perform file, network, and process inspection for guest operating systems without requiring a full in-guest agent on each VM.

Beyond network-layer detection, VCF provides host-level monitoring and log analysis capabilities. VMware ESX hosts generate detailed logs of administrative actions, configuration changes, authentication events, and system state changes, with configurable syslog log levels that can be set using `esxcli` commands. Host Profiles provide a configuration integrity monitoring mechanism that detects drift from a known-good reference profile; when a host configuration deviates from the stored profile, the discrepancy is flagged and can be remediated, supporting detection of unauthorized changes at the host

layer. VCF Operations collects and correlates these logs across the environment, generating alerts when symptoms in alert definitions are triggered. Operators can create custom alert definitions with symptom parameters to identify anomalous host behavior, and the Potential Evidence feature lists problems occurring on an object that are not currently included in alert definitions, supporting identification of issues for investigation.

VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including VMware vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Log Management supports log forwarding configurations where multiple instances can forward logs to a centralized instance, and VCF Operations provides log data transfer functionality for forwarding already-ingested logs. Integration between VCF Log Management and VCF Operations is a prerequisite for creating log-based symptoms and alerts. This log infrastructure supports integration with external SIEM platforms for centralized security event monitoring and correlation.

While these hypervisor-level, network-level, and operations-level detection capabilities address many aspects of host intrusion detection and prevention, they operate primarily at the network and virtualization layer. Organizations should deploy dedicated host-based intrusion detection and prevention agents within guest operating systems for system call monitoring, file integrity monitoring, registry change detection, and other OS-level behavioral analysis that complements the network-layer and log-based inspection provided by VCF and vDefend.

VMware vDefend (Meets)

VMware vDefend provides network-layer intrusion detection and prevention for virtualized workloads through its Distributed IDS/IPS, available in the Advanced Threat Prevention edition, which monitors east-west traffic between workloads and generates threat events based on signature-based detection. Gateway IDS/IPS extends this coverage to north-south traffic at the gateway layer, providing intrusion detection and prevention for traffic entering and leaving network segments.

The IDS/IPS engine uses knowledge-based signatures that match specific patterns corresponding to known types of attacks and malicious instruction sequences. In 9.1, the engine also incorporates behavior-based detection that identifies anomalous events by comparing traffic against a baseline of normal activity. This behavioral analysis introduces a dedicated "suspicious" severity level for events classified through this method. Signatures are bundled with custom detection logic that can be updated without recompiling or modifying the IDS engine.

Signature management is accessible through the Local Manager under Security > IDS/IPS & Malware Prevention > Signature Management. Signatures are organized into configurable profiles that can be filtered by intrusion severity, attack type, CVSS score, attack target, and products affected; profiles also support enabling packet capture for later analysis. Custom signatures can be added to IDS/IPS profiles on both Distributed Firewall and Gateway Firewall, extending coverage to custom applications and emerging threats not yet addressed by standard signature bundles. Threshold settings control how frequently a given signature generates an event and can dynamically adjust rule actions based on observed traffic conditions.

A dedicated IDS/IPS dashboard and Monitoring page allow administrators to review and filter intrusion detection results by multiple criteria to support security event triage. A statistics view tracks traffic inspected by IDS/IPS rules with filtering by site for Global Manager-configured rules. An Intelligent Assist feature accessible through Security > IDS/IPS supports investigation of intrusion attempts by allowing administrators to select specific events and review the latest or historical occurrences.

Security Intelligence within the Security Services Platform (SSP) surfaces IDS/IPS detection results alongside per-workload impact scoring, detection status visibility, and anomaly detection for unusual network traffic patterns in host time-series profiles. IDS/IPS events are filterable by attack target, attack type, CVSS, product affected, service, and signature identifier. Network Detection and Response (NDR) complements the IDS/IPS layer by correlating lateral movement events with subsequent infection-type activity, such as detecting RDP traffic from one workload to another followed by command-and-control activity originating from the destination workload. NDR surfaces IDS signature matches against network traffic in the protected environment and supports filtering of affected workloads by IP address, CIDR notation, or IP range.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.3

> Deploy a Network Intrusion Detection Solution

SCF Controls: NET-08

Aggregate Coverage: Meets

VMware vDefend (Meets)

VMware vDefend provides network intrusion detection and prevention capabilities that directly address this control. vDefend with Advanced Threat Prevention combines multiple detection technologies, including Intrusion Detection/Prevention System (IDS/IPS), Network Detection and Response (NDR), and Network Traffic Analysis (NTA), with aggregation, correlation, and context engines to detect and prevent network intrusions.

vDefend Distributed IDS/IPS operates at the hypervisor level, inspecting both north-south and east-west traffic.

Administrators configure and manage intrusion detection and prevention policies through the NSX Manager interface, where they create IDS/IPS profiles, organize signature-based detection policies, and apply them through distributed firewall rules. The distributed architecture places IDS/IPS inspection at the vNIC level on every protected workload, providing visibility into lateral traffic between VMs that traditional perimeter-based NIDS/NIPS cannot see. IDS/IPS can be deployed in Detect Only mode or in Detect and Prevent mode, giving administrators control over enforcement posture.

Signature management is automated. vDefend IDS/IPS downloads the latest intrusion detection signatures automatically, either directly from the Internet or through a proxy server. Signatures are bundled with custom detection logic that can be updated without recompiling or modifying the IDS engine itself, allowing signature updates to take effect immediately. System Signatures are managed through the Local Manager interface under Security > IDS/IPS & Malware Prevention > Signature Management > System Signatures. When building IDS/IPS profiles, administrators filter included signatures by Intrusion Severities, Attack Types, CVSS scores, Attack Targets, and Products Affected, allowing precise tuning of the detection scope. Administrators can also configure thresholds for individual signatures to control how frequently a signature generates an IPS event, and rate filters that dynamically adjust a rule's action when specific traffic conditions are met. Profiles can also enable packet capture for later analysis of matched traffic.

Beyond automatic signature bundles, administrators can create custom signatures to detect malicious traffic specific to custom applications or to address zero-day vulnerabilities. Custom signatures support specific alert conditions, content matching, thresholds, and metadata, and can be included in IDS/IPS profiles applied to both the Distributed Firewall and Gateway Firewall. In multi-site environments, custom signatures can be managed from Global Manager. Network Detection and Response also consumes IDPS detections generated from custom IDS signatures, surfacing them alongside other detection events within the NDR interface.

NDR extends detection beyond signature matching. Network Detection and Response detects IDS events through signature matches against network traffic in the protected network and integrates with Distributed IDS/IPS to display IDS event details within the NDR interface. NDR Sensor IDS monitors network traffic for suspicious activities or known threat signatures, alerting on potential security breaches. NDR Sensor IDS Packet Capture records raw network packets associated with detected intrusion events, supporting forensic analysis and incident response.

Security Intelligence provides operational visibility into intrusion activity. Intrusion history can be filtered by action, attacker IP, attacker port, PCAP UUID, profile, rule, target IP, target port, and detection location. The IDS/IPS monitoring dashboard allows filtering of intrusion events by multiple criteria to support security event triage and analysis. Per-workload visibility includes impact scoring, signature details, and detection status for each protected VM. Each intrusion event is tagged with a Signature ID and associated protocol information, supporting precise identification and correlation during incident analysis.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to network intrusion detection and prevention at the application delivery layer through IP Reputation-based threat classification, automated DDoS detection and response, bot management, and an Application Rules service.

The IP Reputation service classifies source IP addresses across a wide range of threat categories, including DoS and DDoS attack sources, malware-infected hosts, phishing sites, proxy services, network scanners, and botnets. When an IP address falls into a relevant threat category, administrators configure Network Security Policies on virtual services to identify and block connections from those addresses. Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, including dropping TCP SYN packets from flagged addresses. Shared IP groups allow a single blocklist to be referenced across multiple virtual service policies, so a flagged address can be blocked consistently across the application delivery tier.

For volumetric and protocol attacks, Avi Service Engines detect and mitigate DDoS attacks across Layer 4 through Layer 7, including DNS amplification attacks, DNS Reflection Ingress attacks, and NXDOMAIN attacks. Avi can also report or actively block attackers performing port scans as part of DDoS detection. DDoS attack mitigation mechanisms support IPv6 addresses, including mitigation for Neighbor Discovery Protocol (NDP) attacks. The Avi Controller monitors denial-of-service attack events with configurable alert levels and thresholds, tracking attack count metrics and generating alerts at configurable severity levels. When a SYN flood or other volumetric attack is detected, alert actions can automatically invoke ControlScripts that add the offending source IP address to a blocklist IP group attached to a network security policy, providing automated blocking in response to detected attack events. The Avi Security Manager creates network security rules and DNS rules for Service Engines to block the attacker's IP address, source port, and DNS record request types.

The Application Rules service, available through Avi Cloud Console, provides automatically updated rules specifically designed to block attacks on known application vulnerabilities, including those with published CVE identifiers. These rules extend the detection and prevention surface to application-layer attack patterns beyond IP reputation filtering.

The Bot Management capability identifies bot traffic intent, distinguishing benign bots from malicious actors such as scrapers, spam sources, click fraud engines, bot impersonators, and botnets. The IP Reputation service is also used as a source for bot detection and classification, combining IP-reputation detection, user-agent detection, and IP-location detection through the Bot Decision Component.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) supports L4 Rule CRDs that express custom security policies applied to virtual service traffic, specifying configuration for DDoS attack detection and mitigation. These CRDs can also allow, deny, or rate-limit connections from individual or grouped IP addresses. HostRule CRDs can reference network security policy objects for consistent policy application across ingress resources.

These capabilities address intrusion detection and prevention at the application ingress path. Network-layer intrusion detection and prevention covering east-west and north-south traffic flows across the broader VCF environment is provided by VMware vDefend with IDS/IPS capabilities, which is a separate product and carries the Meets rating for this control. Full satisfaction of the control requires NIDS/NIPS deployment at multiple network layers.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.4

> Perform Traffic Filtering Between Network Segments

SCF Controls: NET-04, NET-04.1

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides multiple layers of access control list (ACL) mechanisms and network traffic restriction capabilities that contribute to data flow enforcement, though full ACL governance across physical and virtual infrastructure requires organizational processes and may benefit from VMware vDefend for advanced stateful firewall rule sets.

At the network infrastructure layer, VCF uses vSphere Distributed Switches to centrally manage VLAN assignments, port group policies, and traffic shaping rules across all hosts in a workload domain. Distributed switches support traffic shaping policies that limit the bandwidth of incoming traffic, helping restrict which traffic types and volumes can traverse each network segment. Distributed port groups and uplink port groups also support a Traffic Filtering and Marking Policy, where per-rule actions can be set to Allow, Drop, or Tag traffic based on defined match criteria, providing rule-based traffic enforcement at the virtual switch level. Traffic segmentation is built into VCF's architecture: management, vMotion, vSAN, and NFS traffic each run on dedicated VLANs and VMkernel ports, and the vMotion network must be distinct from the vSAN network. This separation restricts which traffic types can traverse each segment by design. Private VLANs (PVLANs) provide additional Layer 2 isolation within a single VLAN through virtual network segmentation on distributed virtual switches, limiting communication between VMs even on the same segment. Distributed switches also support VLAN-based SPAN (VSPAN) for virtual distributed port mirroring, which aids in monitoring and validating traffic flows. At the ESX host level, a built-in firewall operates on a deny-by-default basis, closing all ports except those an administrator explicitly designates as authorized, giving each host an independent network access control point.

NSX extends these capabilities with software-defined networking constructs including segments, Tier-0 and Tier-1 gateways, and Virtual Private Clouds (VPCs). NSX Tier-0 gateways can be configured with linked Tier-1 gateways to create multi-tier topologies, enabling route-based traffic restrictions between network tiers. NSX edge gateways handle north-south routing. With vDefend deployed, North-South Firewall Rules on these gateways provide traffic protection, and an NSX project's default gateway firewall and distributed firewall rules (a vDefend capability) govern the default behavior of north-south and east-west traffic for workloads in that project. VPCs are self-contained virtual network environments that provide an abstraction layer for setting up isolated virtual private cloud networks with their own topology, IP address management, and permission models, allocatable to discrete projects in a self-service consumption model. NSX Manager enforces approved authorizations for controlling the flow of management information within network devices based on information flow control policies.

NSX also provides data flow enforcement at the load balancer tier through its Access List Control (ALC) feature. The NSX load balancer compares all traffic flowing through it with ACL statements, which either drop or allow the traffic based on configured rules. This gives administrators another enforcement point for restricting network traffic to only what is authorized.

At the Consumption layer, VMware Kubernetes Service (VKS) and the Supervisor extend ACL enforcement to containerized workloads through Kubernetes NetworkPolicy resources, which function as Layer 3/4 ACLs for pod-level traffic. NetworkPolicy objects specify allowed ingress and egress traffic by pod selector, namespace selector, IP block, port, and protocol; pods not selected by any NetworkPolicy receive no restriction by default, making explicit policy deployment necessary to enforce a default-deny posture across a cluster. VKS clusters run Antrea as the default CNI plugin, which implements NetworkPolicy enforcement through the AntreaPolicy feature gate and provides per-policy and per-rule packet and byte count statistics through the NetworkPolicyStats capability, giving administrators visibility into which policies are actively restricting traffic. For VKS clusters using NSX VPC networking, NSX-backed network policies apply distributed ACLs at the hypervisor level, extending enforcement beyond the CNI layer. The ovn-kubernetes Transparent network mode similarly supports distributed ACLs applied via Kubernetes NetworkPolicy resources. For Layer 7 traffic control within VKS clusters, the Istio service mesh standard package provides a pluggable policy layer and configuration API supporting access controls, rate limits, and quotas based on workload identity; when deployed in ambient mode with strict mutual TLS, all service-to-service

traffic within the mesh is subject to authentication before authorization checks apply, restricting lateral movement to explicitly permitted paths.

For file-level and storage data flow isolation, the Supervisor uses ACLs to isolate file share access within supervisor namespaces, restricting data access between workloads running in different namespaces. vSAN file services support managing ACLs on SMB shares using the MMC tool, giving administrators granular control over which users and systems can access shared storage resources. Administrators should be aware that ACL-based file share isolation in the Supervisor carries a risk of IP spoofing, which should be addressed through complementary network controls when deploying file shares in multi-tenant environments. Argo CD deployments on the Supervisor implement network segmentation and firewall rules to control communication between Argo CD components, following the principle of restricting inter-component traffic to only what each component requires. The Harbor container registry standard package enforces role-based access control over artifact access, complementing network-layer ACLs with image-level access restrictions.

For object-level access control, VCF Automation maintains an ACL table that defines which users can access specific defined entities. System administrators with the Manage General ACL right can create, modify, and remove ACL entries through the accessControls API. Those with the View General ACL right can audit ACL assignments on specific entities. Access to runtime defined entities is controlled through rights bundles and ACL entries. This ACL mechanism works alongside role-based access controls so that rights determine what actions a user can perform while ACLs determine which objects those actions apply to.

VCF Operations for Networks supports ACL visibility through its network assurance and verification capabilities, which allow administrators to validate that ACL configurations are applied as intended across the managed environment. This includes the ability to verify ACL configurations on supported physical network equipment such as Cisco ASR routers, helping validate that physical and virtual network access controls are consistent.

For workload-level traffic enforcement with stateful firewall rules, microsegmentation, and deep packet inspection, VMware vDefend and Gateway Firewall extend VCF's networking foundation with fine-grained Layer 2-7 policy enforcement. Organizations that require ACL governance beyond what VCF provides natively should establish processes for ACL review cycles, change management for firewall rules, and regular validation of both physical and virtual network access controls.

VMware vDefend (Meets)

VMware vDefend provides the primary data flow enforcement mechanism within VCF through its Distributed Firewall, Gateway Firewall, and Security Intelligence capabilities. These capabilities function as software-defined access control lists governing traffic between workloads, segments, and external networks.

The vDefend distributed firewall enforces Layer 2-7 access policies at the vNIC level on every workload. Administrators define firewall rules that explicitly permit or deny traffic based on source and destination groups, ports, protocols, application identity, user identity via Active Directory integration through Identity Firewall, and fully qualified domain names (FQDN filtering). Because enforcement happens at the workload's virtual network interface, traffic is filtered before it reaches the physical network, and policies follow the workload as it moves between hosts. The Application Connectivity Strategy's "Allow Intra, Deny Other Traffic" mode automatically generates an intra-group ALLOW rule with optional logging plus a default ANY/ANY/DROP rule to isolate the group, providing a structured default-deny posture that restricts traffic to only what is explicitly authorized.

URL filtering provides an additional access control layer, enabling rule-based restrictions based on URL categories, URL reputation scores, and custom URL lists applied to both HTTP and HTTPS traffic. Identity Firewall rules can specify source users or groups, destination resources, services, and context profiles to allow or deny traffic based on Active Directory group membership. These rules support Allow and Reject actions and can be applied to physical devices where users log in, as well as to tier-0 and tier-1 gateways. Role-based access control within the Distributed Firewall governs who can create or modify firewall rules, restricting policy changes to authorized personnel.

The vDefend gateway firewall provides stateful North-South traffic inspection at Tier-0 and Tier-1 gateways, enforcing ACL-equivalent rules on traffic entering or leaving network segments. The Gateway Firewall supports Identity Firewall integration with Active Directory for identity-based access control at the perimeter. Together, the Distributed and Gateway Firewalls address both East-West (inter-workload) and North-South (perimeter) data flow enforcement.

Security Intelligence, hosted on the Security Services Platform, supports ACL governance by observing traffic flows between applications and environments. Security Intelligence classifies flows as allowed, blocked, or unprotected and generates policy recommendations with segmentation strategy actions of Allow (creates a default traffic flow allow rule) or Drop (creates a default traffic flow drop rule). When a security policy is published, a rule is automatically generated to allow intra-application traffic. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, helping administrators identify unauthorized communication patterns and tighten ACL governance over time.

The Security Services Platform governs access to Security Intelligence operations through role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Three permission levels apply across operations: Full Access (Create, Read, Update, and Delete), Read, and None. This restricts policy recommendation and enforcement actions to authorized security personnel.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides network-layer access control list (ACL) enforcement at the application delivery layer through Network Security Policies attached to virtual services. These policies evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. Rules reference named IP Groups, which are reusable collections of IP addresses, IP ranges, and IP network prefixes. A Network Security Policy that denies traffic stops further policy evaluation, so ACL denials take effect before any downstream HTTP Security, Request, or Response policies execute.

Administrators configure Network Security Policies on individual virtual services through the Avi Controller. IP Groups are managed centrally and can be referenced across multiple virtual services, providing a scalable method for applying consistent ACL rules across the environment. The Avi Controller API supports programmatic creation and modification of Network Security rules that match on IP address and apply IP Groups to control access, enabling automated ACL governance through scripts or orchestration systems.

At Layer 7, Avi WAF rule actions support pass (allow) and deny (block) options for controlling traffic based on policy matches, extending data-flow enforcement to the application layer. Avi Load Balancer also supports OAuth/OIDC authorization policies that can match token scope attributes and request paths using CONTAINS and BEGINS_WITH match criteria, enabling granular, path-based access control for API endpoints.

The Avi Controller enforces IP Access Lists on its own management interfaces by programming Linux IP tables on the Controller host, restricting network-layer access to specified management endpoints. These lists, configured under Administration > Controller Access Settings, limit which client IP addresses may reach the Controller API and UI.

These mechanisms scope Avi's ACL enforcement to traffic transiting its virtual services and to Controller management-plane access. ACL governance for east-west and other network traffic not flowing through Avi virtual services relies on VMware vDefend and VCF network controls.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.5

> Manage Access Control for Remote Assets

SCF Controls: NET-01.1, NET-03, NET-14.7

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides networking infrastructure and monitoring capabilities that support boundary protection at both external network boundaries and key internal boundaries within the virtual environment.

At the external boundary, NSX Edge nodes serve as the communication gateway for inter-location and northbound traffic, establishing a defined perimeter through which external communications traverse. NSX Edge supports policy-based and route-based IPsec VPN services on Tier-0, Tier-0 VRF, and Tier-1 gateways, enabling secure connectivity between sites and to external networks. NAT rules can be configured at the VPC level to perform IP translation between internal and external networks, controlling which workloads are reachable from outside the environment. External IP configurations allow outside connectivity for virtual machines on private networks by performing address translation through 1:1 NAT, granting access to specific workloads rather than exposing entire network segments.

For internal boundary control, VCF provides several layers of network segmentation. NSX segments, VLANs, and Private VLANs (PVLANS) allow administrators to create logical network boundaries that separate traffic at Layer 2. VMware distributed virtual switches support Private VLAN and VLAN-based SPAN for virtual distributed port mirroring. ESX port groups function as communication boundaries and can be configured with security policies to segment traffic between different groups of virtual machines. vSphere Distributed Switch port groups also support a Traffic Filtering and Marking Policy, which can permit or stop traffic on a per-port-group or per-port basis; port blocking policies provide a complementary mechanism to selectively prevent individual distributed ports from sending or receiving data. vSphere Distributed Switches provide centralized management of these boundaries across all hosts in a workload domain, applying consistent VLAN configurations and traffic shaping rules.

VCF supports multiple distributed switch models that isolate traffic at the physical layer. The Storage Separation Distributed Switch model isolates storage traffic onto a separate vSphere Distributed Switch from management and virtual networking traffic. The Workload Separation Distributed Switch model isolates VM Management traffic onto a separate switch from ESX Management, vMotion, Storage, and Virtual Networking traffic. In secure environments, these separation models can provide physical air-gapped separation of network traffic.

NSX Virtual Private Clouds (VPCs) provide isolated network environments within a shared infrastructure. VPCs support on-demand logical networks that can be advertised as public subnets or exposed through networking services like External IPs or NAT, providing project-level boundary isolation with their own topology, IP address management, and permission models. VCF Automation maintains secure organizational boundaries that isolate tenants from one another, providing additional logical separation within the environment.

Network I/O Control (NIOC) determines the bandwidth that different network traffic types are given on a vSphere distributed switch. When NIOC is enabled, distributed switch traffic is divided into predefined network resource pools covering Fault Tolerance, iSCSI, vMotion, management, vSphere Replication, NFS, and virtual machine traffic. Bandwidth reservation and shares allocation enforce performance boundaries between traffic types under contention. Avi Load Balancer provides Layer 4 load balancing for services, distributing traffic across server pools with configurable load balancing algorithms and health monitoring.

VCF provides network monitoring through multiple components. NSX supports IPFIX profile configuration on segments to enable flow-based network monitoring, giving administrators visibility into traffic traversing the network. At the vSphere layer, NetFlow can be enabled on individual distributed port groups or ports through the vSphere Distributed Switch monitoring policy, providing IP packet flow data independent of NSX. The pktcap-uw command-line utility on ESX hosts supports packet capture at specific points in the network stack, including at physical adapters and at the boundary between the distributed

switch and physical adapters, enabling packet-level traffic inspection without additional tools. NSX Manager monitors control plane connections between transport nodes and manager nodes, providing awareness of the network infrastructure state.

VCF Operations extends monitoring capabilities with network metrics including inbound and outbound connection tracking (net|allInboundTotal and net|allOutboundTotal). The Management Pack for Network Devices provides alerts and notifications for key network events including throughput totals and packet counts, and monitors outgoing errors on network interfaces. VCF Operations can detect protected flows, identifying traffic that has a specific firewall rule associated with it beyond a default allow-all policy, which helps administrators understand which communications are governed by explicit security policies. Outbound flow limits serve as a protection mechanism, with TCP flows limited to 1,000 allowed and 50 denied outbound, and UDP flows limited to 500 allowed and 50 denied outbound. VCF Operations also supports firewall hardening that restricts network access to its own internal services, demonstrating boundary protection for management interfaces.

VCF Operations for Networks adds flow analysis and troubleshooting capabilities, including application discovery based on flows, network topology visualization through the Topology Graph Widget, and traffic flow visualization between applications, application tiers, shared services, and the Internet. VCF Operations for Networks provides intents for network design and verification, helping validate that the network configuration matches the intended design. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU verification, while vSAN network partition health checks detect VLAN misconfigurations and uplink losses. VCF Operations for Networks also provides visibility into vDefend distributed firewall rule activity, including identification of inactive rules that have had no matching flows.

VMware Kubernetes Service (VKS) clusters and the vSphere Supervisor control plane extend boundary protection to the workload consumption layer. Within VKS clusters, Kubernetes NetworkPolicy objects provide declarative packet-filtering rules at OSI Layer 3 and Layer 4, defining permitted ingress and egress traffic based on pod label selectors, namespace selectors, and CIDR blocks. By default, pods accept all traffic; NetworkPolicy objects restrict communication to only the flows required for each workload or namespace, establishing internal boundaries between application tiers. Antrea, the CNI plugin integrated with Supervisor in NSX VPC deployments, enforces these NetworkPolicy rules and exposes NetworkPolicyStats, giving administrators measurable visibility into how boundary controls are applied across cluster-internal traffic. At the cluster perimeter, distributed firewall isolation rules on cluster nodes block external networks from reaching VKS cluster pods by default; Supervisor control plane nodes can reach cluster pods, but traffic originating outside the Supervisor control plane is dropped. Connections from worker nodes and pods to the Kubernetes API server use the API server's secure port by default, and SSH tunnels restrict control plane-to-node communications from exposure outside the cluster network. Kubernetes Ingress resources backed by ingress controllers perform TLS termination and route external requests to backend services, establishing a defined and controlled entry point at each cluster's external-facing edge. Network segmentation and firewall rules are applied to secure inter-component communication within Supervisor Service deployments such as Argo CD.

For stateful firewall inspection, microsegmentation, IDS/IPS, and deep packet inspection at network boundaries, organizations can deploy VMware vDefend, which extends VCF's networking foundation with Layer 2 through Layer 7 firewall capabilities and advanced threat prevention. VCF's networking layer provides the segmentation, routing, and monitoring infrastructure on which boundary enforcement policies operate, but the active enforcement of traffic at those boundaries requires either vDefend or integration with external security tools. Organizational processes for defining boundary policies, reviewing traffic logs, managing firewall rule sets, and maintaining network diagrams are also required.

VMware Private AI Services (PAIS) contributes to boundary protection through AI-infrastructure-specific network isolation patterns for both connected and air-gapped deployments. The core boundary enforcement capabilities, including distributed firewall rules, IDS/IPS inspection, and traffic analysis, are provided by VCF and VMware vDefend.

PAIS setup is configured according to environment Internet connectivity, supporting either connected or disconnected air-gapped deployment models. In a disconnected air-gapped environment, files are downloaded from the Internet to a bastion host VM and then transferred to an admin host VM that has no Internet access, from which VI administrators interact with the environment. This pattern removes direct Internet exposure from the AI infrastructure components and constrains the path by which external content enters the trusted enclave.

In air-gapped deployments, PAIS configures components to pull container images from a local internal registry rather than from public sources. The NVIDIA GPU Operator deploys validator, operator, driver, manager, toolkit, and devicePlugin components as separate container images pulled from the local registry. PAIS model endpoints authenticate to private registries through harbor-pull-secret-readonly to control access to container images.

PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, providing an internal boundary between AI workload data stores and other platform consumers. PAIS uses a CA trust bundle for secure communication with external services and databases.

The NSX Edge cluster or Virtual Network Appliance (VNA) cluster provides two-tier north-south routing for the Supervisor instance and the workloads it runs, while the Workload Domain NSX Manager provides VPC networking services to private AI workloads. VPC networking for the VCF Automation organization is configured with a Public IP range, a transit gateway IP range, and a VPC private IP range to delineate external, transit, and internal address space for AI tenants.

Organizations should refer to the VCF and vDefend Coverages for the underlying boundary monitoring and enforcement infrastructure.

VMware vDefend (Meets)

VMware vDefend provides monitoring and control of communications at both external and internal network boundaries within the virtual infrastructure through stateful firewall inspection, microsegmentation, and behavioral traffic analysis.

At the external boundary, vDefend enforces zone boundaries and provides stateful North-South traffic inspection at the network perimeter. Gateway Firewall policies apply to traffic entering and leaving edge gateways, and Gateway Firewall IDS/IPS events can be monitored on nodes, providing inspection-layer visibility at the external boundary.

At internal boundaries, vDefend enforces East-West traffic policies between virtual machines, containers, and workloads regardless of their physical location. Distributed Firewall rules operate at the vNIC level, creating per-workload enforcement points that function as internal boundary controls. Distributed Firewall manages East-West traffic control for both inter-VPC and intra-VPC communication within Organizations, and Distributed Firewall rules protect traffic between objects within a VPC, enforcing boundaries within project-scoped network environments. This microsegmentation approach allows organizations to define fine-grained internal boundaries beyond traditional VLAN-based segmentation. The policy-level Applied-To field defines a clear boundary around a set of VMs, such as an entire application, allowing targeted policies for specific zones, tenants, or applications without interfering with policies defined for other applications, tenants, or zones. Distributed Firewall policies can explicitly block unsecure protocols such as Telnet, FTP, and TFTP across the data center, supporting protocol-level boundary enforcement. Distributed Firewall also supports targeted deny rules scoped to infrastructure groups via the Applied-To field to protect critical services, facilitating phased Zero Trust adoption. Distributed Firewall governance implements least-privilege security by preventing overly permissive rules such as any-to-any-allow configurations. Distributed Firewall policies manage security for Bare Metal servers through traffic-control rules, extending boundary enforcement beyond virtual workloads. For federated environments, Distributed Firewall policies applied globally allow sources or destinations to be any object without span restrictions, supporting multi-site boundary enforcement.

Security Services Platform adds environment-level boundary enforcement through Protection Rules, which define how traffic flows between environment pairs such as production, development, and test. Protection Rule actions can be set to Drop or Reject to block all traffic between specified environment pairs, or Allow for more selective enforcement. Security Services Platform Environment Protection evaluates whether workloads are protected by environment-specific segmentation policies and measures coverage including the percentage of environment pairs in blocked mode. Application Protection in Strict Mode enforces application-level firewall rules on all application workloads except infrastructure, with scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence, a capability within Security Services Platform, defines private IP ranges as the boundary for internal workloads, treating traffic that crosses this boundary as external. The Secure External Communications project identifies workloads with inbound or outbound connections to external IP addresses to mitigate vulnerability to attacks. Security Intelligence recommends identifying all inter-environment flows and securing them with specific policies before enforcing strict block rules, supporting a methodical approach to boundary hardening.

Network Detection and Response (NDR) monitors traffic across boundaries and collects detection events representing security-relevant activity that has occurred in the network. NDR can be integrated with SIEMs to send security event logs about network infrastructure for centralized boundary monitoring. In sensitive or classified environments, NDR can be configured for air-gapped networks, executing all detection, correlation, and response activities entirely within closed networks using local storage and processing without requiring external connectivity. NDR remediations for events detected on the Gateway Firewall are applied on the Distributed Firewall, providing a unified enforcement response across both the internal and external boundary layers.

vDefend does not define which boundaries an organization should establish or set the policies governing boundary placement decisions. Those are organizational architecture and governance responsibilities. The underlying networking infrastructure of VCF, comprising NSX segments, VLANs, and edge gateways, provides the segmentation and routing fabric on which vDefend's boundary enforcement operates.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides boundary protection mechanisms at the application delivery layer for traffic it proxies. Network Security Policies in Avi evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. These policies apply IP-based traffic filtering at the virtual service level; a deny rule stops further policy evaluation, preventing downstream HTTP Security, Request, or Response policies from executing for that traffic. Network security policies are configurable per virtual service and per Virtual IP address, giving administrators auditable and consistent access controls across the deployment.

Avi's Web Application Firewall (WAF) inspects application-layer traffic at the proxy boundary using positive and negative security models. Positive Security rules define what constitutes allowed application behavior and enforce restrictions on traffic that does not conform to that model. WAF Application Rules provide protection against known attack patterns, including rules targeting specific CVEs; rules are automatically updated through the Controller Cloud Services connection, and existing rules continue to protect applications when that connection is unavailable. WAF rule actions support pass and deny options for controlling traffic based on policy matches. Administrators can also enable the Application Rules service through the Avi Cloud Console, which delivers automatically updated CVE-targeted rules directly to Avi Controllers.

For DDoS mitigation, Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework. This includes protection against DNS Reflection Ingress attacks, which involve sending DNS queries with spoofed IP addresses to flood a victim with unsolicited DNS server responses.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) extends boundary controls to Kubernetes ingress traffic. The L4 Rule custom resource definition (CRD) in AKO allows administrators to express custom Security Policies applied to virtual service traffic, including configuration for DDoS attack detection and mitigation. The `'insecureEdgeTerminationPolicy'` setting in AKO controls handling of insecure traffic, with a redirect option that enforces secure traffic routing through HTTP Request policies applied per FQDN.

Avi Service Engines implement traffic isolation between the data plane and the management and control plane using a dedicated management vNIC bound to the default Linux network namespace, with health monitor traffic further isolated through Linux network namespace features in the kernel. Service Engine IP addresses egressing the Data Plane vNIC are routed through the external network and subjected to routing isolation and ACL/firewalling controls present in that external network. A dedicated management network is required for communication between Avi Controllers and Service Engines. In isolated network deployments, each Avi Controller supports a second management IP address or DNS-resolvable FQDN for Service Engines connecting from an isolated segment, configured via the `'isolated-network-management-address'` setting.

In VCF deployments using the Avi-for-VCF integration, the Management Network hosts the Avi Controller and provides connectivity to vCenter, ESX hosts, and Supervisor control plane nodes, maintaining a defined boundary between management and workload traffic.

Incoming HTTP(S) traffic can be replicated to logging and sideband servers at the protocol level via the Virtual Service Sideband Profile, enabling deep traffic inspection by external appliances such as web application firewalls and supporting compliance and auditing requirements.

Avi also supports a Firewall Sandwich Topology, where virtual services and firewall pool members are chained so that application traffic traverses configured firewall members on its path from the Internet to internal servers. In this topology, a sample of traffic is inspected by the firewall while remaining traffic considered trusted is directly routed to the internal network.

Boundary protection for segments and layers outside Avi's application delivery scope, including network-level perimeter controls, east-west enforcement between application tiers, and internal boundary protection across the broader VCF environment, requires the VCF networking infrastructure and VMware vDefend, which is a separate product.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.6

> Collect Network Traffic Flow Logs

SCF Controls: MON-01, MON-01.13, MON-02.1, MON-02.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states

(Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service,

allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.llmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Meets)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 13.7

> Deploy a Host-Based Intrusion Prevention Solution

SCF Controls: END-06.2, END-07

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides several capabilities that support detection of unauthorized configuration changes, though a complete endpoint detection and response program requires additional organizational processes and specialized security tools.

VCF Operations includes unified configuration management with scheduled drift detection for vCenter instances and vSphere clusters. This capability proactively identifies configuration deviations from a desired state, allowing administrators to detect when settings have been modified outside approved change processes. The Configuration Drift dashboard in VCF Operations lets administrators view and compare configuration drifts, identify which settings have changed, and quickly locate unauthorized modifications across the environment. Drift detection runs on a configurable schedule and compares actual state against the defined baseline. vSphere Configuration Profiles must be enabled on clusters for drift status to be visible in VCF Operations.

vSphere Lifecycle Manager (vLCM) provides a complementary layer of configuration change detection at the host level. vSphere Configuration Profiles define the expected configuration state for ESX hosts within a cluster. When a host drifts from the desired state, vLCM detects the deviation and can remediate the host back to compliance. Software specification compliance checks validate that hosts match the committed desired-state specification, reporting discrepancies for investigation. vLCM can retrieve a host's current desired state, check compliance against it, and apply remediation as needed. vSphere Configuration Profiles can also be configured to trigger alarms on cluster or host out-of-compliance events using the `com.vmware.vclIntegrity.ClusterConfigurationOutOfCompliance` event type; these alarms can notify administrators via email or SNMP trap.

Audit logging across VCF components records configuration changes with full attribution. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, capturing the principal identifier, the affected object, and the time of the modification. NSX Manager generates detailed audit log messages for security policy changes, and for vDefend distributed firewall and gateway firewall configuration changes when that separate product is deployed, recording the username, module name, operation type, operation status, and both old and new values for modified policies. This level of detail supports forensic investigation when an unauthorized change is detected. vCenter also writes audit events to the VCF SSO audit log for changes to security configuration, parameters, or policies.

VCF Operations generates alerts when specific configuration changes occur. An alert is raised when any property of a Security Group is changed, and a separate alert fires when Security Group membership changes, providing near-real-time notification of modifications to network security constructs. VCF Operations also raises a Configuration Change alert when any entity property changes, identifying what changed, when, and who made the modification.

NSX Manager can trigger an unscheduled full configuration backup when the system detects any user, runtime, or configuration-related changes, preserving the state for comparison and rollback. NSX also supports triggering backups specifically for configuration changes in addition to scheduled inventory change backups, providing a recovery point tied to the moment a change was detected.

VCF Operations supports rule-based analytics and machine learning that help identify anomalous behavior patterns across the infrastructure. Dynamic thresholding is enabled by default and uses analysis of historical data to establish baselines, generating alerts when metric values deviate from expected patterns. Intelligent Alerts automate alert correlation and filtering to help administrators focus on the most critical issues. VCF Operations also generates outlier violation alerts when anomalous entities are detected. These analytics help distinguish authorized administrative changes from unauthorized modifications, supporting security teams in prioritizing investigation.

Integration with external monitoring and incident management platforms is available through VCF Operations outbound notification plug-ins, which support standard email, SNMP trap, log file, and REST endpoints. This allows configuration change alerts to feed directly into the organization's incident response workflow and SIEM platforms.

These capabilities provide the detection foundation for identifying unauthorized configuration changes. However, classifying detected changes as cybersecurity incidents and executing an incident response workflow requires organizational processes, integration with a SIEM platform, and potentially dedicated endpoint detection and response tooling that operates beyond what VCF provides natively.

VMware vDefend (Meets)

VMware vDefend provides network-layer intrusion detection and prevention for virtualized workloads through its Distributed IDS/IPS, available in the Advanced Threat Prevention edition, which monitors east-west traffic between workloads and generates threat events based on signature-based detection. Gateway IDS/IPS extends this coverage to north-south traffic at the gateway layer, providing intrusion detection and prevention for traffic entering and leaving network segments.

The IDS/IPS engine uses knowledge-based signatures that match specific patterns corresponding to known types of attacks and malicious instruction sequences. In 9.1, the engine also incorporates behavior-based detection that identifies anomalous events by comparing traffic against a baseline of normal activity. This behavioral analysis introduces a dedicated "suspicious" severity level for events classified through this method. Signatures are bundled with custom detection logic that can be updated without recompiling or modifying the IDS engine.

Signature management is accessible through the Local Manager under Security > IDS/IPS & Malware Prevention > Signature Management. Signatures are organized into configurable profiles that can be filtered by intrusion severity, attack type, CVSS score, attack target, and products affected; profiles also support enabling packet capture for later analysis. Custom signatures can be added to IDS/IPS profiles on both Distributed Firewall and Gateway Firewall, extending coverage to custom applications and emerging threats not yet addressed by standard signature bundles. Threshold settings control how frequently a given signature generates an event and can dynamically adjust rule actions based on observed traffic conditions.

A dedicated IDS/IPS dashboard and Monitoring page allow administrators to review and filter intrusion detection results by multiple criteria to support security event triage. A statistics view tracks traffic inspected by IDS/IPS rules with filtering by site for Global Manager-configured rules. An Intelligent Assist feature accessible through Security > IDS/IPS supports investigation of intrusion attempts by allowing administrators to select specific events and review the latest or historical occurrences.

Security Intelligence within the Security Services Platform (SSP) surfaces IDS/IPS detection results alongside per-workload impact scoring, detection status visibility, and anomaly detection for unusual network traffic patterns in host time-series profiles. IDS/IPS events are filterable by attack target, attack type, CVSS, product affected, service, and signature identifier. Network Detection and Response (NDR) complements the IDS/IPS layer by correlating lateral movement events with subsequent infection-type activity, such as detecting RDP traffic from one workload to another followed by command-and-control activity originating from the destination workload. NDR surfaces IDS signature matches against network traffic in the protected environment and supports filtering of affected workloads by IP address, CIDR notation, or IP range.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes a Config Audit Trail that records all configuration changes made to the Avi Controller, whether initiated through the CLI, API, GUI, or by automated policies. The audit trail captures user activity events and configuration change events over a selected time period and is accessible via Operations > Events > Config Audit Trail. Each event identifies the specific configuration object modified, the tenant context, the timestamp of the change, and the user account that performed the action.

Avi Controller CONFIG_CREATE and CONFIG_DELETE events include client_IP and user_agent fields, which allow operators to identify not only which user account initiated a configuration change but also the source IP address and the client application involved. Event Logs can be filtered by event type using parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE, allowing operators to isolate and review configuration changes systematically. When a

configuration event is selected, the event log displays the specific API fields that were changed, providing detailed change tracking for investigation.

Configuration change events can be forwarded to external systems via syslog. The SYSLOG_JSON alert type captures CONFIG_UPDATE events with details including the event type, affected object, tenant context, update status, and performing user, making Avi's configuration audit data suitable for ingestion into a SIEM or log aggregation platform where correlation rules can generate alerts on unexpected changes. This forwarding path is the primary mechanism by which Avi's configuration audit data integrates with an organization's broader incident detection and response workflow.

Avi also provides a Config Events overlay within Service Engine analytics and Server Pool analytics that allows operators to correlate traffic anomalies with configuration changes by time, helping identify whether a specific configuration change caused a traffic or security impact. The Controller can be configured to enable configuration warnings, which notify users when configuration changes occur.

Organizations must supplement these detection capabilities with defined authorization baselines that specify which configuration changes are expected or permitted, SIEM integration or incident management tooling that acts on CONFIG_CREATE or CONFIG_UPDATE events, and response procedures for investigating and remediating anomalies. Avi provides the detection data; the determination of what constitutes an unauthorized change and the response workflow require organizational policy and integration with external platforms.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.8

> Deploy a Network Intrusion Prevention Solution

SCF Controls: NET-08

Aggregate Coverage: Meets

VMware vDefend (Meets)

VMware vDefend provides network intrusion detection and prevention capabilities that directly address this control. vDefend with Advanced Threat Prevention combines multiple detection technologies, including Intrusion Detection/Prevention System (IDS/IPS), Network Detection and Response (NDR), and Network Traffic Analysis (NTA), with aggregation, correlation, and context engines to detect and prevent network intrusions.

vDefend Distributed IDS/IPS operates at the hypervisor level, inspecting both north-south and east-west traffic.

Administrators configure and manage intrusion detection and prevention policies through the NSX Manager interface, where they create IDS/IPS profiles, organize signature-based detection policies, and apply them through distributed firewall rules. The distributed architecture places IDS/IPS inspection at the vNIC level on every protected workload, providing visibility into lateral traffic between VMs that traditional perimeter-based NIDS/NIPS cannot see. IDS/IPS can be deployed in Detect Only mode or in Detect and Prevent mode, giving administrators control over enforcement posture.

Signature management is automated. vDefend IDS/IPS downloads the latest intrusion detection signatures automatically, either directly from the Internet or through a proxy server. Signatures are bundled with custom detection logic that can be updated without recompiling or modifying the IDS engine itself, allowing signature updates to take effect immediately. System Signatures are managed through the Local Manager interface under Security > IDS/IPS & Malware Prevention > Signature Management > System Signatures. When building IDS/IPS profiles, administrators filter included signatures by Intrusion Severities, Attack Types, CVSS scores, Attack Targets, and Products Affected, allowing precise tuning of the detection scope. Administrators can also configure thresholds for individual signatures to control how frequently a signature generates an IPS event, and rate filters that dynamically adjust a rule's action when specific traffic conditions are met. Profiles can also enable packet capture for later analysis of matched traffic.

Beyond automatic signature bundles, administrators can create custom signatures to detect malicious traffic specific to custom applications or to address zero-day vulnerabilities. Custom signatures support specific alert conditions, content matching, thresholds, and metadata, and can be included in IDS/IPS profiles applied to both the Distributed Firewall and Gateway Firewall. In multi-site environments, custom signatures can be managed from Global Manager. Network Detection and Response also consumes IDPS detections generated from custom IDS signatures, surfacing them alongside other detection events within the NDR interface.

NDR extends detection beyond signature matching. Network Detection and Response detects IDS events through signature matches against network traffic in the protected network and integrates with Distributed IDS/IPS to display IDS event details within the NDR interface. NDR Sensor IDS monitors network traffic for suspicious activities or known threat signatures, alerting on potential security breaches. NDR Sensor IDS Packet Capture records raw network packets associated with detected intrusion events, supporting forensic analysis and incident response.

Security Intelligence provides operational visibility into intrusion activity. Intrusion history can be filtered by action, attacker IP, attacker port, PCAP UUID, profile, rule, target IP, target port, and detection location. The IDS/IPS monitoring dashboard allows filtering of intrusion events by multiple criteria to support security event triage and analysis. Per-workload visibility includes impact scoring, signature details, and detection status for each protected VM. Each intrusion event is tagged with a Signature ID and associated protocol information, supporting precise identification and correlation during incident analysis.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to network intrusion detection and prevention at the application delivery layer through IP Reputation-based threat classification, automated DDoS detection and response, bot management, and an Application Rules service.

The IP Reputation service classifies source IP addresses across a wide range of threat categories, including DoS and DDoS attack sources, malware-infected hosts, phishing sites, proxy services, network scanners, and botnets. When an IP address falls into a relevant threat category, administrators configure Network Security Policies on virtual services to identify and block connections from those addresses. Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, including dropping TCP SYN packets from flagged addresses. Shared IP groups allow a single blocklist to be referenced across multiple virtual service policies, so a flagged address can be blocked consistently across the application delivery tier.

For volumetric and protocol attacks, Avi Service Engines detect and mitigate DDoS attacks across Layer 4 through Layer 7, including DNS amplification attacks, DNS Reflection Ingress attacks, and NXDOMAIN attacks. Avi can also report or actively block attackers performing port scans as part of DDoS detection. DDoS attack mitigation mechanisms support IPv6 addresses, including mitigation for Neighbor Discovery Protocol (NDP) attacks. The Avi Controller monitors denial-of-service attack events with configurable alert levels and thresholds, tracking attack count metrics and generating alerts at configurable severity levels. When a SYN flood or other volumetric attack is detected, alert actions can automatically invoke ControlScripts that add the offending source IP address to a blocklist IP group attached to a network security policy, providing automated blocking in response to detected attack events. The Avi Security Manager creates network security rules and DNS rules for Service Engines to block the attacker's IP address, source port, and DNS record request types.

The Application Rules service, available through Avi Cloud Console, provides automatically updated rules specifically designed to block attacks on known application vulnerabilities, including those with published CVE identifiers. These rules extend the detection and prevention surface to application-layer attack patterns beyond IP reputation filtering.

The Bot Management capability identifies bot traffic intent, distinguishing benign bots from malicious actors such as scrapers, spam sources, click fraud engines, bot impersonators, and botnets. The IP Reputation service is also used as a source for bot detection and classification, combining IP-reputation detection, user-agent detection, and IP-location detection through the Bot Decision Component.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) supports L4 Rule CRDs that express custom security policies applied to virtual service traffic, specifying configuration for DDoS attack detection and mitigation. These CRDs can also allow, deny, or rate-limit connections from individual or grouped IP addresses. HostRule CRDs can reference network security policy objects for consistent policy application across ingress resources.

These capabilities address intrusion detection and prevention at the application ingress path. Network-layer intrusion detection and prevention covering east-west and north-south traffic flows across the broader VCF environment is provided by VMware vDefend with IDS/IPS capabilities, which is a separate product and carries the Meets rating for this control. Full satisfaction of the control requires NIDS/NIPS deployment at multiple network layers.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.9

> Deploy Port-Level Access Control

SCF Controls: AST-02.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF does not include a dedicated Network Access Control (NAC) solution, but NSX, VCF Operations, and VCF Automation provide several capabilities that contribute to detecting and restricting unauthorized devices on the virtual network.

NSX SpoofGuard is the primary mechanism for enforcing device identity at the network layer. SpoofGuard maintains a reference table of VM names, MAC addresses, and IP addresses, and blocks traffic from devices whose source addresses do not match the expected bindings on the corresponding logical port or segment. It can operate in MAC-only mode (authenticating MAC addresses) or IP mode (authenticating both MAC and IP addresses). SpoofGuard can be configured at the port or segment level through segment profiles. If a virtual machine's IP address does not match the IP address on the corresponding logical port and segment address binding, the virtual machine's vNIC is prevented from accessing the network entirely. This behavior flags unauthorized address changes instead of letting them pass silently. NSX also drops forged MAC packets by default when the source MAC of a packet differs from the MAC of the virtual machine adapter, and host transport node statistics track the count of these forged transmit drops for visibility. The MAC Discovery segment profile controls MAC learning behavior, and the recommended practice is to enable SpoofGuard alongside MAC learning for stronger address validation.

VCF Operations provides a Network Auto Discovery feature that scans defined IP address ranges to discover devices on the network. The discovery process supports SSH, SNMP v2/v3, and API credential types for accessing discovered devices. Discovered devices are categorized by status: devices that cannot be added as data sources are placed in an Excluded status, and devices with problems that need remediation are flagged with a Needs Attention status. Excluded devices can later be removed from the excluded list and added as data sources if they are determined to be authorized. VCF Operations also supports intent-based detection of default manufacturer passwords on discovered network devices, flagging devices that still have factory credentials.

The Management Pack for Network Devices extends this visibility by collecting Connected IP Addresses and IP Address information from network devices. It also tracks incoming unknown protocols on interfaces, counting packets or transmission units discarded due to unknown or unsupported protocols, which can help identify unauthorized or misconfigured devices attempting to communicate. The Management Pack retrieves system description information including hardware type, software operating system, and networking software for managed entities, and reports manufacturer name information for physical components.

For network segmentation and isolation, NSX supports VLAN-based segmentation, private VLANs (PVLAN) on distributed virtual switches, and overlay-based segments. VPC subnets can be configured with Private, Public, or Isolated access modes to control traffic flow between segments. NSX Manager enforces approved authorizations for controlling the flow of management information within the network based on information flow control policies. Network profiles in VCF Automation support isolation by subnet, external subnet, security groups, or VLAN transport zone, giving administrators control over which networks workloads can reach. These segmentation controls limit the reach of any unauthorized device that gains network access, even in the absence of a traditional NAC enforcement point.

VCF Automation provides a denylist of internal hosts through the `/cloudapi/1.0.0/testConnection/restrictions` API endpoint. This restricts connection testing API access to specified hosts, blocking access to sensitive internal resources. vDefend, a separately licensed product, adds a Malicious IP Feed that downloads known malicious IP addresses from the NTICS cloud service; administrators can create groups that include those addresses and configure Distributed Firewall rules to block traffic to or from them.

A full NAC implementation that performs 802.1X port-based authentication, posture assessment, and automated quarantine of non-compliant endpoints requires a dedicated NAC product integrated with the network infrastructure. Organizations

deploying VCF should pair these platform capabilities with such a solution to achieve automated detection and disabling of unauthorized devices at the network access layer. VCF's contributions are at the virtual network layer through address validation, device discovery and status tracking, traffic filtering, and network segmentation.

VMware vDefend (Contributes)

VMware vDefend provides several network-level access control capabilities that contribute to detecting and restricting unauthorized devices on the virtual network, though it is not a dedicated Network Access Control (NAC) solution that performs 802.1X authentication or endpoint posture assessment.

VMware vDefend (DFW) enforces security policy at the vNIC level, meaning every virtual machine's network interface is subject to firewall rules before traffic reaches the virtual switch. Administrators can define rules based on IP sets, MAC sets, security groups, and tags, restricting network access to only those workloads that match authorized criteria. DFW supports both an Allow List strategy, which denies all traffic by default with a Drop action, and a Deny List strategy, which allows all traffic by default, giving administrators control over the default application posture. Role-based access control governs who can create or modify firewall rules, preventing unauthorized changes to security policy. This per-vNIC enforcement acts as a form of network access control: only traffic matching approved policies is permitted, and workloads not covered by an allow rule are blocked.

vDefend Identity Firewall extends this by enabling identity-based access control for both virtual and physical devices. Identity Firewall integrates with Active Directory, allowing administrators to write firewall rules that reference user identities rather than IP addresses alone. For physical devices and Windows virtual machines, Identity Firewall uses event log scraping to associate devices with authenticated user identities. Identity Firewall rules can be applied to both DFW and Gateway Firewall, and on Gateway Firewall they can be applied to tier-0 or tier-1 gateways using Active Directory group membership as a source criterion for access control decisions. Devices that lack proper identity bindings can be denied network access at the firewall layer.

VMware vDefend (GFW) provides North-South traffic control at the perimeter of NSX segments and VPCs. The VPC Security Profile activates GFW policies for VPCs within a project, configurable through the NSX UI or NSX API. For multi-tenant environments, the Transit Gateway Firewall provides centralized policy management, and Enterprise Administrators can deny all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP. This allows administrators to control which devices communicate across network boundaries, contributing to isolation of unauthorized traffic flows.

Network Detection and Response (NDR), part of the vDefend Security Services Platform, collects and presents detection events representing security-relevant activity in the network. NDR supports filtering affected workloads by IP address, CIDR notation, or IP range, enabling operators to identify compromised or suspicious hosts. Network Traffic Analytics (NTA) detectors in the Security Services Platform perform suspicious traffic analysis, and Security Intelligence can be scoped to specific hosts or clusters for targeted traffic data collection. These capabilities support identifying unauthorized or anomalous devices by revealing unexpected traffic patterns.

A dedicated NAC solution that performs 802.1X port-based authentication, device posture assessment, and automated quarantine of non-compliant physical endpoints remains outside vDefend's scope. vDefend's contributions operate at the virtual network layer through identity-aware firewall policy, per-vNIC enforcement, and traffic anomaly detection.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer access control mechanisms that address the NAC requirement within the scope of traffic reaching Avi virtual services.

Avi's Network Security Policies and HTTP Security Policies can discard connections from client IP addresses by referencing a named IP Group called Blocklist. Network Security Policies pointing to IP Groups are the recommended method for implementing network-layer access control lists across Avi virtual services, and they are configurable through the virtual service Rules tab under Network Security in the Controller UI, through the Avi Controller CLI using the `networksecuritypolicy` command, or via the REST API. IP Groups define collections of IP addresses, IP ranges, and IP network prefixes that can be

shared across multiple virtual services. The Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, including blocking traffic by dropping TCP SYN packets from identified bad actors.

Avi adds explicit IP Reputation integration with Network Security Policy. The policy can be configured to deny connection attempts from IP addresses with known bad reputations, and IP Group membership can be updated dynamically via the REST API, enabling integration with external threat intelligence sources to keep blocklists current without manual intervention.

Alert actions in Avi can invoke ControlScripts that automatically add offending client IP addresses to a Blocklist IP Group attached to a network security policy. When Avi detects a SYN flood attack, a triggered ControlScript adds the attacker's IP to the blocklist by configuring network security policy DOS rules with the `NETWORK_SECURITY_POLICY_ACTION_TYPE_DENY` action. Logging can be enabled on these rules by setting the log parameter to True, recording denied traffic for audit purposes.

The Avi WAF supports blocking IP addresses based on Autonomous System Number (ASN) using the `IpToASNumber` transformation in ModSecurity language, allowing broad blocking of traffic from known malicious network ranges at the application layer.

Device-level network admission control for the underlying infrastructure, including detection of unauthorized devices attempting access to compute or storage networks, relies on VCF networking and vDefend. Organizations should configure all available Avi mechanisms in conjunction with the platform-level controls available in VCF and vDefend to address the full scope of this control.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.11

> Tune Security Event Alerting Thresholds

SCF Controls: MON-01.13

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple capabilities for tuning event monitoring technologies, analyzing communication traffic and event patterns, and developing profiles that represent normal operational behavior.

VCF Operations includes both dynamic and static threshold mechanisms for alert generation. Dynamic thresholding is enabled by default and determines threshold values automatically based on analysis of historical data. An alert is generated when observed metrics violate the learned threshold. This capability directly addresses the control's requirement to develop profiles representing common patterns, as the system continuously analyzes historical metrics to establish baseline behavior. Static thresholds are also available, where administrators configure specific metric values and alerts fire when observations exceed or fall below those values. Both threshold types can be added and adjusted through VCF Operations threshold configuration.

Alert definition tuning is a supported workflow in VCF Operations. Administrators can create and refine alert definitions following documented best practices to optimize alert behavior for monitored objects. Alert definitions follow a symptom-based model where administrators define incremental levels of concern. Threshold sensitivity is configurable at the symptom level, and wait cycles can be set to control how quickly alerts fire after symptom conditions are met. Alert definition thresholds should be configured without gaps to maintain continuous alert coverage across the full range of monitored values. For example, administrators should ensure that threshold ranges for related alerts (such as a warning at 50% and a critical at 75%) do not leave gaps that could cause lower-severity alerts to cancel without triggering higher-severity ones. Minimizing unnecessary alerts in VCF Operations is approached by adjusting alert generation parameters rather than suppressing alerts after the fact.

VCF Operations Intelligent Alerts further refine monitoring output by automating alert correlation and filtering. This reduces alert flooding and helps administrators focus on the most significant issues rather than processing large volumes of duplicative alerts from multiple monitoring tools detecting the same problem.

For network traffic analysis and pattern development, VCF Operations Network Operations provides entity metrics through NetFlow Reporter for monitoring network traffic and transmission errors. Flow-based application discovery analyzes traffic patterns and network flows to identify applications in the environment, directly building the traffic profiles this control requires. NSX Live Traffic Analysis monitors traffic at a source or between source and destination, with packet capture to identify packet drops and bad flows between endpoints. VCF Operations for Networks supports search-based alerts that can be configured to detect specific traffic patterns or anomalies, with configurable severity levels of Critical, Moderate, Warning, and Info. The Recommended Firewall Rules API retrieves recommended rules based on flow traffic observed between groups, reflecting analysis of actual communication patterns in the environment. VCF Operations also displays the top firewall rules based on flow traffic, providing visibility into which rules are handling the most network activity.

VCF Operations supports event trend and anomaly analysis through its log analysis capabilities. Administrators can construct queries and view results in the Event Trends tab to analyze log events for trends and anomalies over time. User-defined events from VCF Operations for Networks can be collected as notifications, and VCF Operations can be configured to collect events, tasks, and alarms from VMware vCenter as well as logs from VCF Operations for Networks and VCF Log Management, providing a broad event data set for pattern analysis.

The vCenter alarm infrastructure integrates with events and performance counters, enabling administrators to create alarm definitions with automated responses to threshold violations, security events, and system state changes. VCF PowerCLI supports creating metric-based alarm triggers with the New-AlarmTrigger parameter to define thresholds and conditions for CPU usage and other performance metrics. vCenter can also create alarms to monitor events on vSAN objects, including the cluster, VMware ESX hosts, datastores, networks, and virtual machines. vCenter also includes an event burst filter that

monitors the incoming event stream for identical events occurring over a short period and consolidates repeated occurrences into a single event before storage, reducing noise from event flooding in the event log.

VCF Log Management includes pre-built content packs with dashboards and alerts for VCF components, including NSX environment monitoring. These content packs provide pre-built dashboards, alerts, and queries that administrators can customize to match their environment's specific event patterns and operational norms.

For workloads deployed through VMware Kubernetes Service (VKS) on the VCF platform, Prometheus with Alertmanager is available as a standard package installed in the `tanzu-system-monitoring` namespace. Prometheus collects time-series metrics from cluster components and forwards them to Alertmanager, which handles alert routing, grouping, inhibition, and notification based on configurable rules. Alerting rules are defined via the `prometheus.config.alerting_rules.yml` parameter, and alert routing behavior is governed through the `AlertmanagerConfig` custom resource, which specifies how alerts are grouped, inhibited, and dispatched to external notification targets with configurable group intervals and wait times. Alertmanager is deployed as a `StatefulSet` with 3 replicas for high availability in the `tanzu-system-monitoring` namespace. The `kube-state-metrics` component generates metrics on the state of Kubernetes objects, including pod counts, deployment readiness, and resource saturation, which can drive alerting rules when integrated with Prometheus. Individual cluster components expose instrumentation that supports threshold analysis: the `kube-apiserver` publishes `apiserver_watch_events_total` to track watch event volume by group, resource, and version; the `kubelet` exposes pod lifecycle event metrics including `kubelet_evented_pleg_connection_success_count`; and the Kubernetes scheduler exposes `scheduler_inflight_events` to monitor in-flight scheduling activity. API Priority and Fairness metrics expose data about whether API server configuration is throttling important traffic or processing poorly-behaved workloads, supporting threshold adjustments for API-level load patterns. Kubernetes Event objects record cluster state changes with microsecond-level timestamps and include a series field that captures repeated event occurrences, enabling identification of patterns that warrant alerting rules. The `kubectl events` command supports real-time event streaming via the `--watch` flag and filtering by event type via the `--types` flag. Istio, available as a standard package on VKS clusters, automatically generates metrics, logs, and distributed traces for all service mesh traffic including ingress and egress, providing per-service traffic data that forms the basis for network-level threshold configuration and normal traffic profile development. Native Kubernetes system component traces record the latency of and relationships between operations in the cluster, covering control-plane components such as the API server, kubelet, and scheduler, supplementing Prometheus metrics as a data source for establishing baseline cluster operation patterns and informing control-plane-level threshold configuration. Dynatrace, when deployed on VKS clusters via its operator, automatically instruments applications and infrastructure upon deployment, collecting metrics, logs, and traces to support monitoring profile development.

VCF Automation alert threshold values are set within VCF Operations, centralizing threshold management across the platform.

VMware vDefend (Meets)

VMware vDefend provides multiple mechanisms for tuning event monitoring technologies through traffic and event pattern analysis, spanning IDS/IPS signature management, Network Detection and Response (NDR) detector thresholds, and Network Traffic Analysis (NTA) for suspicious traffic.

vDefend Distributed IDS/IPS includes configurable threshold and rate-limiting controls that let administrators tune how and when alerts fire. Threshold settings define the minimum number of rule matches required before an alert is generated: the IDS/IPS generates an alert only after a rule matches the configured count within a defined time window. Limit thresholds restrict alert volume by generating at most one alert per host within a configurable time period. A combined "Both" threshold type applies thresholding and limiting together, generating a maximum of one alert if a signature triggers a specified number of times within a time window. Custom IDS/IPS signature rules include a ``threshold`` keyword that controls alert frequency directly within the rule syntax, providing per-rule tuning capability when deploying custom detection content. These controls allow administrators to tune IDS/IPS alerting to match their environment's traffic patterns and reduce false positives without losing detection coverage.

Security Services Platform NTA detectors include per-detector threshold values and exclusion lists managed from the Detector Activation tab. Detections falling below the configured threshold are discarded, allowing administrators to tune

detection sensitivity based on their environment's baseline traffic patterns. NTA continuously monitors and analyzes network traffic and flow records using machine learning models and statistical techniques to identify deviations such as protocol misuse and unusual traffic patterns. Each NTA detector maps to a specific MITRE ATT&CK category or technique, providing structured context for tuning decisions.

NDR aggregates detections based on event type, activity type, and detection method, including matching the same IDS signature, helping administrators recognize patterns across multiple detections. Detection events correlate to form campaigns in NDR, allowing administrators to evaluate detection patterns at a higher level rather than responding to individual alerts. The unified event list can be filtered by detection impact score using checkboxes, and by MITRE ATT&CK tactic through histogram visualization, allowing administrators to focus on high-impact events and tune detection rules based on observed severity and tactic distributions. NDR Sensor alarms clear automatically when the triggering metric drops below the threshold. Security Services Platform alarms are categorized by severity (Critical, High, Medium, Informational), providing structured prioritization for alert management.

The Threat Event Monitoring dashboard in vDefend provides visibility into the current state of security issues in the data center, helping security teams understand network activity and identify areas that may require threshold adjustment. NDR integrates with external SIEM platforms including Splunk and VCF Log Management, and supports custom endpoints with configurable headers. NDR sends event logs to the configured SIEM when a detection event occurs, when an existing detection event is updated, or when a new campaign is created, providing real-time visibility into detection activity across the network. This integration allows organizations to incorporate vDefend detection events into broader monitoring workflows where additional tuning and correlation can occur.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable alarm thresholds, event monitoring tools, and integration channels that support alert threshold tuning within the recovery and replication domain.

PNR monitors connections between sites by sending periodic ping requests, logging connection check events to track connectivity health. Resource threshold alarms monitor consumption on the PNR Server host and raise alarms only when configurable resource thresholds are reached, allowing administrators to calibrate alert sensitivity to their operational baseline. PNR alarms can be configured to send email notifications, SNMP traps, or run custom scripts on the VMware vCenter host in response to events, giving administrators flexibility in how threshold violations are communicated. In multi-vCenter environments, PNR displays events from all PNR server instances registered as extensions, providing a unified view for cross-site monitoring.

vSphere Replication supports definition and editing of alarms to alert administrators when specific replication events occur, such as after configuring a virtual machine for replication. Alarms can be tuned to specific event types, and the event log provides a record for identifying patterns. PNR allows users to silence alerts on health findings when warnings or failures are not actionable, reducing noise in active monitoring environments.

The Clean Room Orchestrator adds a dedicated monitoring layer for isolated recovery environments. It maintains a running list of system-generated events and user actions that can be filtered by event category, event severity, or timestamp for monitoring and audit purposes. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. The Clean Room Orchestrator sends email alerts when the status of the orchestrator or connectors changes, such as when status moves from good to warning. It also supports event forwarding to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise SIEM platforms and centralized alerting systems.

VCF Operations extends PNR monitoring into a centralized operations console, providing an advanced alert system that notifies administrators when specific conditions are detected on protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms for tuning event monitoring at the application delivery layer through configurable alert thresholds, severity levels, alert filter sensitivity, and notification throttle controls.

Administrators can create metric-based alert configurations from the Avi Controller, with each alert rule defining threshold values and multiple event conditions combined using logical operators to determine when notifications fire. Alert severity is classified as High, Medium, or Low. This classification governs how alerts are displayed in the Controller UI and how they are forwarded to remote systems.

For resource utilization monitoring, Avi supports dual-threshold tuning through the `watermark_thresholds` parameter in the Service Engine group analytics policy, which defines the threshold level for triggering metric events and alerts, and a corresponding reset threshold that clears the alert once utilization drops below it. These thresholds are adjustable to match the traffic and load patterns observed in a given deployment. The metric-based alert configuration also includes a throttle parameter that sets the minimum time interval between consecutive alert notifications, giving administrators control over notification frequency without sacrificing visibility into persistent conditions.

Alert filter sensitivity can be adjusted to make the system more or less responsive to generating new alerts, allowing operators to reduce noise from routine traffic variations or increase sensitivity during incident response periods.

Alert notifications can be delivered through multiple channels: the local Controller UI, email, syslog, SNMP v2c or SNMPv3 traps, and ControlScript, all configured in the Operations > Notifications page. The Avi Controller supports multiple SNMP servers for alert delivery and can configure SNMP notifications with TLS encryption and strict certificate verification. Custom alert actions can be created to supplement or replace the default system alert actions such as System-Alert-Level-High, allowing organizations to build notification and response workflows tailored to specific traffic patterns and event conditions.

The Service Engine Analytics Anomalies Overlay displays periods of abnormal traffic detection based on moving averages, generating anomaly detection events with timestamps when each anomaly is detected. Granularity is adjustable by changing the time interval. The Config Events Overlay correlates configuration changes such as adding, deleting, or modifying pools, virtual services, or Service Engines with traffic metrics, enabling administrators to identify whether traffic anomalies were caused by configuration modifications and supporting an iterative tuning process.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 14.0

> Security Awareness and Skills Training: Establish and maintain a security awareness program to influence behavior among the workforce to be security conscious and properly skilled to reduce cybersecurity risks to the enterprise.

SCF Controls: SAT-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.1

> Establish and Maintain a Security Awareness Program

SCF Controls: SAT-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.2

> Train Workforce Members to Recognize Social Engineering Attacks

SCF Controls: SAT-02.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.3

> Train Workforce Members on Authentication Best Practices

SCF Controls: SAT-02, SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.4

> Train Workforce on Data Handling Best Practices

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.5

> Train Workforce Members on Causes of Unintentional Data Exposure

SCF Controls: SAT-03.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.6

> Train Workforce Members on Recognizing and Reporting Security Incidents

SCF Controls: SAT-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.7

> Train Workforce on How to Identify and Report if Their EnterpriseAssets are Missing Security Updates

SCF Controls: SAT-02, SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.8

> Train Workforce on the Dangers of Connecting to and Transmitting Enterprise Data Over Insecure Networks

SCF Controls: SAT-02, SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.9

> Conduct Role-Specific Security Awareness and Skills Training

SCF Controls: SAT-03, SAT-03.1, SAT-03.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.0

> Service Provider Management: Develop a process to evaluate service providers who hold sensitive data, or are responsible for an enterprise's critical IT platforms or processes, to ensure these providers are protecting those platforms and data appropriately.

SCF Controls: TPM-01, TPM-05.4, TPM-05.5, TPM-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.1

> Establish and Maintain an Inventory of Service Providers

SCF Controls: TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.2

> Establish and Maintain a Service Provider Management Policy

SCF Controls: RSK-09, TPM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.3

> Classify Service Providers

SCF Controls: TPM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.4

> Ensure Service Provider Contracts Include Security Requirements

SCF Controls: IAO-03.2, PRI-07.1, TPM-03.2, TPM-04, TPM-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of access control, identity federation, tenant isolation, and monitoring to mitigate risks associated with third-party access to infrastructure assets, applications, services, and data.

VCF SSO integrates with federated identity providers through standards-based protocols, supporting SAML 2.0, OIDC, and AD/LDAP as authentication sources. LDAP-based directory services such as Active Directory are supported for identity management across the platform, including NSX Manager, which supports both Active Directory over LDAP and Open LDAP as identity sources. This allows organizations to extend their existing identity governance to VCF rather than maintaining separate credential stores for third-party users.

Role-based access control enforces least-privilege principles across the platform. VCF local accounts support configurable roles such as superAdmin, and VCF Automation assigns host switch-level permissions through the Cloud Administrator group (Cloudadmin role). The administrators role in VCF Operations is restricted to specific users who need access to objects and actions across the entire environment. For Kubernetes workloads, vSphere Supervisor namespaces support role-based access control with EDIT, VIEW, and OWNER roles that grant specific privileges to users or groups. The Namespace Owner/Edit/View role scopes consumers of a vSphere Namespace to provisioning VKS clusters and vSphere Pods using kubectl, while vSphere Administrator and Supervisor Administrator roles have broader access to cluster and namespace resources. This layered role model restricts third-party access to specific workload boundaries.

VCF Automation implements a provider-and-consumer model that separates the operators of services from the organizations that consume them. Partner services from external vendors are integrated through this model, where providers manage services and organizations consume the resulting business outcomes such as self-service provisioning of Kubernetes clusters, databases, and other resources. Service providers control the publication scope of service instances to selected organizations and decide which roles, rights bundles, and UI plug-ins to include when publishing services. Provider Consumption Organizations offer additional administrative capabilities on top of standard organizations, allowing provider administrators to provision workloads while maintaining separation from consumer tenants. This architectural separation limits third-party visibility and access to only the resources they need to operate.

For third-party application integration, VCF Automation supports dedicated service accounts that automate access for third-party applications. Organizations can generate and issue API access tokens that applications use on their behalf, providing a controlled mechanism for programmatic access rather than requiring shared user credentials. The VCF Operations orchestrator presents an open architecture for plugging in external third-party applications, with integration points managed through the platform rather than through direct infrastructure access.

Tenant isolation is enforced through VCF Automation Organizations, which provide secure infrastructure isolation, quotas, and chargeback across multiple tenants. Within each organization, further isolation exists at the project and namespace levels. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through these organizations while network isolation at the NSX segment level restricts lateral movement between tenants. An Enterprise Admin can share resources with projects in a controlled manner, making objects available for consumption only within designated boundaries. App isolation policies in VCF Automation allow deployments that require on-demand security groups to enforce vDefend firewall rules at the application level. Data-in-transit communications default to TLS encryption for platform services.

VCF Operations monitors resource usage and policy compliance across the environment, providing visibility into third-party activity. VCF Operations supports firewall hardening that restricts network access to internal services, limiting the network paths available to third-party integrations. Service Discovery identifies permanent listening TCP ports and established UDP connections, and service discovery dashboards provide ongoing visibility into the services operating in the environment. VCF

also provides capabilities to discover objects that are not compliant with a security standard, supporting ongoing risk identification for configurations affected by third-party access.

VMware Private AI Services (PAIS) provides technical mechanisms that contribute to mitigating risks associated with third-party access to AI-related assets, services, and data. These mechanisms operate at the trust validation, authentication, authorization, and content approval layers.

Trust Establishment for External Integrations

PAIS uses a CA trust bundle to establish secure HTTPS communication with external services and databases. Administrators must import CA trust bundles for the OIDC provider, Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, MCP servers providing tools for agents, and the database server when those entities are not supplied at activation. Without an explicitly configured CA trust bundle, PAIS will not establish connections to those services, so third-party integrations require deliberate administrative action rather than automatic open access. PAIS supports updating certificate content for trusted entities through the same trust bundle mechanism, allowing administrators to refresh trust material as provider certificates change.

Access Control for Services and Data

PAIS access is controlled through OIDC group-based authorization. User accounts must be members of specified authorized groups (configured via the `authorizedGroups` setting) to access the service, and the `oidc-groups-claim` setting controls which OIDC claim is consulted for group identification in the organization namespace. PAIS requires HTTPS-based communication for OIDC provider integration. SharePoint data sources used as Knowledge Base inputs require user name and password authentication, with support limited to SharePoint On-Premises deployments, so the credential and connectivity posture for that integration is explicit rather than implicit.

Harbor Access and Model Storage

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. These controls help administrators scope which users and workloads can push to or pull from a registry used by PAIS.

Model Validation Before Deployment

Before uploading a model to a PAIS Model Gallery, the platform recommends evaluating the model's performance and safety for the intended business use case, including examining inference requests for malicious behavior and performing hands-on functional tests. PAIS guidance directs administrators to distribute models within the organization that have been validated on a Deep Learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. This workflow helps administrators verify third-party or externally sourced models before they become available for production use.

VMware vDefend (Contributes)

VMware vDefend contributes to mitigating risks from third-party access to organizational technology assets, applications, services, and data through network-level access controls, threat detection, and security posture reporting. Identity governance, authentication, and administrative access controls are handled by other VCF components (VMware vCenter, VCF SSO). vDefend enforces the network security boundary that constrains what third parties can reach once they have been granted access.

vDefend enforces microsegmentation policies at the vNIC level, allowing administrators to define granular network access rules that restrict third-party workloads or connections to only the specific application tiers and services they require. Context-aware rules allow policies to incorporate workload-level attributes, limiting the network reach of third-party connections to defined sets of addresses, ports, and protocols. In multi-tenant VCF environments, the VPC Isolation with Essential Services strategy allows enterprise administrators to enforce strict inter-project isolation at the Distributed Firewall level while delegating more granular control to application owners within each project. This architecture is suited to environments where

third-party development teams or external service providers operate within shared infrastructure, because Distributed Firewall policy at the project boundary can be set independently of what individual tenants configure inside their own VPCs.

vDefend provides north-south traffic filtering at the perimeter of logical network segments. Enterprise administrators can enforce isolation between projects by denying inter-project communication except for specified infrastructure protocols, adding an enforcement point for controlling inbound and outbound access from external or third-party networks. This policy layer applies regardless of what routing exists at the NSX level, giving security teams a dedicated control plane for third-party network boundaries.

vDefend IDS/IPS monitors east-west and north-south traffic for malicious activity, detecting exploitation attempts that may arise from compromised third-party connections. Signature rules support storing TLS and SSL certificates on disk for forensic analysis and threat investigation. Custom signature sources, including those derived from cybersecurity advisories, can be deployed to address threats specific to proprietary or custom applications that third parties introduce into the environment.

Security Services Platform Security Segmentation capabilities identify risky application protocols, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, in use across the environment. This flags workloads, including those operated by third parties, that transport data without encryption, and allows administrators to restrict or block them as part of the security baseline. The Security Segmentation Report identifies at-risk workloads across categories including Public Traffic, Obsolete OS, Risky Application Protocols, and Inter VDI Server Connections, providing a structured view of workload-level risk that is directly relevant to understanding the exposure introduced by third-party access. Application monitoring in Security Services Platform surfaces security risks identified across workloads, allowing administrators to take targeted remediation steps against risky or non-compliant third-party workloads.

Security Services Platform certificate management supports importing CA bundles and web proxy certificates to establish trust for external service connections, including those used by the Malware Prevention Service. This controls which external services the platform can reach and provides a configuration point for managing trust relationships with third-party service endpoints.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer mechanisms relevant to protecting sensitive and regulated data in transit at the application delivery tier.

For data in transit, each virtual service that handles encrypted connections is configured with an SSL/TLS profile that specifies the accepted cipher suites and protocol versions. These profiles are configurable per virtual service, allowing organizations to enforce strong cryptographic standards on connections carrying sensitive or regulated data. The System-Secure-HTTP application profile provides an additional layer of protection by enforcing HTTPS, protecting cookies, managing client IP handling, and controlling protocol behavior for HTTP virtual services.

TLS session persistence state is stored in encrypted form at the Service Engine so that session data is not exposed when a client reconnects to a different Service Engine. Communication between Avi Controllers and Service Engines uses encrypted channels.

Avi's Analytics Profile includes a sensitive log profile capability that controls how sensitive data appearing in client requests is handled in application logs. Operators configure this setting to suppress or mask fields that may contain regulated information, reducing the risk of sensitive data being written to log storage in cleartext.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports PKIProfile resources that enable certificate-based authentication and encryption for communication with backend services. The RouteBackendExtension custom resource definition provides backend TLS configuration capability, supporting encryption of traffic between Service Engines and backend servers. The System-Standard SSL Profile can be applied through AKO to enable SSL/TLS re-encryption for backend traffic using modern cipher suites.

The Avi Cloud Console Application Rules service allows organizations to protect applications from known vulnerabilities by enabling managed application security rules on their Avi Controllers.

Fully satisfying this control also requires an organizational data classification program that identifies which data is sensitive or regulated under applicable contracts, maps that data to the application flows handled by Avi virtual services, and verifies that Avi's encryption and logging controls are applied to those flows. Avi provides the technical mechanisms; the organizational program determines how and where they are applied.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.5

> Assess Service Providers

SCF Controls: RSK-09.1, TPM-04, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.6

> Monitor Service Providers

SCF Controls: TPM-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 15.7

> Securely Decommission Service Providers

SCF Controls: PRM-05, PRM-06, PRM-07, TDA-01, TDA-01.1, TPM-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.0

> Application Software Security: Manage the security life cycle of in-house developed, hosted, or acquired software to prevent, detect, and remediate security weaknesses before they can impact the enterprise.

SCF Controls: SEA-01, TDA-01, TDA-06, WEB-07, WEB-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1

> Establish and Maintain a Secure Application Development Process

SCF Controls: SEA-01, SEA-01.1, SEA-02, TDA-02.3, TDA-05, TDA-06, TDA-06.3, TDA-09.6, TDA-16, WEB-07, WEB-08

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several centralized management capabilities that support organization-wide implementation of cybersecurity and data protection controls, though it does not constitute a complete governance, risk, and compliance (GRC) platform on its own.

VCF Automation Organizations offer a centralized structure for access control and resource sharing across the platform. Organization administrators can distribute infrastructure and configure access management to groups within their organizations using the organization management functionality in VCF Automation. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through VCF Automation Organizations while maintaining security through network isolation. The Organization Administrator role can create and manage policies centrally, providing a single point of control for security policy definition and enforcement within the VCF environment. VCF Automation also supports role-based access control through group membership and role assignment management in its Access Control interface.

VCF SSO and the VCF Identity Broker provide centralized authentication and identity management across VCF components. The Identity Broker acts as a centralized authentication source, and VCF SSO integrates with it to manage authentication for VCF instance components. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and provides VCF SSO and centralized management of federated access through unified identity configuration. Role-based access control (RBAC) enforces consistent authorization policies across the stack: vCenter allows fine-grained control over authorization with permissions and roles by associating a role to a user or group on objects in the vCenter object hierarchy, and vSAN similarly supports RBAC and permissions management.

For network security management, NSX Manager provides centralized policy and grouping constructs. Security groups are defined and managed through NSX Manager, and in multi-site deployments, global security groups can be created on an NSX global manager and consumed by associated local managers, enabling consistent group definitions across geographically distributed environments. vDefend policies on Tier-0 and Tier-1 gateways are managed centrally from NSX Manager. For distributed firewall enforcement, microsegmentation, and advanced security policy at the vNIC level between workloads, VMware vDefend is a separate product that extends NSX networking; when deployed, its policies are managed from the same NSX Manager interface. PowerShell cmdlets such as `InvokePatchSecurityPolicyForDomain` are available for programmatic creation of security policies, supporting automation of security policy deployment at scale. The VCF distributed switch includes built-in security controls that help protect network traffic, providing baseline security capabilities that are centrally configured through vCenter.

VCF Operations provides continuous monitoring and operational visibility across the environment. Its configuration management capabilities include scheduled drift detection for vCenter and cluster objects, enabling proactive detection of configuration deviations from the desired state. Administrators can view and compare configuration drifts and identify settings that have changed. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. The VCF Log Management cluster is the central point for log collection, aggregation, and analysis for all VCF instances within a given fleet.

VCF Operations is the lifecycle management layer, coordinating configuration and updates across VCF components from a single management plane. It simplifies provisioning new infrastructure, managing passwords, installing certificates, and patching or upgrading infrastructure components.

An auditor evaluating this control should verify that the organization has designated VCF Automation Organizations as the centralized structure for access control and policy management, that VCF SSO and Identity Broker are configured for

centralized authentication across all components, that NSX Manager security policies are defined and applied consistently across all workload domains, that VCF Operations drift detection is scheduled and monitored, and that VCF Operations is used as the authoritative source for component lifecycle operations. The auditor should also confirm that these VCF-native capabilities are integrated into the organization's broader cybersecurity governance framework, as VCF addresses the technical control implementation layer but does not replace the need for organizational policies, risk management processes, and compliance monitoring tools.

VMware vDefend (Contributes)

VMware vDefend contributes to centralized management of cybersecurity controls by providing a unified management plane for network security policy across the virtualized data center. vDefend's centralized capabilities span firewall policy, intrusion detection and prevention, malware prevention, and traffic analytics, all managed through a single interface or, for multi-site deployments, through Global Manager.

The vDefend distributed firewall (DFW) allows administrators to define, organize, and enforce microsegmentation policies from a central management plane. Policies are organized into pre-defined categories (Infrastructure, Environment, Application) that provide a logical structure for managing large rule sets. Administrators can create security groups based on VM attributes, IP sets, or dynamic criteria, and apply east-west firewall rules to those groups consistently. When rules are published, they are pushed from the management plane to every host in the targeted clusters, so enforcement is uniform across the environment without requiring per-host configuration. For multi-site or federated deployments, NSX Federation Security provides centralized management of security policies across all sites through Global Manager. Distributed and Gateway Firewall policies created from Global Manager are synchronized to Local Managers at each registered site. Administrators can define custom regions within a federated deployment and assign specific Security and Network policies to those regions, enabling policy scoping at geographic or administrative boundaries.

In 9.1, vDefend extends centralized policy management to VPC-scoped workloads in VCF Automation. Five system-defined security strategies are available for VPC security posture: VPC Isolation, VPC Isolation with essential services, VPC External Connectivity, VPC Secure Connection, and NONE. Project Administrators can select a pre-defined security posture that enforces Secure by Default principles, rather than manually configuring firewall rules for individual VPCs. The Distributed Firewall supports Organizations in VCF Automation for multi-tenant policy isolation, and the Organization Admin (Tenant Admin) role holds full access to manage Transit Gateway firewalls, distributed firewalls, and all VPC gateway firewalls within that tenant context.

Distributed IDS/IPS and Malware Prevention are centrally managed. IDS/IPS profiles and signature sets are configured centrally and distributed to hosts, and Distributed Malware Prevention rules follow the same publish model as firewall policies. In multi-site environments, IDS/IPS signature management is centralized through Global Manager, which distributes updates to multiple Local Managers and supports both automatic update and manual version control.

Security Services Platform provides centralized network security analytics and visibility through Security Intelligence, which analyzes traffic flows across the data center and generates policy recommendations, including recommended security policies and security groups, that administrators can review and publish as Distributed Firewall rules. The platform includes segmentation planning tools that help administrators design and implement microsegmentation strategies from a central vantage point. Security Services Platform also extends centralized policy management to bare metal servers, where security policies are defined, propagated, and enforced through the same centralized model as virtualized workloads.

Role-based access control within vDefend and Security Services Platform governs who can perform security operations. Security Services Platform defines five roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, each with differentiated permissions for policy publishing, traffic visualization, and configuration changes. Configuration of Distributed Firewall policies requires explicit DFW Manage/View rights and rights for Groups and Services, so access to centralized policy management is controlled at the permission level.

vDefend's centralized management is scoped to network security controls. Organization-wide centralized management of all cybersecurity and data protection processes, including identity management, compute hardening, compliance tracking, and governance, requires the broader VCF platform and external GRC systems.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates several mechanisms that support secure-by-default configurations, while also requiring administrator action to fully realize those defaults across a deployment.

At the database engine level, DSM applies fixed security settings that cannot be overridden by users. MySQL database instances managed by DSM enforce encrypted connections on both the main connection interface and the administrative connection interface, with the `require_secure_transport` parameter set to ON by default. The parameters controlling transport encryption on these interfaces, including `tls_version`, `admin_tls_version`, and `host_cache_size`, are system-managed; any user-submitted changes are automatically overwritten back to their default values. In DSM, TLS is enforced by default for system users connecting to PostgreSQL databases. Administrators can override this enforcement for system users via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace, but the secure default requires system user connections to use TLS. The `dsm_mgmt` internal management login for SQL Server databases restricts users from accessing or modifying system-level objects, keeping administrative operations in a secure, isolated context.

Data service policies give administrators a structured mechanism to define and enforce consistent security standards across tenants. In DSM, custom database options controls within data service policies expand to three settings: allow all custom parameters, restrict to an approved allowlist, or disallow all custom parameters entirely. The disallow setting blocks users from adding database parameters outside the administrator-defined baseline. These policies can be applied across different tenants through DSM's integration with VCF Automation, supporting uniform standards in multi-tenant deployments. Administrators define and configure data service policies through the DSM UI.

Infrastructure policies set additional guardrails by restricting the quality and quantity of resources that DSM users can consume from vSphere clusters, reducing the risk that databases are provisioned outside defined resource boundaries. Infrastructure policy settings include IP pools, VM class definitions, user permissions, and storage policy selection. Once a policy is in active use by a database, its existing settings cannot be modified, though new compute resources with corresponding parameters can be added. DSM also detects and blocks network address overlap between infrastructure policy IP ranges and system configuration networks.

For in-transit security, DSM requires certificate authority (CA) configuration to establish encrypted connections to database clusters. Organizations can replace the default DSM certificate with a custom certificate through the DSM UI; however, custom certificate configuration on the Provider VM can only be performed on a fresh installation where no data services are deployed. DSM's SMTP notification settings include an Auto TLS option for establishing secure connections to the SMTP server. Administrators should verify that all certificates meet the cryptographic algorithm requirements for DSM, as non-compliant certificates can cause validation errors, service startup failures, or TLS handshake issues after upgrade. For SQL Server database clusters, DSM supports the `network.tlsProtocols` custom engine setting to define the allowed TLS versions for client connections.

DSM Plug-in virtual machine encryption is active only when a Key Management Server is configured in the environment. Deployments without KMS integration do not have Provider Appliance VM encryption active, and administrators should address KMS configuration during initial deployment planning to activate this protection.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer ships in a secured and reasonably locked down state by default, establishing a security baseline at the application delivery and load balancing layer before administrators apply further customization.

For application TLS termination, new virtual services created through basic mode automatically use the default system SSL/TLS profile. The Standard SSL/TLS Profile is included with the system and designed for typical deployments. Default system SSL/TLS profiles can be modified but not deleted, preserving a known secure baseline. The HTTP application profile's Security tab controls security settings for HTTP applications associated with the profile, and those settings can be supplemented with more granular configuration through policies or DataScripts. The built-in System-Secure-HTTP application profile enforces HTTPS, protects cookies, manages client IPs, and controls protocol behavior for L7 virtual services.

For Controller and Service Engine secure channel communications, the system uses System-Default-Secure-Channel-Cert as the default SSL key and certificate reference, configured through the System Settings administration panel. Both the Controller and Service Engine Groups reference this certificate automatically without requiring additional configuration after deployment. Administrators can define a Unique Deployment Password during Controller provisioning to support instance-specific isolation from first boot.

Certificate lifecycle management includes a Let's Encrypt Certificate Management Profile available by default at Controller boot time, configurable with name, tenant, and password. Certificate Management Profiles support custom parameters, including sensitive values such as passwords, that can be marked to prevent display in the web interface or API transmission.

User account security includes a default profile enforcing password and account policies. Administrators can create additional profiles with customized thresholds for organizational requirements. Controller security guidance recommends enforcing strong passwords, restricting administrative access to known source IP address ranges via the allowed-IP-list setting, and applying role-based access controls to limit privilege to the minimum necessary. When Controller deployment is automated, Ansible Vault is recommended for protecting API keys and passwords in deployment scripts.

The WAF layer includes Application Rules designed for straightforward deployment. In Avi, Positive Security configuration has moved from the WAF Policy to Virtual Service > Positive Security Policy, providing more granular per-service control over application security posture.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports securityContext and podSecurityContext settings that apply security configuration to the AKO pod from deployment. The podSecurityContext can be tuned via the AKO tunables configuration to meet organizational security requirements for the operator component.

Hardening of the underlying compute, storage, and network fabric depends on VCF platform controls addressed in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 16.2

> Establish and Maintain a Process to Accept and Address Software Vulnerabilities

SCF Controls: TDA-04.2, TDA-06.2, TDA-06.5, TDA-09, TDA-09.1, TDA-15, THR-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.3

> Perform Root Cause Analysis on Security Vulnerabilities

SCF Controls: IRO-13, TDA-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.4

> Establish and Manage an Inventory of Third-Party Software Components

SCF Controls: TDA-02, TDA-02.1, TDA-02.5, TDA-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.5

> Use Up-to-Date and Trusted Third-Party Software Components

SCF Controls: AST-03.2, TDA-06, TDA-06.3, TDA-11, TDA-14.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple integrity verification mechanisms for software and firmware components across the platform stack, spanning hardware trust, software lifecycle management, containerized workload registries, and ongoing drift detection.

At the firmware level, ESX hosts support UEFI Secure Boot and Trusted Platform Module (TPM). Secure Boot verifies that each component loaded during the boot process is digitally signed, restricting execution to authorized firmware and drivers. TPM provides hardware-based measurement of boot-time components, and administrators can retrieve the TPM event log for configuring firmware trust with an attestation service or validating boot-time TPM measurements. vCenter provides programmatic access to host hardware TPM information and endorsement keys through the Trusted Infrastructure API, and supports unsealing secrets bound to endorsement keys to verify reported TPM measurements. The Security Configuration Guide recommends enabling both Secure Boot and TPM as part of ESX host hardening. Virtual machines can also be configured with UEFI Secure Boot to verify the integrity of firmware and bootloader code before execution, and a virtual TPM (vTPM) device can be added to a VM to perform cryptographic operations and attest the VM platform's integrity.

Hardware and firmware compatibility is enforced through certification requirements. Storage I/O controllers, drivers, and firmware versions must be certified and listed in the Broadcom Compatibility Guide. ESX driver and firmware versions should be verified for hardware compatibility, as mismatches can affect performance and stability. The vSAN hardware compatibility health checks verify deployed hardware against the Broadcom Compatibility Guide to identify unsupported or outdated firmware. VCF requires certified software and hardware components, drivers, controllers, and firmware to avoid unexpected data loss and performance issues.

For software integrity during deployment, the VCF Installer downloads and validates binaries after selection to confirm integrity before they are applied to the environment. VCF also requires verification of the server fingerprint for each ESX host during commissioning, with fingerprint confirmation activated before host validation proceeds. All communication between the VCF Installer and ESX hosts is performed over HTTPS, validating identity by comparing the common name of the certificate against the FQDN provided in the deployment wizard. The VCF CLI binary can be verified using a sha256sum.txt checksum file available alongside the CLI download or from the VCF Automation Tenant Portal, providing an integrity check for the tooling used to manage VCF Services consumption.

vSphere Lifecycle Manager manages software component lifecycle through structured payloads that encapsulate groups of components for coordinated management. It validates host compliance against a desired-state software specification, allowing administrators to check whether hosts in a cluster match the intended configuration before applying updates. The Drafts service offers a `validate_Task` method that checks whether a draft software specification is complete and whether there are conflicts between components or unresolved dependencies. The `Invoke-CheckHostSoftwareAsync` PowerCLI cmdlet performs remediation pre-checks on hosts to verify software and hardware compatibility with a desired software specification before remediation proceeds. ESX also enforces software integrity at the package level through the Host Image Profile Acceptance Level: each vSphere Installation Bundle (VIB) has an associated acceptance level, and ESX conducts integrity checks to confirm that only packages meeting the configured acceptance threshold are permitted to install on the host.

At the data layer, vSAN uses end-to-end checksums to verify data integrity, confirming that each copy of a file matches the source. When a checksum mismatch is detected, vSAN automatically repairs the data by overwriting the incorrect copy with the correct data.

For containerized workloads, VKS clusters require internal or trusted CA certificates for local registries, and VKS Cluster Management image registry policies restrict the source registries from which images can be pulled. The VCF CLI `imgpkg` command supports adding CA certificates for registry API validation through the `--registry-ca-cert-path` flag, and image pull secrets authenticate to container registries before pulling images. Harbor, available as a standard package on VMware

Kubernetes Service (VKS) clusters, provides vulnerability scanning, content trust, and policy-based replication for software supply chain security. Harbor secures artifacts with policies and role-based access control, allowing platform teams to define which images are trusted and restrict deployment of content that has not been scanned or signed. Kubernetes admission controllers can automatically verify image signatures at deploy time to validate the authenticity and integrity of container images before a workload is permitted to run in a vSphere namespace; organizations can deploy admission webhooks that block unsigned images from being scheduled on VKS cluster namespaces. Kubernetes release artifacts, including the platform Software Bill of Materials (SBOM), can be verified using SHA512 and SHA256 checksums together with sigstore certificate and signature files available from sbom.k8s.io, allowing platform administrators to confirm the integrity of Kubernetes components. Security Technical Implementation Guides (STIGs) for system components, including vSphere Supervisor and VKS Kubernetes releases (VKrs), are available through Tanzu STIG hardening to guide integrity-related configuration of the consumption layer.

Ongoing integrity monitoring is provided through VCF Operations, which runs property-based signature checks every four hours. These checks scan VMware vCenter, ESX, NSX, VCF Operations, vSAN, and VCF Automation to detect configuration drift or unauthorized changes across the SDDC stack. VCF Operations also provides scheduled drift detection for vCenter and cluster objects, enabling proactive detection of configuration deviations from the desired state.

VMware Private AI Services (PAIS) provides a structured validation workflow for ML models that gives the AI platform a technical mechanism for software integrity verification within its scope.

The Model Gallery workflow requires MLOps engineers to validate ML models against the security, privacy, and technical requirements of the organization before those models can be uploaded to a Model Gallery for use by AI application developers. Integrity validation is performed in a Deep Learning VM (DL VM) acting as a sandbox. The process checks the hash code of model files, scans them for malware, scans them for serialization attacks, and tests correct inference behavior using Triton Inference Server before upload. Only models that pass these checks are admitted to the gallery. The Model Gallery itself helps maintain integrity of uploaded models by assigning a unique digest to each revision when the same model is pushed multiple times, which allows administrators to identify specific model versions across re-uploads.

PAIS Model Runtime endpoints reference model container images through the `spec.model.ociRef` property in the ModelEndpoint specification and support image pull secrets for private OCI registries that require authentication. PAIS requires CA trust bundles to be imported for the Private Harbor registry, for content management systems used as data sources in Data Indexing and Retrieval, and for MCP servers providing tools for agents. These trust bundles allow PAIS to verify the identity of the systems serving model and tool artifacts during pulls and tool invocations.

For agentic workflows that use the Model Context Protocol (MCP), PAIS requires examination and approval of MCP server tool capabilities and parameters before use in agents to confirm suitability against organizational security standards. This extends integrity verification to the tool layer of AI applications built on the platform.

Auditors reviewing a PAIS deployment should look for evidence that the validation workflow is being followed: confirmation that MLOps engineers are performing hash verification, malware scanning, serialization attack scanning, and Triton inference testing before model uploads, that Model Gallery revisions carry unique digests, that CA trust bundles are imported for the Private Harbor registry and MCP servers, and that the MCP tool approval step is documented against the organization's defined security and privacy requirements.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.6

> Establish and Maintain a Severity Rating System and Process for Application Vulnerabilities

SCF Controls: RSK-01, RSK-01.1, RSK-02, RSK-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.7

> Use Standard Hardening Configuration Templates for Application Infrastructure

SCF Controls: CFG-02, CFG-02.5, TDA-06.5, TDA-12, WEB-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 16.8

> Separate Production and Non-Production Systems

SCF Controls: TDA-07, TDA-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support the separation of development, testing, and operational environments, though the organizational policies and governance processes that define environment boundaries and enforce segregation must be established independently.

VCF workload domains provide infrastructure-level separation, allowing administrators to deploy distinct domains for development, testing, and production workloads with independent compute, storage, and networking configurations. Each workload domain operates with its own resource boundaries and management policies, and configuration settings appropriate for one environment tier may differ from those used in another. VCF documentation explicitly notes that configuration appropriate for development environments may not be suitable for production environments within the same deployment.

VCF Operations includes an environment classification feature that allows administrators to tag Business Application environments as Development, Production, Staging, Test, or DR. This classification enables differentiated monitoring and management across environment tiers. Administrators can configure custom groups with distinct alert policies and capacity calculations for production environments versus testing environments, allowing each tier to operate under monitoring rules appropriate to its purpose. The VM Performance and VM Contention dashboards note that development environments can tolerate a small amount of contention in CPU and memory, while production environments should not, reinforcing the need for distinct operational treatment per environment.

VCF Automation provides organizational and project-level isolation boundaries that map naturally to environment separation. Each organization in VCF Automation operates in an isolated environment with dedicated network setup and network isolation, where users can access only allocated services and resources. Within an organization, projects create additional isolation boundaries between teams, and namespace-level isolation adds a further layer of separation. Security groups and vDefend firewall rules support network isolation between project environments. When stronger isolation is required between environment tiers, multiple projects or organizations can be used; when isolation requirements are lower, fewer projects simplify the operating model. These constructs give administrators the building blocks to enforce separation between development, testing, and production workloads.

NSX Projects enable isolation of networking and security configurations for multiple departments or organizational units within a single NSX deployment, allowing network-level separation between environment tiers. NSX multi-tenancy isolates security and networking objects across tenants, supporting the use of separate tenant configurations for development, testing, and production environments.

vSphere provides workload isolation at multiple levels. Each VM runs as an isolated system protected from interference by other VMs or workloads. Resource pools isolate virtual machine performance from other users of the same pool. Namespaces provide additional isolation for containerized workloads, and administrators can assign different port groups as the network for each namespace, providing layer 2 isolation between namespaces. Cross-namespace communication is blocked unless explicitly permitted. vSphere Auto Deploy requires secure network separation between the production network and the management or deployment networks, making this separation a prerequisite for stateless or stateful ESX host provisioning workflows.

The VCF CLI supports context-based environment switching, enabling administrators to move between local development, staging, and production clusters without requiring constant configuration updates. This helps maintain clear boundaries between environments during day-to-day operations and reduces the risk of accidental changes to production systems.

VCF also supports a test-before-production discipline across several components. VCF Operations allows test runs before final deployment to verify that management packs collect correct data and accurately represent the target system. The

documentation recommends testing newly created configuration files for the Management Pack for Aggregator with a test instance before applying them to production systems. For VM-based workloads on vSphere Supervisors, administrators are directed to create production images with the latest patches and required security settings that follow corporate security policies, establishing a controlled promotion path from development to production. Administrators can also configure more restrictive VIB acceptance levels for ESX hosts in production than for hosts in testing environments, limiting which software packages can be installed on production infrastructure.

vSphere administrators set guardrails for the policy and governance of VMs, delivering VM resources such as VM classes and VM templates to DevOps engineers. This separation of administrative and consumer roles restricts who can modify production infrastructure versus who can consume resources in development or testing namespaces.

Defining which environments are designated as development, testing, or production, establishing access policies for each, and managing the lifecycle of changes across those environments requires organizational processes beyond what VCF provides. VCF supplies the isolation mechanisms and classification tools; the organization must define the policies that govern how those mechanisms are used.

VMware vDefend (Contributes)

VMware vDefend provides network-level enforcement mechanisms that support separating development, testing, and operational environments, reducing the risk of unauthorized access or cross-environment changes.

The Distributed Firewall enables environment isolation through microsegmentation, dividing the data center into broader security zones such as production, development, testing, and PCI environments. Distributed Firewall rules are enforced at the vNIC level, so environment boundaries are maintained even when workloads from different environments share the same physical hosts or network segments. The Gateway Firewall in vDefend can enforce isolation between projects by denying all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, while permitting internal team communication within isolated development virtual private clouds.

Security Services Platform provides purpose-built tools for defining environment hierarchies and configuring segmentation policies. Administrators define environments by specifying which virtual machines, IP addresses, distributed virtual port groups, and network segments belong to each environment using CSV files, which Security Intelligence uses to create groups and apply appropriate tags. When implementing environment pair controls, the recommended approach is to apply a broad block policy between sensitive pairs such as Testing and Production as an initial step, then identify all inter-environment flows and add specific policies before enforcing a strict block. Security Intelligence administrators can monitor traffic leakage between environments, establish permitted exceptions, and apply lockdown protection rules to control inter-environment traffic.

The Security Segmentation Score provides a quantitative view of segmentation coverage. The Environment Protection component evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test, contributing five points to the overall score. The security segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies. The Environments monitoring window shows the total number of inter-environment pairs and how many are without inter-environment policies. Segmentation Planning supports the design phase by allowing administrators to publish environments together with related applications to maintain proper correlation between them. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy, including regions, zones, and virtual machines, to verify that the environment hierarchy is correctly defined before enforcement begins.

For Virtual Desktop Infrastructure deployments, Security Services Platform recommends isolating VDI servers from server-based traffic patterns and preventing separate VDI environments from communicating with one another.

Defining which workloads belong to which environment, determining which environment pairs may communicate, and managing the lifecycle of configuration changes across environments require organizational processes and decisions that vDefend does not govern. vDefend enforces the network boundaries once those decisions are made.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms at the application delivery layer to support separation between development, testing, and operational environments. The primary isolation mechanism is Avi's multi-tenant architecture: a single Avi Controller cluster can host each environment in a dedicated tenant with RBAC-enforced access boundaries, or organizations can deploy separate Controller clusters per environment. Controller cluster topology supports this separation; each Controller cluster can be configured as a one-node cluster for development and testing, or a three-node cluster for production, giving organizations a clear infrastructure-level distinction between environment tiers.

Within a single-cluster deployment, Avi's tenant model provides administrative isolation, scoping visibility and access to objects within tenant boundaries. Service Engine Groups provide data-plane isolation: virtual services for test and production environments should be deployed on different Service Engine Groups, so application traffic from test workloads is handled by different data-plane VMs than production traffic, reducing the risk of cross-environment data flows. An administrator can deploy virtual services for the same application in both test and production environments on different Service Engine Groups within the same tenant, or across separate tenants for stronger isolation.

In 9.1, the Avi for VCF integration adds dedicated environment isolation constructs. Service Engine Group allocation within VCF Automation blueprints for Layer 4 and Layer 7 virtual services provides operational isolation, keeping each project within its designated boundaries. Namespace allocation in the Avi Controller similarly scopes each project's resources. In Organization-Managed Mode, organization administrators manage their own Service Engine Group configurations and infrastructure settings, reinforcing the organizational boundary between environment owners. VCF Automation integration supports infrastructure-as-code workflows, which can be used to apply consistent environment configurations across development, testing, and production tiers.

Service Engine deployments using dedicated management mode provide network isolation between data and management traffic, separating the management plane from application traffic paths.

Organizations should define which Avi tenants map to which environments, establish RBAC policies that restrict personnel from operating across environment boundaries, and configure distinct Service Engine Groups for each tier. The Avi Controller's configuration audit log supports review of whether environment boundaries have been respected during configuration changes.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.9

> Train Developers in Application Security Concepts and Secure Coding

SCF Controls: SAT-03, SAT-03.8

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.11

> Leverage Vetted Modules or Services for ApplicationSecurity Components

SCF Controls: TDA-06, TDA-06.3, TDA-12, TDA-14, TDA-14.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.12

> Implement Code-Level Security Checks

SCF Controls: TDA-06.5, TDA-09, TDA-09.2, TDA-09.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.13

> Conduct Application Penetration Testing

SCF Controls: TDA-09.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.14

> Conduct Threat Modeling

SCF Controls: TDA-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.0

> Incident Response Management: Establish a program to develop and maintain an incident response capability (e.g., policies, plans, procedures, defined roles, training, and communications) to prepare, detect, and quickly respond to an attack.

SCF Controls: IRO-01, IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 17.1

> Designate Personnel to Manage Incident Handling

SCF Controls: IRO-02, IRO-04, IRO-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.2

> Establish and Maintain Contact Information for Reporting Security Incidents

SCF Controls: IRO-09, IRO-10, IRO-10.2, IRO-10.3, IRO-10.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides detection, monitoring, alerting, notification delivery, and investigation capabilities through VCF Operations that support timely identification and reporting of incidents involving sensitive or regulated data. While the organizational process of formally reporting such incidents to regulators, affected individuals, or other stakeholders falls outside the platform's scope, VCF supplies the technical foundation that enables an organization to detect incidents quickly, gather evidence, and route information to the people and systems responsible for response.

VCF Operations event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces suspicious access events and policy violations. This capability allows security teams to identify unauthorized or anomalous activity that may indicate a data incident. VCF Operations also provides audit tracking that identifies who made changes to the data center during a specific time range, which is important for establishing the scope and timeline of an incident involving sensitive data.

VCF Operations compliance management continuously monitors infrastructure by evaluating collected data against defined policies. When a compliance alert is triggered on VMware vCenter instances, VMware ESX hosts, virtual machines, distributed port groups, or distributed switches, compliance violations are recorded for investigation. This automated detection of deviations from compliance baselines helps organizations identify potential data-related incidents as they occur rather than discovering them after the fact. Compliance management also highlights risk areas and provides actionable remediation recommendations, supporting the triage process that precedes formal incident reporting.

VCF Operations generates alerts based on configurable thresholds and event definitions. When an alert fires, VCF Operations can deliver notifications through multiple outbound channels: SNMP traps to network management platforms, webhook calls to REST-enabled systems (in JSON or XML format), a ServiceNow plug-in that automatically creates incidents in the ServiceNow ticketing system, a Slack plug-in that forwards alerts to Slack channels with links to alert details, and email. Notification rules let administrators filter which alerts are forwarded and to which endpoints, so that events potentially involving data exposure reach the right teams without delay.

All VCF components support syslog forwarding to external log aggregation and SIEM platforms. vCenter syslog forwarding can be configured through the vCenter Management API, and ESX hosts send syslog feeds through Log Collections configuration. VCF Log Management ingests and indexes these events from across the stack, providing real-time analytics to search and filter logs instantly for troubleshooting or auditing. Users can collect and analyze log feeds, view log-related metrics, and dynamically extract fields from log messages based on customized queries. This centralized log management gives security operations teams the ability to correlate events across the environment.

Accurate log correlation depends on synchronized clocks across all components. The vSphere documentation notes that incorrect time settings in vCenter and ESX hosts make it difficult to inspect and correlate log files to detect attacks and render auditing inaccurate; NTP should be configured on all vCenter instances and ESX hosts so that log timestamps are reliable for incident investigation and reporting.

The Diagnostic Findings feature provides a consolidated view of known product issues, VMSA-based security exposures, and industry best-practice recommendations across the VCF environment. Diagnostic Findings are alerts without notifications that result from a scan of the platform against known issues, logs, and properties. This provides an additional signal that may be relevant during incident triage, helping teams determine whether an observed event is related to a known vulnerability.

For incident tracking and investigation, VCF Operations provides capabilities at multiple levels. The Troubleshooting Incident Page in VCF Network Operations displays information related to incidents, including status, root cause metrics, closing remarks, and timestamps for when incidents were created. During investigation, analysts can flag metrics and mark root

causes, creating a documented trail that supports the incident reporting process. Incident status can be tracked as resolved or unresolved within the platform. VCF Operations also supports scheduled automated reports at regular intervals to track current resources and identify potential risks to the environment, which can feed an organization's incident reporting workflow.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, giving organizations awareness of the state of their data protection posture. VCF Automation includes data compliance controls that require explicit consent before exposing user names. This supports organizations that must track access to personally identifiable information.

To satisfy this control fully, organizations must establish incident response procedures that define reporting timelines, designate responsible personnel, identify the authorities and regulators to notify, and specify the content and format of incident reports. VCF provides the detection, correlation, notification delivery, and evidence-gathering layer, but the reporting process itself requires organizational policies, communication channels, and human decision-making.

VMware vDefend (Contributes)

VMware vDefend provides network-layer situational awareness capabilities that contribute to documenting, monitoring, and reporting the status of cybersecurity incidents through their lifecycle.

Security Intelligence is the primary situational awareness engine within vDefend. It detects and categorizes suspicious traffic events by severity (Critical, High, Medium, and Low) and maps them to MITRE ATT&CK tactics and techniques, giving incident responders a structured understanding of what is occurring on the network and how it relates to known attack patterns. The Monitor & Plan Overview dashboard in Security Intelligence displays high-level information about the most recent state of network activities and objects under management, providing operators with a current picture of the environment. Security Intelligence supports detection and display of tactics and techniques from the ATT&CK framework, showing the number of detected suspicious events that used each tactic or technique during the selected time period. Security teams can compare the ratio of detected versus prevented events to assess how effectively security controls are containing activity, and the Threat Event Monitoring tab provides key insights about the current state of various security issues in the data center to help security teams understand network activity and prioritize focus areas. The IDS/IPS threat event monitoring page displays summaries for the last 14 days.

The Security Explorer Computes view provides a record of all IDS/IPS events for in-depth analysis over a 30-day timeframe, giving teams the historical context needed to understand incident progression. The View Full Event History capability displays all events associated with a specific signature ID and intrusion severity, supporting focused investigation of recurring or related events.

Network Detection and Response (NDR) correlates individual detection events into campaigns, providing a higher-level view that connects related events across time and across workloads. Each campaign aggregates correlated threat activity and maps it to different stages of an attack, giving responders a consolidated view of an ongoing incident rather than a stream of disconnected alerts. The Campaign Blueprint tab within Security Services Platform visualizes correlated security events and key actors for security incident investigation. Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

The Security Segmentation Report gives security operations personnel insight into their organization's security posture and supports prioritization of remediation efforts. The report includes an Inter-Environment Pair Protection Rule Action Summary that provides a tabular summary of inter-environment communications. The Rule Analysis feature generates downloadable CSV reports of the last successful analysis, with separate CSV files for each detected anomaly type, providing exportable documentation of security findings. Alarms notify of all open conditions categorized by severity (Critical, High, Medium, and Informational) to flag conditions requiring attention. The Security Services Platform defines a dedicated Security Operator role that monitors security systems and responds to security incidents, providing a role-based access model for incident response functions.

These capabilities provide the network security dimension of incident situational awareness: detecting threats, categorizing their severity, mapping them to attack frameworks, correlating events into campaigns, and maintaining historical records.

However, vDefend does not manage the organizational processes of notifying stakeholders, assigning incident ownership, tracking resolution status through a ticketing system, or producing management reports on incident posture. Those responsibilities require organizational incident management procedures and dedicated ITSM or SOAR tooling.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supplies mechanisms that help internal stakeholders track the status of cyber recovery operations and protection-related incidents through to resolution. The PNR appliance records operational information into log files, and the platform logs events with corresponding alarms to track system health and surface issues before they affect protection. The Alarms list maintains a history of all notifications that require attention, with search and filtering by severity.

The Clean Room Orchestrator is the primary surface for incident situational awareness during ransomware recovery operations. Events carry severity levels of Info, Warning, Error, and Emergency, and a global view shows the collection of clean room events, tasks, and alarms across recovery operations. PNR supports configuration of email alerts for critical events in the clean room orchestrator so that designated recipients receive notification of important recovery operations and system events.

Cyber Recovery, the ransomware recovery capability within PNR, integrates with Carbon Black and CrowdStrike for security and vulnerability analysis during ransomware recovery. CrowdStrike-integrated detection records include date, time, duration, status, the affected process or executable, the user who performed the action, and the threat tactic and technique. CrowdScore for Incident Detections measures real-time threat level on a scale of 0 to 100, with a score of 100 indicating a critical threat that calls for immediate attention. Vulnerabilities are presented with their Common Vulnerabilities and Exposures (CVE) identifiers and links to articles in the National Institute of Standards and Technology (NIST) database. Carbon Black behavior analysis results appear on the Analysis > Alerts tab, and malware scan findings are displayed in the Alerts tab ranked by severity score. Cyber Recovery also maintains a history log for reprotect operations that can be exported as a report to verify the reprotection process.

Snapshot badging provides a documented audit trail of snapshot validation, marking snapshots as Verified for clean snapshots, Compromised for malware-confirmed snapshots, or Encrypted for data encryption findings. The Protection and Recovery Cloud Management Pack integrates with VCF Operations to collect data from a Protection and Recovery Cloud instance, extending incident visibility into the VCF Operations console.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to

be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer visibility and reporting mechanisms that support an organization's incident documentation and status communication processes. The primary reporting tool is the Application Security Report, accessible under Application Monitoring in the Avi Controller UI. This report can be generated per virtual service and downloaded in PDF format, with report generation status visible on the Reports page. It produces a structured summary of WAF findings and pre-check results, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, trend summaries showing total and flagged requests, and overall application security posture. The Application Security Report is designed for security teams, executives, and auditors, providing audit-ready documentation of WAF activity that personnel can distribute to internal stakeholders as part of incident documentation workflows.

Avi generates structured alert events for security-relevant and operational conditions. The Alert feature processes system events and metrics against user-defined rules and generates alerts that initiate configured actions such as sending an email, a syslog message, or an SNMP trap, enabling integration with an organization's broader incident management tooling. Alert configurations define triggers with configurable parameters that determine when alerts fire and what actions follow. Metric-based alerts can be configured with multiple events combined using logical operators against specified thresholds. The Service Engine Analytics Anomalies Overlay generates alerts with a timestamp, a resource name identifying the object reporting the alert, and a severity level of High, Medium, or Low that determines whether additional notification is triggered. Avi also logs denial of service attack events with detailed context including event ID, attack count, threshold values, and alert level.

Avi Controller and Avi Service Engine log audit records for certificate validation failures, client authentication failures, SSH session establishment failures, and identification of initiators and targets of failed trusted channel establishment attempts. These audit records are forwarded to Events, Syslog, and Splunk, providing integration points for an organization's centralized incident monitoring and log aggregation infrastructure.

Avi does not provide an end-to-end incident management and tracking system. Defining incident categories, assigning ownership, tracking status through resolution, communicating updates to internal stakeholders at each stage, and maintaining incident records beyond Avi's application-layer logs and reports are organizational responsibilities. Avi's reporting and alerting capabilities feed the organization's incident management process as inputs alongside other tools and workflows.

Control 17.3

> Establish and Maintain an Enterprise Process for Reporting Incidents

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 17.4

> Establish and Maintain an Incident Response Process

SCF Controls: IRO-02, IRO-04, IRO-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 17.5

> Assign Key Roles and Responsibilities

SCF Controls: IRO-01, IRO-02, IRO-04, IRO-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 17.6

> Define Mechanisms for Communicating During Incident Response

SCF Controls: IRO-02, IRO-04, IRO-07, IRO-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control 17.7

> Conduct Routine Incident Response Exercises

SCF Controls: IRO-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.8

> Conduct Post-Incident Reviews

SCF Controls: IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.9

> Establish and Maintain Security Incident Thresholds

SCF Controls: IRO-02, IRO-04, IRO-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.0

> Penetration Testing: Test the effectiveness and resiliency of enterprise assets through identifying and exploiting weaknesses in controls (people, processes, and technology), and simulating the objectives and actions of an attacker.

SCF Controls: VPM-01, VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.1

> Establish and Maintain a Penetration Testing Program

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.2

> Perform Periodic External Penetration Tests

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.3

> Remediate Penetration Test Findings

SCF Controls: RSK-06, VPM-04, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized software and firmware patching across the entire infrastructure stack through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane. VCF Operations is the central orchestration point for patching and update operations, coordinating patch releases (such as 9.0.1.0100) that deliver time-sensitive fixes to security and operational issues between major, minor, and maintenance releases.

VCF uses a desired-state model for host remediation through vSphere Lifecycle Manager (vLCM). Administrators define a software specification for each cluster, and vLCM brings all hosts into compliance with that specification during remediation. This approach applies uniformly to VMware-supplied components and third-party solutions alike. To make a third-party solution available on a cluster, administrators create a software specification containing the solution and remediate all hosts with that image. vLCM manages software updates for VMware ESX hosts, including patches of the ESX base image, OEM add-ons, components from different software vendors, and VMware Tools updates. Dynamic patch baselines automatically adjust their contents based on specified criteria each time Update Manager downloads new patches, keeping remediation current without manual baseline maintenance. Fixed baselines are also available for environments that require explicit control over which patches are applied. Hardware Support Manager (HSM) plugins extend vLCM to manage vendor-specific firmware and driver updates alongside software patches, providing unified lifecycle management for both software and firmware from within the same interface. Firmware updates through Hardware Support Manager are only available for clusters and hosts managed with vSphere Lifecycle Manager images; hosts managed with baselines do not support firmware updates through this mechanism.

The remediation workflow is coordinated through multiple layers. Coordinator Manager runs pre-checks before remediation begins to evaluate how each host in the cluster is affected and whether additional steps are needed. Pre-checks verify component connectivity, version compatibility, and component status. The ESX Updater Manager then handles the actual remediation on each host. Coordinator Manager also allows administrators to query the status of the remediation operation for the cluster and for each individual host, providing centralized visibility into remediation progress. The VCF Operations cluster transition specification includes a remediationOptionsSpec with a configurable remediationFailureAction that supports automatic retry with adjustable retryCount and retryDelay parameters, allowing administrators to define consistent remediation behavior.

VCF Operations extends lifecycle management with patch planner functionality for VCF core components, including the ability to download and manage upgrade, patch, and install binaries. Pre-update validation performs health checks and compatibility verification before patches are applied, and component interdependency management helps maintain compatibility and stability across the infrastructure during updates. All dependent elements related to package objects are added to packages automatically to help maintain compatibility between versions. VCF Operations also provides compliance management capabilities that detect violations, highlight risk areas, and provide actionable remediation recommendations, with out-of-the-box workflows mapped to recommendations and associated with specific alerts for automated remediation.

VCF supports programmatic management of the patching process through multiple interfaces. The VMware vCenter patching API supports discovery of all available and applicable updates for vCenter instances in the environment, including minor in-place updates and major migration-based updates. REST API endpoints provide operations for checking pending updates, requirements checking, staging, and installation. The life cycle management API provides operations for listing all available updates and upgrades and generating a pre-check compatibility report before applying updates. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, and the Update-Entity operation remediates hosts by applying baselines with configurable failure handling and retry behavior. PowerCLI provides the Update Manager module with cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating hosts, including a Test-Compliance command to verify entities against

downloaded patches. The vCenter Appliance itself can be patched via the vCenter Appliance Management Interface (VAMI) or the appliance shell; VMware distributes vCenter patches in two forms, ISO-based and URL-based, and the `software-packages` utility in the appliance shell supports both methods, including staging patches from a repository URL, installing directly from a URL without staging, or installing from an attached ISO image. These interfaces enable integration with external change management and orchestration systems for automated remediation workflows.

VCF includes several capabilities to reduce patching risk and support continuity during updates. Live Patching updates and restarts discrete components without requiring host evacuation or reboot, as vSphere Lifecycle Manager does not place hosts into maintenance mode when a Live Patch is enforced. Snapshots should be created before patching VCF Operations fleet management to provide a rollback path. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, which evacuates data to maintain object accessibility during updates through durability components. The VCF Download Tool supports a patches-only option and offline depot configuration for managing patch binaries in air-gapped environments.

VCF Operations complements patch application with patch-gap detection for server firmware. It monitors hardware properties across the fleet, including BIOS version and BIOS release date, and provides dashboards that flag hosts running outdated server BIOS. This detection capability helps administrators identify hosts that require firmware patching before they become a compliance or security gap.

The VCF Consumption layer, implemented through vSphere Supervisor and VMware Kubernetes Service (VKS), extends this patching coverage to Kubernetes control plane components and cluster add-ons. VKS clusters use a rolling update model where updates are initiated by changing the cluster specification; the Supervisor reconciler applies changes node by node to maintain cluster availability during the process. This model covers control plane components including kube-apiserver, kube-controller-manager, kube-scheduler, etcd, kubelet configuration, and CoreDNS, all updated through the kubeadm upgrade mechanism. Kubeadm supports targeted patching of individual components through a patches directory; files named with the pattern `target[suffix][+patchtype].extension` (for example, `kube-apiserver0+merge.yaml` or `etcd.json`) apply strategic merge patches, merge patches, or JSON patches to the specified component. The patches mechanism is available through the InitConfiguration, JoinConfiguration, and UpgradeConfiguration APIs, providing consistent patching behavior across cluster initialization, node join, and upgrade operations. Instance-specific patches can also be applied over the base KubeletConfiguration through kubeadm customization.

VKS clusters support add-on management that enables installation and updates of standard packages through versioned add-on repositories. Administrators can track and update packages such as istio, harbor, sriov-network-device-plugin, windows-gmsa-webhook, and vsphere-pv-csi-webhook as new versions become available. For container image currency, Harbor is available as a Supervisor service and provides vulnerability scanning and content trust capabilities to help identify images that require patching. Admission controllers, including validating webhooks and image pull policies, can be configured to restrict deployment of images that have not passed vulnerability scanning or that contain known vulnerabilities, integrating image patch compliance into the workload deployment workflow. Content library VM images deployed in the vSphere Supervisor environment should be created with the latest patches and required security settings aligned with organizational security policies. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS node releases (VKRs), providing prescriptive hardening guidance that defines what patches and configurations constitute a compliant deployment for the Kubernetes consumption layer.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend) contributes to continuous vulnerability remediation by providing network-level threat detection and automated remediation capabilities that address known and emerging threats across protected workloads.

vDefend Distributed IDS/IPS detects known attack signatures across east-west traffic within the data center. The IDS/IPS engine supports CVE-based signature searches, allowing administrators to identify and enable signatures that address specific newly disclosed vulnerabilities. Knowledge-based signatures cover attacks that are already known and documented; for custom applications and zero-day scenarios, administrators can author custom IDS/IPS signatures that extend detection beyond the standard signature set. This combination of vendor-maintained and custom signatures allows organizations to

respond to new vulnerability disclosures by deploying detection rules that identify exploitation attempts before patches can be applied.

Security Services Platform's Security Assessment generates Security Segmentation Reports and Blast Radius Reports that identify at-risk workloads, communication chains, and network flows, providing the visibility needed to plan and prioritize remediation activities. Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test. Security Services Platform provides remediation workflows that translate detected threats into actionable security policy changes. When IDS/IPS or Gateway Firewall events identify malicious activity, administrators can apply remediation actions that create or modify Distributed Firewall rules and IDS/IPS policies to block the identified attack vectors. Two remediation strategies are available: Targeted remediations create narrow, precise policies that address the specific threat with minimal impact to existing workloads, while Comprehensive remediations create broader policies that defend against similar attack patterns. Intelligent Assist automates the selection between these strategies and handles the creation of groups, security profiles, rules, and policies needed to implement the remediation. The Response and Remediation feature performs automated policy creation based on user role and permissions.

Security Services Platform supports ongoing security posture management through asset inventory classification and traffic monitoring. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workload communication patterns change. Security Intelligence generates microsegmentation recommendations by analyzing inventory assets to create or update vDefend sections. The Security Segmentation Score Breakdown report details protection coverage across environment pairs and highlights pairs that lack inter-environment policies, making coverage gaps easier to identify and address.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.4

> Validate Security Measures

SCF Controls: CHG-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms that support verification of cybersecurity and data protection control functionality following changes, though the organizational process of systematically defining when verification is required and documenting results remains an additional responsibility.

VCF Operations includes a Configuration Drifts capability that monitors vCenter instances and vSphere clusters for deviations from assigned configuration templates. When a change is made, scheduled drift detection compares current configuration values against the desired state defined in those templates. Any deviation is flagged, and administrators can view and download drift status reports from the Configuration Drifts dashboard. Configuration templates can be integrated with a source control repository for versioning and change control, supporting automated testing and validation of configuration updates after changes are applied.

At the host and cluster level, vSphere Configuration Profiles manage the configuration of all hosts in a cluster collectively, ensuring consistency and detecting when individual host configurations deviate from the cluster-level desired state. vSphere Lifecycle Manager extends this to software specifications, offering compliance check operations that return the compliance status of each host in a cluster against the committed desired state. Together, these mechanisms allow administrators to confirm that host-level security controls remain intact after patching, upgrades, or configuration changes.

VCF Operations continuously monitors infrastructure objects against configured compliance benchmarks and identifies non-compliant objects along with their specific violations. When non-compliance is detected, VCF Operations provides actionable remediation recommendations. Automated remediation actions can also be configured to bring objects back into compliance based on severity. Separately, VCF includes automated compliance assessment capabilities for vSphere security controls based on the VMware vSphere Security Configuration Guide. These assessments can be run after changes to confirm that host and virtual machine configurations remain aligned with the established security baseline, where drift from the baseline after a change would indicate that a control is no longer functioning as intended.

NSX Manager maintains detailed audit logs that capture both old and new values for modified security policies. When a security policy is changed, the audit log records the user who performed the operation, the security policy identifier, rule configurations, action types, and sequence numbers. This level of detail allows administrators to review exactly what changed in a security policy and compare the before-and-after state, which is a foundational step in verifying that security controls continue to operate as designed after modifications.

Lifecycle management operations include built-in precheck validation. VCF Operations requires a precheck validation step before management component upgrades can proceed, and NSX Manager's upgrade coordinator includes pre-checks to validate upgrade readiness. These prechecks help confirm that the environment is in a known-good state before changes are applied.

VCF Automation provides a Content and Policies interface that identifies custom forms containing actions that cannot be validated. The Form Actions tab in the custom form designer lists all actions used in a form, allowing administrators to review non-validatable actions and verify their input validation code. This provides a mechanism for verifying that automation-driven controls continue to enforce expected behavior after form or policy modifications. VCF Automation day 2 action policies control which users can run selected actions on deployed resources, with only users matching the policy criteria permitted to execute those actions. After changes to these policies, administrators can review the policy configuration to confirm that the intended access restrictions remain in place.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor provide additional mechanisms for verifying security control behavior after changes. Pod Security Admission supports three enforcement modes

that can be set independently per namespace: enforce, audit, and warn. The enforce mode blocks pods that do not comply with the configured Pod Security Standard; the audit mode logs non-compliant pod creation attempts without blocking; and the warn mode returns a warning to the API client without blocking. VKS cluster management provides out-of-the-box security policy templates, including baseline and restricted profiles that mirror Pod Security Standard definitions, and custom policies can be created in Dry run mode to observe their impact before enabling full enforcement. After a change to Pod Security Admission configuration, operators can apply the restricted profile in audit or warn mode to observe which workloads would be affected, with the audit log capturing the results for review.

Kubernetes ValidatingAdmissionPolicy bindings support validationActions of Deny, Warn, and Audit to control how validation failures are handled during admission. When set to Audit, policy violations are recorded in the Kubernetes audit log without blocking traffic, allowing operators to observe policy match behavior after a policy change without disrupting production workloads. The FailurePolicy field governs behavior when a policy expression fails to evaluate, and bindings are scoped to namespaces so that namespace-level labels determine enforcement scope. After deploying or modifying a ValidatingAdmissionPolicy, operators can submit representative test resources to verify that validation rules fire as intended.

Kubernetes RBAC provides a SelfSubjectAccessReview capability that allows operators to query whether a given subject holds a specific permission on a given resource, enabling direct confirmation that role bindings are applying as intended after changes to Roles, ClusterRoles, RoleBindings, or ClusterRoleBindings. Pod security contexts can also be reviewed after policy changes to verify that individual workloads are operating within the intended privilege boundaries.

At the Supervisor infrastructure level, core cluster component pods such as etcd and kube-apiserver record restart events and uptime duration. After configuration changes that affect the cluster control plane, operators can examine these health indicators to confirm that cluster infrastructure components remain continuously operational and that changes have not disrupted core control functionality.

For resilience control verification, VKS cluster management supports backup and restore of entire clusters, selected namespaces, or specific resources identified by a label, managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management. The Velero Plugin for vSphere supports both stateless and stateful applications and allows restore operations to be initiated from the Data Protection tab, including restoring a backup from a source cluster to a different target cluster. VKS cluster node VMs are backed up and restored through Supervisor state backup using the vCenter backup feature. After changes to backup or storage configuration, performing a test restore from a recent backup confirms that the resilience control is functioning correctly.

Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Service release nodes (VKrs) are available to guide hardening verification for the Kubernetes platform layer, providing a reference baseline against which post-change configuration compliance can be assessed.

These capabilities provide the technical building blocks for post-change control verification across the full VCF platform: configuration drift detection, compliance benchmarking, audit logging of security policy changes, upgrade prechecks, automation policy review, Pod Security Admission audit modes, admission policy verification, Kubernetes RBAC inspection, and VKS backup restore testing. However, they do not by themselves constitute a complete verification program. Organizations must establish procedures that define when functional verification is required, what controls to test after specific types of changes, how to perform functional testing of whether security controls are actively blocking, detecting, or enforcing as intended, and how to document verification results.

VMware vDefend (Contributes)

VMware vDefend and the Security Services Platform (SSP) provide several mechanisms that help organizations verify that network security controls continue to operate as intended after changes to firewall policies, segmentation rules, and threat protection configurations.

The Security Services Platform's Security Intelligence feature includes a Monitoring capability that checks for changes in the scope of input entities every hour when enabled. When a change is detected, affected policy recommendations are flagged with a "change-detected" status indicator. Administrators can review the flagged recommendations through the Policy

Recommendations interface, accessible via Monitor & Plan, and rerun the analysis to confirm that segmentation policies and firewall rules remain consistent with the intended security posture after an infrastructure or policy change.

The Rule Analysis feature on the Security Services Platform provides a structured mechanism for verifying the efficiency and correctness of Distributed Firewall rules. When activated, Rule Analysis evaluates rule configurations and generates reports identifying redundant, shadowed, or misconfigured rules. After changes are made to firewall policies, running Rule Analysis helps confirm that the updated rule set operates as intended and that no unintended effects have been introduced. The feature's operational status is visible in the Security Services Platform UI at System > Platform & Features by checking the Rule Analysis feature card Status field.

The Security Services Platform extracts all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with one another. This supports a verification workflow where policy consistency across IDS and threat prevention configurations can be reviewed following changes. Before republishing policies, administrators can also review infrastructure and environment rules through the Review & Add Rules interface for the SSP-Infrastructure policy, confirming that rules are free of error conditions before propagating changes to the enforcement layer.

The Security Services Platform System > Overview page displays the current platform status, allowing administrators to assess stability before and after configuration changes. Feature-specific status indicators are available at System > Platform & Features, where the Rule Analysis and Malware Prevention feature cards each display a current operational status that administrators can check following updates or changes. The platform's deployment wizard also conducts validation checks before implementing configuration changes, reducing the risk that a change introduces a misconfiguration that could silently degrade security control effectiveness.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several mechanisms that help verify data protection controls remain functional after changes to the environment.

Test recovery operations are the primary verification mechanism. Administrators can run test recoveries at any time to confirm that recovery plans execute correctly without affecting production workloads. Each test exercises the full recovery workflow, including virtual machine startup, network reconfiguration, and any custom steps defined in the plan. Recovery plans transition through defined states during testing, moving to a Test Complete state when the test finishes or a Test Interrupted state when a failure occurs during execution. This state tracking provides immediate visibility into whether data protection controls are operating as designed following any change.

Recovery plan history reports capture the result and timestamps for each plan execution and for individual steps within the plan. These records can be exported for documentation and compliance purposes, giving change management teams evidence that data protection controls were exercised and verified after changes. PNR explicitly requires that protection groups and recovery plans be verified following upgrades to the Protection and Recovery Appliance, and that connections between protected and recovery sites be validated for correctness after any upgrade.

Protection group state monitoring surfaces configuration problems that result from environmental changes. Protection and Recovery protection groups monitor the status of virtual machines and determine which operations are allowed in each protection state. Groups transition through well-defined states including Configuring Protection, Removing Protection, Restoring Placeholders, and Operations in Progress. When protection is disrupted by a change, the affected group transitions to a state that restricts test recovery and planned migration operations, surfacing the problem before a recovery attempt is made.

Alarms provide proactive notification when changes affect data protection controls. Alarms are generated when connectivity problems occur or when protection groups and recovery plans enter an error state, allowing administrators to detect and remediate issues promptly.

PNR introduces an Advanced Cyber Compliance (ACC) subscription that extends verification capabilities. With ACC enabled, Cyber Recovery can install security sensors on virtual machines during the validation phase to perform vulnerability analysis, behavioral analysis, and malware signature scanning. This adds an active security verification layer alongside the existing

snapshot integrity and replication status checks. The ACC subscription also enables use of the Latest instances option in recovery plans, providing additional recovery point selection capabilities for verification testing.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support verification of security control configurations following changes. The Avi Controller CLI includes the ``show networksecuritypolicy`` command, which allows administrators to inspect the current state of Network Security Policies and confirm that changes have taken effect as intended. At the virtual service level, Avi WAF Policies attach a Positive Security group that applies learned application data and defines hit and miss actions, giving administrators a direct view of the rules actively enforced after a WAF policy modification. The ``learned-data-promotion-location`` setting controls which learned application data is promoted to Positive Security rules, allowing administrators to validate that the correct data has been incorporated following a change.

For correlating configuration changes with observed effects, the Service Engine Analytics Config Events overlay lets administrators identify whether a shift in traffic behavior was caused by a specific configuration modification, such as an update to virtual service security settings. This provides a post-change verification path that links configuration actions to traffic outcomes in a single view. Individual Layer 4 Policy Set rules provide a mechanism to control the behavior of Layer 4 virtual services by evaluating Layer 3 and Layer 4 attributes, allowing targeted policy modifications to be assessed in isolation.

ControlScripts are Python-based scripts that execute on Avi Load Balancer Controllers and are initiated by Alert Actions triggered by system events. They can alter Avi Load Balancer configuration or communicate with remote systems such as email, syslog, and SNMP servers, enabling automated post-change health checks and notification workflows. Alert Actions can also trigger ControlScripts to automatically add offending client IP addresses to a blocklist attached to a Network Security Policy, providing a feedback loop between detection and enforced policy state. The Application Security Report generates a downloadable PDF documenting security findings and pre-check results, supporting structured post-change documentation.

For deployments integrated with VCF, the Avi Load Balancer for VCF documentation specifies that Avi Management Plane alarms, alerts, and dashboards must be operational as part of post-upgrade validation, establishing explicit criteria that administrators can check following software changes.

The control's question asks whether the organization verifies control functionality as a deliberate process. Avi's observability features, CLI inspection tools, Config Events overlay, and ControlScript automation support that activity by making control state visible and queryable after a change. The organization must define acceptance criteria, expected baselines, and approval workflows. Avi does not automate the organizational verification decision itself.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.5

> Perform Periodic Internal Penetration Tests

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

